

HDF5 Audit Report

Gerd Heber and Elena Pourmal

HDF5 is a foundational component of the scientific software ecosystem, yet its safety, security, and privacy properties warrant analysis across component boundaries. This report presents a targeted, ecosystem-level technical audit of the core library and file format, command-line tools, extension mechanisms (VOL connectors, filter plugins, and virtual file drivers), selected language bindings and applications, the upstream and downstream software supply chain, representative independent format implementations, and long-term data-accessibility concerns.

Two themes dominate. First, HDF5's CVE history is not a collection of unrelated defects but a small number of recurring root-cause classes, chiefly the use of unvalidated file-derived sizes, counts, and offsets in low-level C memory operations. We therefore argue that patching individual crashes is insufficient and propose a program built on an explicit invariant registry for each on-disk structure, a two-phase parser boundary separating decode from object construction, centralized checked arithmetic, structure-aware fuzzing, and file-open security profiles that make hostile input a first-class concern. Second, privacy exposure in HDF5 arises largely from normal, correct operation rather than from an attack: the format's self-describing metadata, structural layout, workflow artifacts, and extension mechanisms can disclose sensitive information even when raw data are protected. Encryption is a necessary but partial control.

Throughout, we frame the recurring failure as trust-boundary confusion and give risk-informed mitigations together with a distinct implementation-planning framework for library maintainers, extension authors, downstream projects, and end users. Although the subject is HDF5, the analysis is intended to generalize to comparable open-source scientific data ecosystems.

Acknowledgments: This material is based upon work supported by the U.S. National Science Foundation under Federal Award No. 2534078. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the National Science Foundation.

Revision History

Version Number	Date	Comments
v1	July 4, 2026	Initial draft released for internal review.
v2	August 31, 2026	Public release.

Contents

1. Introduction	7
1.1. Purpose and Engagement Type	7
1.2. Objectives and Intended Audience	7
1.3. Scope	8
1.4. Assessment Dimensions	10
1.5. Temporal Boundary and Evidence Basis	11
1.6. Methodology	12
1.7. Report-wide Risk Rating and Mitigation Planning	13
1.8. Limitations and Assurance	19
1.9. Privacy Context	20
2. Assessment Surfaces	22
3. HDF5 Core Library and File Format	24
3.1. Accidents Waiting to Happen – HDF5 Safety	24
3.2. Verify and Verify – HDF5 Security	24
3.3. HDF5 Privacy: Assets and Exposure	25
3.3.1. Introduction	25
3.3.2. HDF5 Assets and their Exposure	27
3.4. HDF5 Tools	31
3.4.1. Privacy exposure through HDF5 command-line tools	31
3.5. Audit Findings and Mitigation Planning	35
3.5.1. Security and Safety	35
3.5.2. Privacy	49
4. HDF5 Library Extensions	54
4.1. Overview	54
4.2. Virtual Object Layer (VOL) Connectors	54
4.2.1. Privacy-Relevant Mechanisms for VOL Connectors	54
4.3. Filter Plugins	57
4.3.1. Privacy-Relevant Mechanisms for Filter Plugins	57

4.4. Virtual File Drivers (VFD)	61
4.4.1. Privacy-Relevant Mechanisms for VFDs	61
4.5. Architectural Observations and Mitigation Planning	64
4.5.1. Privacy	65
5. HDF5 Wrappers and Language Bindings	72
5.1. Overview	72
5.2. Python	72
5.3. Java	72
5.4. Audit Findings and Mitigation Planning	72
6. Applications using HDF5	73
6.1. Boundary Case Study: External Raw Storage and the Hugging Face Incident	74
6.2. Audit Findings and Mitigation Planning	76
7. HDF5 in the Software Supply Chain	83
7.1. Upstream Dependencies	83
7.2. Downstream Dependencies	84
7.3. Audit Findings and Mitigation Planning	87
8. Independent HDF5 Implementations	89
8.1. Overview	89
8.2. Two Distinct 2026 Chunk-Layout Cases	89
8.2.1. Sufficient but Nonminimal Encoding	90
8.2.2. Contradictory PureHDF Metadata	90
8.3. Audit Findings and Mitigation Planning	91
9. Long-term Data Accessibility and Interpretability	93
9.1. Audit Findings and Mitigation Planning	93
10. Resources	94
References	95

A. Findings Register 101

A.1. Evidence and Scoping Backlog 102

A.2. Response Routing 103

A.3. Evidence Actions Without Assigned Urgency 104

A.4. Core Library, Tool, and Format Findings 105

A.5. Application-Boundary Findings 108

A.6. Independent-Implementation and Interoperability Findings . . . 111

A.7. Evidence-Backlog Record Details 113

B. Phased Mitigation Roadmap 114

B.1. Accountability Roles 114

B.2. Phase Gates and Clocks 116

B.3. Work-Package Register 118

B.4. Acceptance and Closure Evidence 122

B.5. Finding and Evidence-Action Coverage 126

B.6. Change Control and Residual Risk 129

C. CVE History Summary 131

D. Software Supply Chain Details 136

1. Introduction

1.1. Purpose and Engagement Type

This report presents a targeted, evidence-based technical assessment of safety, security, and privacy risks in the HDF5 software and data ecosystem. Its purpose is to identify systemic risk patterns, explain the trust boundaries at which those risks arise, and recommend mitigations for the organizations and individuals that develop, distribute, deploy, or use HDF5.

The term *audit* denotes a documented technical examination. This engagement is not a compliance certification, attestation engagement, penetration test, or exhaustive line-by-line source-code review. It expresses no independent assurance opinion and does not certify that any HDF5 release, application, file, or deployment is safe, secure, privacy-preserving, conforming, or free from defects. Authorship and sponsorship are disclosed in the front matter.

1.2. Objectives and Intended Audience

The objectives of the assessment are to:

1. identify important assets, interfaces, capabilities, trust boundaries, and failure modes across the HDF5 ecosystem;
2. distinguish accidental safety and data-integrity failures from adversarial security failures and privacy harms arising during authorized operation;
3. identify recurring root-cause classes rather than treating individual crashes, CVEs, disclosures, and interoperability failures as unrelated events;
4. examine how risk propagates between the file format, core library, tools, extensions, bindings, applications, supply chain, and independent implementations;
5. distinguish file-format conformance, acceptance by a particular implementation, and safe use in a particular deployment;

6. recommend mitigations attributable to the actors able to implement and enforce them; and
7. identify lessons applicable to comparable open-source scientific data ecosystems.

The primary audience is The HDF Group's maintainers, security responders, release engineers, and technical governance bodies. Additional audiences include extension and plugin authors, binding and independent-implementation maintainers, downstream application and distribution maintainers, operators of data-ingestion services, research-infrastructure teams, data stewards, and security and privacy reviewers.

Recommendations are assigned, where possible, to the layer able to enforce them. A control failure at an application or deployment boundary is not classified as a core-library defect merely because an HDF5 mechanism was involved.

1.3. Scope

Component scope is not binary in this report. The assessment distinguishes the following levels of coverage:

Primary assessment objects. These are the HDF5 on-disk format; the core C library, with emphasis on its handling of file-controlled metadata; HDF5 command-line tools; the capability, trust, and privacy characteristics of VOL connectors, filter plugins, and Virtual File Drivers as extension classes; and HDF5 build, release, and dependency configuration. The report states findings and mitigations for these objects.

Boundary case studies. Selected downstream incidents and interoperability disputes are examined to determine how HDF5 capabilities interact with application authority, deployment policy, or independent implementations. The cases include model and dataset ingestion, external-resource resolution, plugin loading, and conformance disputes involving files produced by independent writers. The referenced projects are not audited as products.

Contextual references. Other components are identified to describe ecosystem reach, dependency relationships, compatibility consequences, or potential exposure. A contextual reference does not constitute an assessment or assurance conclusion about that component.

Case studies and samples are selected purposively according to exposure to untrusted input or ambient authority, evidence of a recurring failure class, interoperability or archival consequence, and relevance to cross-cutting mitigations. They are not a statistical sample and do not support prevalence or frequency estimates.

In this report, *ecosystem-wide* describes the breadth of surfaces considered. It does not mean that every implementation, configuration, or downstream product was examined exhaustively.

Out of scope. The following are outside the engagement:

- HSDS source code, client behavior, REST endpoints, authentication and authorization, tenant isolation, deployment configuration, storage backends, and service availability;
- a complete safety, security, or privacy assessment of HDFView, Keras, TensorFlow, Hugging Face, PureHDF, or any other application, service, framework, or independent implementation cited as a case study or ecosystem dependency;
- general AI or machine-learning safety, model behavior, training, inference, and framework functionality unrelated to an HDF5 integration boundary;
- detailed assessment of MPI semantics, collective-I/O correctness, concurrency, fault tolerance, performance, or parallel-filesystem security in Parallel HDF5;
- exhaustive review or testing of every HDF5 release, platform, build configuration, compiler, filter, connector, binding, application, package, or independent implementation;
- penetration testing of production services, exploit development, or proof that every defect or vulnerability class has been identified;

- assessment of a particular organization's production infrastructure, credentials, identity systems, network controls, or operational procedures, except as context for a cited incident or mitigation; and
- legal, regulatory, contractual, research-ethics, or functional-safety certification.

References to HDFView identify downstream exposure or reader behavior, not an HDFView finding. References to machine-learning frameworks or services concern only their handling of HDF5-controlled inputs. References to Parallel HDF5 are limited to the configuration, dependency, extension, or trust-boundary characteristics expressly discussed.

HSDS may appear in ecosystem diagrams for context, but no conclusion about HSDS should be inferred.

1.4. Assessment Dimensions

Safety. Safety means operational robustness and protection of data integrity, availability, recoverability, interoperability, and long-term accessibility in the absence of a malicious actor. Relevant conditions include malformed, truncated, inconsistent, or partially written files; resource exhaustion; I/O failure; incompatible implementations; and foreseeable misuse. Safety in this report does not mean regulated functional or physical safety.

Security. Security concerns the possibility that an adversary can compromise confidentiality, integrity, or availability, or cause a process to exercise authority contrary to the operator's intent. The principal threat scenario is an HDF5 file, metadata field, external reference, plugin requirement, archive, or model artifact controlled by an untrusted party and processed by an application possessing filesystem, network, compute, plugin-loading, or credential authority.

The assessment includes memory-safety defects, denial of service, resource exhaustion, external-resource resolution, dynamic code loading, downstream deserialization, and supply-chain compromise. A security consequence does not require

a defect in the HDF5 format or parser: an intentional HDF5 capability can become an attack mechanism when a downstream application interprets file-controlled instructions using authority unavailable to the file's originator.

Privacy. Privacy concerns adverse consequences arising from the disclosure, retention, inference, aggregation, correlation, or secondary use of information. Such consequences may arise during authorized and otherwise correct operation, without a security breach. The assessment includes scientific data, descriptive and structural metadata, object names and attributes, provenance, workflow artifacts, caches, temporary copies, external resources, and information that becomes sensitive when datasets are combined.

The report evaluates privacy-exposure mechanisms and possible technical or governance controls. It does not determine compliance with privacy statutes, regulations, contracts, consent requirements, institutional policies, or research-ethics obligations.

1.5. Temporal Boundary and Evidence Basis

The evidence cutoff for this revision is August 27, 2026. Public evidence available on or before that date is eligible for consideration. Later developments are outside this revision unless expressly incorporated as subsequent-event updates.

The historical analysis has no fixed lower date and includes earlier releases where necessary to examine cited vulnerabilities, compatibility behavior, and implementation changes. Because this is a historical, ecosystem-level assessment, no single software baseline applies. A conclusion concerning one release, commit, build configuration, platform, or third-party version is not presumed to apply to others. Version-specific conclusions are bounded by the artifact identifiers cited with them. Where an exact artifact is not identified, a statement should be read as an architectural or historical class-level observation, not as a release-specific conclusion.

The principal evidence consists of published HDF5 specifications and API documentation; selected source code and build configurations; security policies,

advisories, and CVE records; issue and pull-request discussions; cited commits and regression artifacts; and authoritative documentation or incident reports from representative downstream and independent projects.

1.6. Methodology

The engagement uses a qualitative, risk-informed technical-assessment method:

1. **Surface and trust-boundary mapping.** The ecosystem is decomposed into format, parser, tool, extension, binding, application, supply-chain, independent-implementation, and data-lifecycle surfaces.
2. **Asset and harm analysis.** The assessment identifies relevant data, meta-data, code, credentials, compute and storage resources, availability, interoperability, and interpretability, together with plausible safety, security, and privacy consequences.
3. **Document and artifact examination.** Specifications, documentation, public source artifacts, vulnerability records, fixes, issue records, build configuration, and representative ecosystem documentation are examined.
4. **Root-cause and pattern analysis.** Defects and incidents are grouped by the earliest violated invariant or trust-boundary failure supported by the evidence, rather than only by crash type, CVE identifier, or affected application.
5. **Conformance and interoperability analysis.** Acceptance by one HDF5 reader is not treated as proof that a file conforms to the applicable specification, and rejection by another reader is not treated as proof that it does not. Where implementations disagree, the analysis distinguishes the normative requirement, writer behavior, reader validation, and compatibility policy.
6. **Risk and mitigation analysis.** Adverse-event scenarios are evaluated under the report-wide inherent- risk method in Section 1.7. Recommendations are then analyzed separately for control coverage, enforcing actor, response urgency, implementation dependencies, effort, sequence, and acceptance ev-

idence. Cross-cutting controls and prerequisite protections are distinguished from local remediations.

For incidents involving multiple components, the analysis distinguishes the HDF5 mechanism, the authority supplied by the host application, the failed control or policy boundary, and the resulting impact. The presence of HDF5 in an exploit chain is not, without additional evidence, classified as a parser or file-format defect.

The report distinguishes, where practicable, among:

Documented observation: directly supported by a cited specification, source artifact, test, advisory, incident record, or maintainer diagnosis; the applicable discussion distinguishes source-reported evidence from independent reproduction;

Reasoned inference: a conclusion drawn from observations, with material assumptions and uncertainty identified; and

Recommendation: a proposed control to be validated through implementation and acceptance evidence.

Unless a finding expressly records an independent reproduction or test, it should be understood as the result of document, artifact, or architecture examination rather than independent dynamic verification.

1.7. Report-wide Risk Rating and Mitigation Planning

This subsection defines the only risk-rating method used in this report. A formal rating applies to a specific adverse-event scenario, not to a technology, chapter, CVE count, root-cause family, recommendation, or implementation task. Each rated finding states, directly or by reference, the assessment object and affected version or surface; the initiating actor or non-adversarial event; the condition, exposure, and material preconditions; the assets or people affected; the credible consequence; and, when time materially affects the rating, the assessment horizon.

Materially different versions, deployments, preconditions, or consequences are rated separately.

A risk scenario can be summarized as follows:

Given [actor or non-adversarial event], [assessment object and scope], and [exposure and preconditions], [condition or event] may cause [harm] to [assets, people, operations, or other organizations] [during the material assessment horizon, if any].

Inherent risk. Inherent risk is the risk presented by the stated scenario in its defined assessed population and deployment. It includes only controls that are mandatory and intrinsic to the identified implementation, version, and scoped default configuration; it gives no credit for optional, compensating, organization-specific, or proposed controls. A feature, configuration, privilege, or user action required to reach the condition is a scenario precondition and informs exposure; it is not an implementation-effort factor. A disabled-by-default or opt-in state constrains exposure only when that state is part of the stated scope. Deployments in which the feature is enabled are rated separately when the difference is material.

Where the effectiveness and coverage of existing controls are supported by evidence, a finding may also state *current residual risk*. A *target residual risk* may be projected for a recommendation, but it is not treated as achieved until the control passes its acceptance criteria. Neither current nor target residual risk replaces the inherent-risk rating. When a residual rating is stated, it uses the same criteria and identifies the controls credited in the assessment.

Inherent risk combines the impact and exposure levels in Table 1 using Table 2. Exposure is the rubric's reachability and recurrence axis: it expresses how readily and commonly the scenario arises under the stated conditions, not a numerical probability. The axes and tiers are ordinal; their labels are not numeric scores and are not multiplied.

Table 1 – Report-wide impact and exposure criteria

Level	Name	Decision rule
I1	Limited impact	Transient or localized effect with routine recovery; no material incorrect result, durable data loss, sensitive disclosure, or harm to individuals.
I2	Material impact	Meaningful workflow interruption; recoverable data loss or corruption; a persistent but bounded compatibility or scientific-validity problem; or limited disclosure, inference, or privacy harm affecting a defined population.
I3	Serious impact	Major data loss, corruption, or outage; process compromise or unauthorized resource access; consequential scientific invalidity; or substantial sensitive- information disclosure or privacy harm.
I4	Severe or systemic impact	Widespread, cross-tenant, or privileged compromise; irreversible loss of unique or critical scientific records; large-scale disclosure of highly sensitive information; or ecosystem- or mission-level disruption.
E1	Exceptional exposure	The scenario requires an unusual configuration and several restrictive preconditions, affects a narrow surface, and is exceptional within the stated assessed population.
E2	Constrained exposure	The scenario is realistic but limited to an opt-in feature, restricted actor capability, uncommon workflow, or multiple material preconditions.
E3	Broad exposure	The scenario arises in a common workflow or deployment, has few material preconditions, commonly crosses a trust boundary, or recurs within the stated assessed population.
E4	Routine exposure	The scenario arises during default or normal operation, is broadly reachable and repeatable, or is straightforward to trigger or automate. Malicious intent is not required for safety or privacy harm.

Table 2 – Report-wide inherent-risk matrix

Impact	E1	E2	E3	E4
I4 Severe/systemic	High	High	Critical	Critical
I3 Serious	Moderate	High	High	Critical
I2 Material	Low	Moderate	Moderate	High
I1 Limited	Low	Low	Moderate	Moderate

The following decision rules apply:

1. Use the greatest credible impact supported by evidence, not an unconstrained theoretical worst case.
2. Judge exposure from the stated reachability, preconditions, deployment prevalence, and recurrence. A confirmed incident establishes feasibility but does not by itself establish ecosystem-wide exposure. Absence of adequate prevalence or recurrence evidence changes confidence or rating status; it does not establish E1.
3. Rate the scenario at the boundary where authority and control reside. Participation in an exploit chain does not assign the full impact to every component in that chain.
4. Split findings when affected versions, deployment profiles, or consequences would produce materially different ratings.
5. Do not add or average safety, security, and privacy impacts. Record each applicable dimension and identify the substantiated impact that controls the overall rating.
6. Do not translate CVSS scores, CVE counts, publicity, privacy-exposure category codes, or recommendation numbers into this rating.
7. State a time horizon when it materially affects impact or exposure. Do not directly order ratings that use materially different horizons.

Evidence confidence and rating status. Confidence records uncertainty in the evidence and is separate from both exposure and risk:

High confidence. Direct, scope-specific primary evidence supports the condition and material rating assumptions through reproduction or mutually consistent specification, source, fix, and test artifacts.

Moderate confidence. Credible primary evidence supports the scenario, but an important element such as reproduction, prevalence, version boundaries, or causal attribution remains incomplete.

Low confidence. The scenario or rating depends materially on incomplete, disputed, secondary, or uncorroborated evidence.

Confidence is not multiplied into, added to, or subtracted from inherent risk. If uncertainty could change the tier, the report gives the plausible range and the controlling assumptions rather than silently lowering the rating.

A rating record also states one of the following statuses:

Rated. Both axes and the resulting tier are supported by the cited evidence.

Provisional. Both axes can be estimated, but material uncertainty remains and is expressly stated.

NE—not evaluated. At least one axis lacks sufficient evidence. An NE finding is not implicitly Low risk.

N/A—not applicable. The item is not a risk-bearing finding, such as a recommendation, implementation task, or program theme.

Narrative findings that do not state impact, exposure, tier, status, and confidence carry no formal report-wide rating.

Risk and implementation planning are separate. The risk record and the recommendation record are separate. The following planning fields never change the inherent-risk rating:

Table 3 – Treatment-planning fields kept separate from inherent risk

Field	Recording rule
Response urgency	Records <i>Immediate</i> , <i>Near-term</i> , <i>Planned</i> , or <i>Monitor</i> , with the rationale and target horizon. It is determined from current residual risk, time to harm, active exploitation or recurrence, and stated risk tolerance—not from dependencies or effort.
Implementation dependencies	Lists concrete prerequisite recommendation or decision identifiers. Use <i>None known</i> when none are identified and <i>TBD</i> when dependency analysis has not been performed; do not encode dependencies as severity.
Effort	Records <i>Not estimated</i> , <i>Small</i> (localized change), <i>Medium</i> (multi-module or coordinated change), or <i>Large</i> (architectural, cross-project, compatibility, or migration work). Estimate work independently of elapsed duration or delivery horizon. Effort is not subtracted from risk.
Implementation sequence	Records a delivery wave or order together with its concrete prerequisite or enabling rationale. Recommendation identifiers alone do not establish sequence, and delivery order is not a risk rating.
Owner and target horizon	Names the actor with authority to implement or accept the recommendation and the intended completion date or release.
Acceptance evidence	States the observable test, artifact, or operational evidence required to mark the recommendation complete and reassess residual risk.
Residual-risk decision	Records the verified remaining rating and the accountable decision to accept, further reduce, avoid, or transfer it.

Unless a stricter stated risk tolerance applies, the default response-urgency rule maps Critical current residual risk to *Immediate*, High to *Near-term*, Moderate to *Planned*, and Low to *Monitor*. Active exploitation or recurrence, imminent harm, or a credible irreversible consequence can raise urgency. When current residual risk has not been assessed, inherent risk is the conservative provisional baseline. Dependencies and effort may shape the delivery plan or require an

interim containment action, but they never lower response urgency. Any departure from this mapping requires a recorded rationale and accountable decision.

A Critical scenario remains Critical even when its mitigation is high effort. An enabling action may appear earlier because it is a prerequisite; the action does not thereby acquire a risk rating. Immediate containment and a later architectural treatment may therefore address the same finding on different delivery horizons.

Every formal finding record should contain a stable identifier, scenario, dimension, affected scope, evidence, I/E rationale, an inherent-risk tier when evaluated or explicit no-tier/NE notation, rating status, confidence, and linked recommendation identifiers. Every recommendation record should separately identify the findings addressed, enforcing actor or owner, urgency, dependencies, effort, sequence and target horizon, acceptance evidence, status, and residual-risk decision. Numbered recommendation identifiers in later sections identify items only; they do not establish risk, urgency, effort, dependency, or delivery order.

The populated report-wide register is Appendix A. That appendix is authoritative for formal ratings in this revision: chapter narrative, recommendation numbering, CVE metadata, and descriptive uses of words such as “high” or “important” do not create an additional rating unless they map to a registered finding. Appendix B separately groups the recommendations into proposed work packages with accountable roles, dependencies, effort, phase gates, acceptance evidence, and residual-risk decision requirements. Those planning fields do not revise the register’s inherent ratings or represent stakeholder-approved commitments until adopted and assigned.

1.8. Limitations and Assurance

This assessment is time-bounded and based predominantly on public evidence. It is not an exhaustive review of the HDF5 source tree, every file-format feature, every configuration, or every ecosystem component. Representative sampling supports conclusions about observed mechanisms and recurring classes; it does not establish their frequency throughout the ecosystem.

Public CVE and issue records may be incomplete, duplicated, disputed, or subsequently corrected. Deployment-specific exposure and impact depend on application privileges, isolation, resource limits, enabled features, data sensitivity, and provenance. Proposed mitigations are evaluated analytically unless an implementation and verification procedure is expressly cited.

This report provides no formal assurance or certification opinion. Its conclusions are bounded by the assessment objects, methods, evidence, and cutoff described above. The absence of a reported finding does not establish the absence of defects, vulnerabilities, safety failures, or privacy risk.

Inherent-risk ratings express the authors' evidence-based judgment under Section 1.7; an unrated finding is not assumed to be Low risk. Numbered recommendation identifiers do not express risk, urgency, effort, dependency, or sequence. Recommendations become auditable commitments only when paired with an owner, affected scope, target horizon, implementation status, acceptance criteria, and residual-risk decision.

1.9. Privacy Context

The National Institute of Standards and Technology (NIST) defines privacy as “a condition that safeguards human autonomy and dignity through various means, including confidentiality, predictability, manageability, and disassociability.” Historically, privacy was interpreted as preventing unauthorized access to or disclosure of Personally Identifiable Information (PII). However, NIST emphasizes that contemporary privacy risks extend far beyond traditional notions of confidentiality. Modern privacy concerns increasingly arise from inference, aggregation, behavioral profiling, secondary use of data, context changes, and surveillance effects [41]. NIST emphasizes that privacy risks are distinct from cybersecurity risks and may emerge even when systems are secure, lawful, and functioning exactly as intended [11]. HDF5 inherits many of the same classes of privacy risks identified by NIST, although these risks manifest differently in scientific and engineering environments.

HDF5 was designed to maximize data shareability, extensibility, portability, and long-term usability, and doesn't enforce data privacy or provide data protection mechanism. Its rich metadata model, self-describing structure, plugin architecture, and interoperability layers can expose information extending beyond the raw data stored within the file. Sensitive information in HDF5 ecosystems may emerge through HDF5 internal and user-defined metadata, for example, HDF5 attributes, object names, file organization, and objects properties. It may be exposed during HDF5 data lifecycle through provenance records, workflow artifacts, and correlations across multiple datasets and files.

A common misconception in scientific computing is that privacy concerns are resolved once data access is restricted or datasets are anonymized. However, privacy risks often persist even when traditional security mechanisms are correctly implemented. Restricting access does not prevent inference from metadata. Anonymization may remove direct identifiers while leaving contextual information sufficient for re-identification. Similarly, data reduction or aggregation does not eliminate the possibility that sensitive information may be reconstructed through correlations across files, workflows, or external repositories. In modern scientific ecosystems, privacy exposure frequently results from accumulation of data and metadata over time rather than disclosure of a single sensitive piece of raw data or metadata.

The privacy risks are amplified by current scientific practice of data openness and shareability. HDF5 datasets increasingly move across organization, systems, cloud platforms, workflows, and public and private repositories. Data are routinely repurposed beyond their original intent and analyzed by users who were not involved in their creation. Machine learning systems further amplify these concerns by discovering hidden relationships across data stored in HDF5 and enabling new forms of inference that may not have been anticipated when data were originally collected. As a result, data stored in the HDF5 files may experience evolving privacy characteristics through its lifecycle.

Therefore, privacy exposure in HDF5 is not limited to unauthorized access, data breaches, unsafe use, or malicious behavior; it is distinct from, but can overlap with, data security and safety. By design HDF5 file format and library do not

guarantee data privacy. In addition, privacy risks may emerge during legitimate scientific workflows, through data sharing, reuse, and analysis. In this document we audit privacy assets and different privacy exposure mechanisms (or surfaces) in HDF5 with the goal to raise awareness about privacy risks when using HDF5.

2. Assessment Surfaces

Figure 1 maps the principal components and interfaces considered when identifying HDF5 risk. Inclusion in the figure provides ecosystem context and does not override the scope levels and limitations defined in Section 1.3. In particular, HSDS is shown for context but remains outside the engagement.

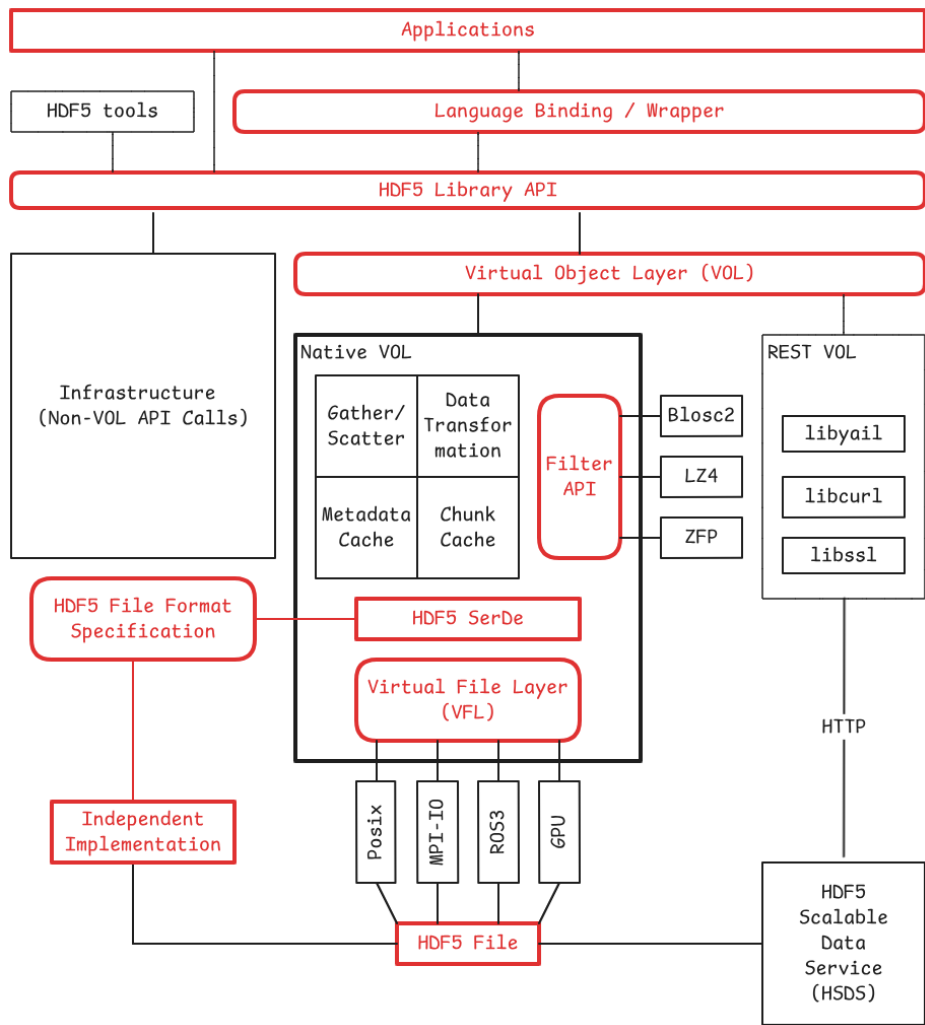


Figure 1 – HDF5 assessment surfaces (interfaces: rounded rectangles)

3. HDF5 Core Library and File Format

3.1. Accidents Waiting to Happen – HDF5 Safety

- Disk full [8]
- File corruption [6]
- Long-term data accessibility and interpretability, see section 9

3.2. Verify and Verify – HDF5 Security

- Integer arithmetic
- File format parsing issues
- Malicious plugins, see section 4

A CVE history summary is included in Appendix C. The list mixes true HDF5-library issues, removed-tool issues, duplicate/rejected/not-HDF5 entries, and entries with no commit URL. The main pattern is not “many unrelated bugs”; it is repeated failure to validate file-derived structure sizes, offsets, counts, message lengths, continuation chunks, datatype metadata, or filter parameters before using them in low-level C memory operations. The 2025 entries alone show repeated heap overflows, use-after-free, null dereference, memory leak, and resource-consumption defects across object headers, file-space metadata, type conversion, filters, and metadata cache code.

The fix commentary confirms that several CVEs were symptoms of corrupted metadata not being rejected early. (Examples: the file-space page-size fix added a sanity check immediately after reading `page_size` from the file; the object-header-continuation fix rejects zero continuation chunk sizes; the self-referential continuation-message fix checks expected versus actual deserialized object-header chunks; and the cache-image fix added buffer-size arguments, overflow checks, input validation, and cleanup.)

The major root-cause categories are tighter than the CVE count suggests, and are summarized in Table 4.

Table 4 – Major root-cause categories in the HDF5 CVE history

Root-cause category	What it means for HDF5
unchecked file-derived sizes / counts / offsets	The dominant class. HDF5 metadata controls object layout, heap blocks, chunks, dataspace, filters, links, and type descriptors. When those fields are malformed, C code later trusts them.
inconsistent internal bookkeeping	Attribute tables, cache images, continuation chunks, and free lists often needed separate “allocated capacity” versus “actual count” tracking.
decode/encode asymmetry	Several issues happen because decode did not reject bad messages, then encode/flush later assumed valid native structures.
arithmetic precondition failures	Divide-by-zero and multiplication-overflow checks were missing in chunking, layout, b-tree, filter, and dataspace paths.
unsafe cleanup/lifetime paths	Use-after-free, double-free, leaks, and null dereferences show that malformed input often breaks unwinding logic as much as the primary decode logic.
unbounded traversal, recursion, loop-progress, and resource-limit failures	File-controlled graphs, dimensions, and metadata can drive recursion, repeated work, or allocation without a structural progress rule or explicit budget.
legacy tool attack surface	gif2h5, HDF to GIF conversion, h5dump, and h5repack appear repeatedly. Removal of gif2h5 was a structural mitigation, not just a patch.
triage quality, duplicate/variant clustering, reachability, and fix-completeness metadata	Several entries have <code>commit_url: null</code> , “not filed against HDF5,” “cannot reproduce,” “not applicable,” or tentative confidence. Those should not be counted as reviewed HDF5 fixes without qualification.

3.3. HDF5 Privacy: Assets and Exposure

3.3.1. Introduction

Privacy risks in the HDF5 core library and file format are not accidental; as discussed in the Introduction, they are systematic and arise from multiple factors. The design and implementation of the HDF5 file format and library present one important source of such risks. Additional risks emerge from scientific

workflows, software ecosystems, interoperability mechanisms, and evolving data usage contexts.

Before describing the assets that require protection in HDF5 and the mechanisms through which privacy exposure may occur, it is important to emphasize several fundamental characteristics of HDF5 and the audit approach adopted in this document.

- *HDF5 privacy primarily concerns accidental or unintended exposure of sensitive information rather than malicious attacks.* Malicious attacks and unauthorized access are primarily addressed through cybersecurity mechanisms and are outside the scope of this section.
- *HDF5, by design, does not provide privacy protections.* When privacy is a concern, users and organizations are responsible for protecting data throughout the entire data lifecycle. In this document, the term data refers not only to individual HDF5 objects within a single file, but also to collections of HDF5 files and external data accessible through the HDF5 library, connectors, and related software components.
- *HDF5 neither implements nor enforces privacy standards.* Furthermore, even when privacy standards and technical safeguards are in place, sensitive information may still be exposed through legitimate data processing, contextual interpretation, pattern discovery, inference, aggregation, and other analytical activities.
- *HDF5 does not manage authentication, authorization, or filesystem protection.* However, privacy risks extend beyond traditional security concerns. Sensitive information may be exposed during legitimate data use by authorized users, even within highly secure computing environments.
- *The risk of sensitive information exposure generally increases over the data lifecycle.* Sensitive information stored in HDF5 may be exposed during any stage of the lifecycle, including data creation, processing, storage, sharing, transfer, reuse, and archival.
- *HDF5 extensibility mechanisms and associated software ecosystems may alter the privacy characteristics of data.* Features such as filters, Virtual

Object Layer (VOL) connectors, Virtual File Drivers (VFDs), and external applications, including conversion and analysis tools, may introduce new privacy exposure surfaces or modify existing ones.

The remainder of this section focuses on the assets that require protection in HDF5, the mechanisms through which sensitive information may be exposed, and potential approaches for mitigating privacy risks.

3.3.2. HDF5 Assets and their Exposure

The primary assets requiring protection are the scientific data themselves. In HDF5, these include data stored in HDF5 objects, such as files, groups, datasets, datatypes, and dataspace, which represent experimental observations, measurements, simulations, images, sensor outputs, and computational results.

Scientific data may be exposed through direct access using HDF5-based software, including command-line utilities, graphical viewers, and programming interfaces such as Python. However, privacy-sensitive information may also be inferred through examination of the low-level storage organization and auxiliary metadata embedded within the file to support portability, interoperability, and efficient data access. For example, string attributes visible through standard operating system utilities (e.g., the Unix strings command) may disclose dataset names, experimental identifiers, or other descriptive information. Similarly, inspection of dataset headers may reveal storage layout, chunk organization, compression methods, or data acquisition patterns (e.g., frame-based acquisition stored as chunked datasets). Examination of embedded strings may also disclose the use of external storage or references to datasets located in other HDF5 files.

It is important to distinguish between protecting access to data values and protecting information about data representation. Even when raw data are protected through mechanisms such as compression or encryption, information describing their storage organization, layout, or access methods may remain accessible and reveal sensitive contextual information about the underlying data or the processes that generated them.

Data Assets

The primary assets requiring protection are the scientific data themselves. In HDF5, these include data stored in HDF5 objects, such as files, groups, datasets, datatypes, and dataspace, which represent experimental observations, measurements, simulations, images, sensor outputs, and computational results.

Scientific data may be exposed through direct access using HDF5-based software, including command-line utilities, graphical viewers, and programming interfaces such as Python. However, privacy-sensitive information may also be inferred through examination of the low-level storage organization and auxiliary metadata embedded within the file to support portability, interoperability, and efficient data access. For example, string attributes visible through standard operating system utilities (e.g., the Unix strings command) may disclose dataset names, experimental identifiers, or other descriptive information. Similarly, inspection of dataset headers may reveal storage layout, chunk organization, compression methods, or data acquisition patterns (e.g., frame-based acquisition stored as chunked datasets). Examination of embedded strings may also disclose the use of external storage or references to datasets located in other HDF5 files.

It is important to distinguish between protecting access to data values and protecting information about data representation. Even when raw data are protected through mechanisms such as compression or encryption, information describing their storage organization, layout, or access methods may remain accessible and reveal sensitive contextual information about the underlying data or the processes that generated them.

Metadata Assets

User-defined metadata often constitute one of the most privacy-sensitive asset classes in HDF5. The format was intentionally designed as a self-describing data model that allows extensive contextual information to be stored alongside scientific data. While HDF5 attributes are the most recognizable form of user-defined metadata, they represent only one category of descriptive information maintained within an HDF5 file.

User-defined metadata include all user-created HDF5 objects and object properties that organize, identify, or describe stored data. These include groups, datasets, their associated datatypes and dataspace, committed datatypes, and attributes attached to HDF5 objects. Each HDF5 attribute is itself a structured metadata object with a name, datatype, and dataspace. Additional metadata assets include file and object names (link names), committed datatype names, compound datatype member names, enumeration labels, object comments, and information stored in the user block. Collectively, these metadata describe the logical organization, semantics, and relationships of the stored data and frequently contain experiment-specific, operational, or organizational information.

Like scientific data, metadata assets may be exposed not only through HDF5 applications but also through direct examination of the binary file format. Inspection of file structures or extraction of embedded strings without using HDF5 software may reveal object names, descriptive attributes, storage relationships, user block contents, and other contextual information that could disclose sensitive information about the data, their origin, or the organization that produced them.

Structural Metadata Assets

Privacy-sensitive information may also be inferred from the structural characteristics of HDF5 files. Structural metadata assets include user-defined organizational structures, such as the hierarchical arrangement of objects, dataset storage layouts (e.g., contiguous, chunked, compact, or external storage), filter pipelines, and relationships established through links, object references, region references, or virtual datasets (VDS). In addition, the HDF5 library maintains internal structural metadata that describe and manage these user-defined structures, including chunk indexing schemes, B-tree organizations, and other implementation-specific data structures.

Even when raw data are inaccessible, for example, because they are encrypted, compressed, stored externally, or protected by file-system access controls, structural metadata may disclose information about the purpose of the data, experimental design, workflow organization, relationships among datasets, or assumptions made by the generating application. Naming hierarchies, grouping strategies, stor-

age layouts, and reference relationships may reveal semantic information about scientific activities or operational processes. Likewise, implementation-specific structures, such as chunk indexing formats or other internal metadata, may disclose characteristics of the HDF5 library version or software implementation used to create or process the file.

Like scientific data and user-defined metadata, structural metadata may be exposed through HDF5 applications or by direct examination of the binary file format without using HDF5 software.

Derived and Reconstructed Information

Privacy-sensitive information in HDF5 may also arise through inference or reconstruction from combinations of available data and metadata. Derived assets include relationships inferred from multiple HDF5 datasets, external links, object references, region references, virtual dataset (VDS) mappings, or information obtained by combining HDF5 data with external sources. These relationships may reveal information that is not explicitly represented within any single dataset or file.

For example, correlating quality-control datasets with experimental observations, combining temporal and spatial measurements, or reconstructing relationships across linked HDF5 files may disclose sensitive characteristics that are not apparent when individual datasets are examined in isolation. Consequently, privacy-sensitive assets extend beyond explicitly stored data and metadata to include information that can be inferred through aggregation, correlation, reconstruction, or other forms of analysis.

Workflow and Applications Artifacts

Privacy-sensitive assets in HDF5 extend beyond data and metadata stored within HDF5 files to include artifacts created by applications, processing workflows, and the surrounding software ecosystem. These artifacts include command outputs (e.g., h5dump output), diagnostic logs, temporary files, metadata snapshots, cached intermediate datasets, conversion artifacts, and outputs generated by plu-

gins or connectors (e.g., binary files produced by an HDF5 VOL connector for another scientific data format).

Examples include VFD SWMR metadata snapshots, cached intermediate results, diagnostic logs, and metadata generated during translation between non-self-describing data formats and HDF5. Such artifacts may expose scientific data, metadata, storage organization, workflow decisions, or implementation details beyond what is contained in the original HDF5 file. Because they are often created automatically, these artifacts may persist beyond their intended lifetime and remain unnoticed by users focused primarily on the scientific datasets themselves.

Scientific data processing workflows routinely enrich, restructure, annotate, and transform datasets to improve interoperability, reproducibility, usability, or analytical value. However, these processes may also introduce or preserve contextual information that was not intended for disclosure. Automatically generated metadata, intermediate processing products, and derived datasets may reveal experimental assumptions, workflow decisions, data provenance, software implementation details, or scientific semantics that were absent from the original data. Consequently, privacy exposure may arise not from malicious activity or unauthorized access, but as an unintended consequence of routine scientific data processing.

3.4. HDF5 Tools

Not strictly part of the core library, but the tools are an important part of the ecosystem and have their own set of issues.

3.4.1. Privacy exposure through HDF5 command-line tools

HDF5 command-line tools provide convenient mechanisms for managing HDF5 files. They can be used to display or extract raw data, and user-defined and structural HDF5 metadata (e.g., `h5dump`, `h5ls`, `h5debug`), edit raw data and attributes with `h5edit`, extract or aggregate data using `h5copy`, change characteristics of HDF5 objects, for example, remove or add data filters and change storage properties using `h5repack`. HDF5 command-line tools are routinely

employed throughout the HDF5 data lifecycle. While the command-line tools are essential for working with HDF5 data, they are ultimate sources of unintended privacy exposure.

The HDF5 tools were designed to ease access to HDF5 data, to reveal information about the contents and organization of HDF5 files, and to manage that information while avoiding steep learning curve of HDF5 programming. I.e., HDF5 command-line tools were designed to expose HDF5 assets. Depending on the tool and the selected options, they may display object names, attributes, datatype definitions, storage layouts, chunking parameters, filter pipelines, external storage locations, object references, virtual dataset mappings, and portions or all of the stored data to name a few. Even when users intend only to verify file integrity or inspect metadata, command output may disclose information that is considered sensitive in a particular context.

Privacy exposure is not limited to information displayed on the terminal by `h5dump` or `h5ls`. Command output is frequently redirected to files, incorporated into automated workflow logs, attached to bug reports, archived as diagnostic information, or shared. The output can be used by other tools (e.g., `h5import`) or applications to generate new data. Consequently, metadata and scientific data extracted by HDF5 tools may persist outside the original HDF5 file and become accessible to individuals who were never intended to access the underlying information.

Several command-line tools may also create new HDF5 files or transform existing ones. `h5repack` and `h5copy` may generate additional copies of data and/or aggregate data, modify storage layouts, remove or add data filtering; `h5edit` may modify and introduce new metadata, change raw data values and preserve information that was not expected to be retained. I.e., the tools can alter the privacy characteristics of the resulting files, particularly when they are incorporated into larger workflows, backups, or public data repositories.

Because HDF5 command-line tools are widely used in automated scripts, continuous integration systems, and scientific workflows, their privacy implications should be evaluated alongside those of the HDF5 library and HDF5-based applications. The privacy mitigation strategies discussed in the next section apply not

only to the HDF5 library itself but also, and often to an even greater extent, to HDF5 command-line tools. This is because these tools are designed to expose HDF5 assets and to generate persistent outputs (e.g., new binary and text files).

The table below summarizes the assets exposed by the listed command-line tools.

Table 5 – Privacy exposure through HDF5 command-line tools

Tool	Exposed assets	Workflow artifacts	Privacy considerations
h5dump	Raw data; user-defined and structural metadata	Text dumps, redirected output, logs	Displays datasets, attributes, datatypes, storage layout, filter information, object references, and VDS mappings. May expose data stored in other HDF5 files through external links and Virtual Datasets (VDS). Output is frequently redirected to files or logs, creating persistent copies of sensitive information.
h5ls	User-defined and structural metadata (optionally raw data)	Terminal output, logs	Reveals object hierarchy, object names, datatypes, storage properties, links, and object relationships. With the <code>-d</code> option, also displays dataset values.
h5repack	Raw data; user-defined and structural metadata	New HDF5 file	Creates additional HDF5 copies while potentially modifying storage layout, filters, and metadata. The <code>-merge</code> option can aggregate datasets reachable through external links into a single file. May access non-HDF5 data through configured VFDs and VOL connectors.
h5diff	Raw data; user-defined metadata	Comparison reports	Reads and compares datasets and attributes. Reports may disclose sensitive values or structural differences.
h5copy	Raw data; user-defined and structural metadata	Additional HDF5 files	Copies objects within or between HDF5 files, increasing the number of persistent copies of sensitive information.
h5stat	Structural metadata	Statistics reports, logs	Reports object counts, storage statistics, chunk information, free space, and other implementation characteristics that may reveal dataset complexity or workflow properties.
h5debug	Structural metadata	Debug output	Displays low-level internal file structures, addresses, B-trees, heaps, chunk indexes, and other implementation metadata intended for debugging.

Table 5 – Privacy exposure through HDF5 command-line tools, continued

Tool	Exposed assets	Workflow artifacts	Privacy considerations
h5watch	Raw data; user-defined metadata	Monitoring output, logs	Monitors SWMR datasets and reports newly written data, timestamps, and update activity in real time.
h5import	Raw data; user-defined metadata	New HDF5 file	Imports external data into HDF5, creating additional copies while potentially preserving metadata and semantics from the source format.
h5jam/h5unjam	User block contents	Extracted or embedded files	Stores or extracts arbitrary information in the HDF5 user block, including scripts, XML documents, application metadata, or proprietary information.
h5mkgrp	Structural metadata	Modified HDF5 file	Creates or modifies the group hierarchy. Limited direct privacy exposure but changes descriptive metadata and namespace organization.
h5edit	Raw data; user-defined metadata	Modified HDF5 file	Creates or modifies attributes; modifies raw data. Limited direct privacy exposure but changes data and user-defined metadata.
h5format_convert	Raw data; structural metadata	Converted HDF5 file	Converts files between HDF5 format versions, creating additional copies while preserving or rewriting internal metadata structures.
h5clear	Structural metadata	Modified HDF5 file	Clears SWMR status and metadata cache information. Primarily affects recovery metadata and file consistency information.

Note: All HDF5 command-line tools are built on top of the HDF5 library and therefore inherit its capabilities. When VFDs or VOL connectors are configured, these tools may transparently access data stored in remote services, external storage systems, or non-HDF5 data sources exposed through connectors. Consequently, privacy exposure is not necessarily limited to the HDF5 file specified on the command line but may extend to the broader HDF5 ecosystem.

3.5. Audit Findings and Mitigation Planning

Formal core and official-tool findings are registered as CORE-SEC-001, CORE-SEC-002, CORE-TOOL-001, CORE-PRIV-001, and CORE-SAFE-001 in [Appendix A](#). The two shared-event security findings are provisional historical parser-boundary scenarios; they do not assert that every current HDF5 release contains every represented defect.

3.5.1. Security and Safety

The selected CVE history shows repeated malformed-file parsing pressure against a complex binary metadata machine. The fix direction should not be “patch each crash.” It should be systematic metadata validation at decode boundaries, explicit invariants for each on-disk structure, fuzz corpora tied to invariants, and hard separation between parser acceptance and internal object construction.

Goal: HDF5 should be able to parse any byte stream as hostile input and either reject it cleanly or produce a validated internal object graph. Anything else is security debt.

Implementation program: define parser invariants first, harden decode boundaries, then make fuzzing, CI gates, and release governance enforce them.

The CORE-S identifiers below are stable identifiers for recommendations in the core-security track. Their numbers do not express risk, urgency, effort, dependency, or implementation order.

Parser normalization is a central recommendation: decode file bytes into a validated intermediate form before constructing internal objects, so malformed metadata cannot reach trusted C paths.

Our goal should be: *make malformed HDF5 files boring*. Every corrupted file should terminate in a controlled H5E_BADVALUE, H5E_OVERFLOW, H5E_

CORRUPT, or H5E_RESOURCE path. No segfaults. No assertions. No leaks. No undefined behavior. No late-stage encode/flush crash from a bad decode.

The current CVE list includes many issues in H5FS, H5C, H5O, H5T, H5Z, and vector-copy paths, with repeated heap overflows, use-after-free, null dereference, and resource-consumption outcomes. HDF5's own format documentation explains why this happens: a file is a graph of groups, datasets, and named datatypes; on disk it is represented through lower-level structures such as the superblock, B-tree nodes, object headers, global heaps, local heaps, and free-space metadata. That means the library is parsing a dense graph of mutually referential, *attacker-controlled* metadata.

Recommendation CORE-S0: Stop closing CVEs as “fixed” unless the class is killed

Adopt the following rule:

If the fix is not a structural change that eliminates the root cause, then it is not a fix.

For every new CVE or crash:

Table 6 – Required artifacts for closing HDF5 CVEs or crash reports

Required artifact	Purpose
crashing input	becomes a permanent corpus seed
minimized input	used in quick PR regression
root-cause category	maps to a known invariant class
invariant update	prevents sibling bugs
sanitizer regression	proves no crash, no leak, no UAF
negative test	checks controlled failure code
reviewer checklist update	prevents reintroduction

This is the first cultural shift. A patch that only adds a local `if` is tolerated for embargoed fixes, but the issue remains open as a **class bug** until the invariant framework catches sibling cases.

Recent commits show the right direction, but too locally. One fix added a sanity check immediately after reading file-space page size from the file and used the same fuzzer to verify that the previous assertion became a corrupted-file error. [20] Another hardened `H5C__reconstruct_cache_entry()` by adding buffer-size tracking, overflow checks, input validation, and safe cleanup. [19] Those are exactly the moves to systematize.

Recommendation CORE-S1: Build an invariant registry for the file format

Create a versioned document and machine-readable metadata file, for example:

```
security/invariants/  
  superblock.yml  
  object_header.yml  
  dataspace.yml  
  datatype.yml  
  layout.yml  
  filters.yml  
  heaps.yml  
  free_space.yml  
  links.yml  
  cache_image.yml
```

Each entry should define:

```
id: H5O-CONT-001  
component: object_header  
structure: continuation_message  
condition: continuation_chunk_size > 0  
failure: H5E_CORRUPT
```

checked_at :

- H5O__cont_decode
- H5O__chunk_deserialize

fuzz_targets :

- fuzz_object_header

cves :

- CVE-2025-6856
- CVE-2025-6816

Start with these invariant families.

Table 7 – Invariant families to enforce first

Area	Invariants to enforce first
superblock	offset size and length size are valid; base address, EOF address, driver info address, and root object address are inside the file or explicitly undefined; EOF does not wrap
object headers	message length fits inside chunk; continuation chunks are nonzero; continuations do not self-reference; continuations are acyclic; message flags match message type; unknown messages cannot be cast into known message structures
free-space meta-data	page size is nonzero and below max; section size fits page/file bounds; serialized section count matches decoded section count
heaps	heap object offset and size are inside heap; free-list blocks do not overlap; free-block list is acyclic; no allocation uses unchecked <code>count*size</code>
dataspaces	rank is bounded; dimension product is checked; selected point count is checked; hyperslab stride, count, block, and start do not overflow
datatypes	storage size is nonzero; precision fits storage size; member offsets fit compound size; string length is bounded; vlen/ref types cannot escape validation
layouts	compact data size equals <code>dataspaceelements*dattypesize</code> ; chunk dimensions are nonzero; chunk product is checked; chunk index references are inside file bounds
filters	parameter count is bounded; decompressed size is bounded; scale-offset precision is validated; filter output ratio cannot exceed configured resource limits
cache image	cache-entry count, address, size, and alignment are bounded; decoding consumes exactly the expected number of bytes; cleanup is safe after partial decode
tools	string rendering is length-bounded; conversion tools never trust input dimensions; tool-only parsers use the same checked arithmetic wrappers as the library

This registry becomes the source of truth for code review, tests, fuzzing, and documentation.

Recommendation CORE-S2: Introduce a two-phase parser boundary

Right now, too many paths appear to do this:

```
file bytes -> native internal object
            -> later code assumes validity
```

Change the architecture to:

```
file bytes -> bounded raw decode
            -> semantic validation
            -> native object construction
```

Concrete rule: *No public or internal runtime object is constructed from file metadata until the corresponding validator has passed.*

Implement the pattern by component:

```
1 | herr_t H5O_msg_decode_raw(const uint8_t *buf, size_t buf_size,
   |   ↳ H5O_msg_raw_t *raw);
2 | herr_t H5O_msg_validate(const H5F_t *f, const H5O_msg_raw_t *raw,
   |   ↳ H5O_validation_ctx_t *ctx);
3 | herr_t H5O_msg_construct(const H5O_msg_raw_t *raw, H5O_msg_t *out);
```

Do not let decode functions allocate complex structures before basic bounds are known. A raw decoded object should hold values, offsets, and spans, not trusted pointers into long-lived internal state.

All decode functions that consume file bytes should take one of these forms:

```
1 | herr_t decode(const H5F_t *f, const uint8_t *buf, size_t buf_size,
   |   ↳ out_t *out);
2 |
3 | herr_t decode_cursor(H5_decode_cursor_t *cur, out_t *out);
```

Ban this pattern in security-sensitive decode code:

```
1 | const uint8_t **pp
```

unless there is also an explicit `p_end` or remaining-size counter. The cache-image fix already moved in this direction by adding a buffer-size argument and bounds checks. [19]

Recommendation CORE-S3: Centralize checked arithmetic and allocation

Most parser bugs become exploitable when metadata reaches allocation, copy, or pointer arithmetic. Add a small, mandatory checked-arithmetic layer.

Example API:

```
1 herr_t H5_checked_add_hsize(hsize_t a, hsize_t b, hsize_t *out);
2 herr_t H5_checked_mul_hsize(hsize_t a, hsize_t b, hsize_t *out);
3 herr_t H5_checked_addr_add(haddr_t base, hsize_t len, haddr_t eoa,
  ↪ haddr_t *end);
4 herr_t H5_checked_alloc_size(size_t count, size_t elem_size, size_t
  ↪ *bytes);
```

Then make these rules review-blocking:

Table 8 – Review-blocking parser arithmetic and allocation patterns				
Ban		Replacement		
malloc(n*size)		H5MM_calloc_checked(n, size)		
addr+size		H5_checked_addr_add(addr, size, eoa, &end)		
memcpy(dst, src, n)	from file-derived size	H5_checked_memcpy(dst, dst_size, src, src_size, n)		
pointer increment without <code>p_end</code>		cursor-based decode		
raw recursion through object graph		bounded traversal context		

The 2024 security commit added multiplication-overflow checks for dataset storage size and checks against file bounds. [21] That pattern should become a library-wide rule, not a local repair.

Recommendation CORE-S4: Create security profiles for file opening

Add explicit modes. Do not rely on users to infer safe behavior.

```
1 typedef enum {
2     H5_SECURITY_PROFILE_LEGACY,
3     H5_SECURITY_PROFILE_TRUSTED_FAST,
4     H5_SECURITY_PROFILE_UNTRUSTED_STRICT,
5     H5_SECURITY_PROFILE_FORENSIC
6 } H5_security_profile_t;
```

Suggested semantics:

Table 9 – Security profile semantics	
Profile	Behavior
legacy	current compatibility bias
trusted_fast	normal validation, generous resource limits
untrusted_strict	strict metadata validation, plugin loading disabled unless allowlisted, resource limits enforced
forensic	never repairs silently, reports all structural anomalies, best-effort inspection without unsafe traversal

Expose it through file-access property lists:

```
1 H5Pset_security_profile(fapl, H5_SECURITY_PROFILE_UNTRUSTED_STRICT);
2 H5Pset_max_metadata_bytes(fapl, 256 * 1024 * 1024);
3 H5Pset_max_object_header_chunks(fapl, 1024);
4 H5Pset_max_btree_depth(fapl, 64);
5 H5Pset_max_filter_expansion_ratio(fapl, 100);
6 H5Pset_plugin_policy(fapl, H5_PLUGIN_POLICY_DISABLED);
```

This matters because HDF5 supports dynamically loaded plugins, and the runtime API can enable or disable plugin classes; the docs also state that `HDF5_PLUGIN_PRELOAD=: :` disables all dynamic plugins. Turn that capability into a first-class security policy, not an environment-variable trick.

Recommendation CORE-S5: Fuzz by structure, not just by whole-file crashes

Whole-file fuzzing is necessary but insufficient. It finds symptoms. Structure-aware fuzzing finds families.

Build fuzz targets in this order:

Table 10 – Structure-aware fuzzing implementation sequence

Order	Fuzz target	Why first
1	object-header message decoder	many paths flow through it
2	datatype decoder and converter	high exploitability and complex nested metadata
3	dataspace and selection decoder	rank, count, hyperslab, and point math
4	layout and chunk index decoder	storage-size, address, and chunk-product risks
5	free-space and local/global heap decoders	repeated historical overflow and list-corruption class
6	filter pipeline and scale-offset filter	compression/decompression boundary risk
7	metadata cache image reconstruction	high complexity and recent CVE pattern
8	h5dump/h5repack rendering tool paths	tool paths often bypass library assumptions

Use three fuzzing layers:

Table 11 – Fuzzing layers

Layer	Description
byte-level fuzzing	current randomized mutation against APIs
structure-aware mutation	valid superblock with corrupted object headers, valid object header with bad continuation, valid datatype with bad member offset

Table 11 – Fuzzing layers, continued

Layer	Description
invariant-guided genera-	generate files that violate exactly one invariant at a time
tion	

OSS-Fuzz already supports libFuzzer, AFL++, Honggfuzz, Centipede, sanitizers, and distributed execution for C/C++ projects. Use OSS-Fuzz for long-running public coverage and ClusterFuzzLite or local CI for PR-level checks.

Table 12 – Fuzzing acceptance criteria

Stage	Gate
PR	run minimized CVE corpus under ASan/UBSan/LSan
nightly	run structure fuzzers for core parsers
weekly	report coverage by component, not just total line coverage
release candidate	72-hour fuzz soak on changed parser areas
CVE closure	crashing input added to corpus and mapped to invariant

Recommendation CORE-S6: Make malformed-input regression cheap

Create this repository layout:

```
test/security/
  corpus/
    cve/
      CVE-2025-7069/
        input.h5
        expected.yml
      CVE-2025-6269/
        input.h5
        expected.yml
    invariants/
```

```
H5O-CONT-001/  
H5T-SIZE-002/  
harnesses/  
  fuzz_object_header.c  
  fuzz_datatype.c  
  fuzz_dataspace.c  
  fuzz_layout.c  
  fuzz_filters.c  
expected_errors/  
  corrupt_file.yml
```

Each expected.yml should include:

expected:

exit: controlled_error

allowed_errors:

- H5E_CORRUPT
- H5E_BADVALUE
- H5E_OVERFLOW

forbidden:

- SIGSEGV
- SIGABRT
- leak
- use_after_free
- timeout

invariant:

- H5FS-PAGE-001

This gives maintainers a fast way to prove that old crashes remain dead.

Recommendation CORE-S7: Add a security-review checklist that blocks risky parser changes

Every PR touching decode, encode, object lifecycle, filters, tools, or plugin loading should answer:

Table 13 – Security-review checklist for parser-adjacent changes

Question	Required answer
Does this read file-derived bytes?	list buffer and bounds source
Does this allocate using file-derived values?	show checked multiplication
Does this copy memory using file-derived sizes?	show source and destination bounds
Does this traverse links, chunks, heaps, B-trees, or continuations?	show cycle and depth bounds
Does this construct native objects before validation?	explain why or refactor
Does this add or change cleanup paths?	show partial-init safety
Does this invoke plugins or filters?	show policy interaction
Does this alter error handling?	show malformed-input test

Add automated enforcement where possible:

```
fail PR if new decode function lacks size parameter
fail PR if malloc(count * size) appears outside checked wrapper
fail PR if memcpy appears in parser code without checked wrapper annotation
fail PR if new parser file lacks fuzz target registration
fail PR if new object traversal lacks max-depth or visited-set logic
```

This will annoy contributors at first. Good. That friction is cheaper than post-release CVEs.

Recommendation CORE-S8: Separate compatibility from safety

HDF5's backward compatibility is valuable, but it creates a security trap: old, permissive parsing keeps malformed legacy structures alive.

Implement this policy:

Table 14 – Compatibility and safety profile policy

Case	Behavior
valid legacy file	accepted
ambiguous legacy construct	accepted only in legacy or trusted_fast; warning in forensic; rejected in untrusted_strict
structurally invalid file that old versions tolerated	rejected in all non-legacy profiles
parser repair needed	repair only through explicit tool, never silently during normal open
unknown message with unsafe flags	rejected unless profile explicitly allows preservation

The point is not to break legitimate archives. The point is to stop treating corrupted metadata as compatibility.

Recommendation CORE-S9: Harden tools as separate attack surfaces

Do not assume h5dump, h5repack, converters, and test utilities are less important. They are often the first thing users run on untrusted files.

Actions:

Table 15 – Tool hardening actions

Tool class	Change
inspection tools	use H5_SECURITY_PROFILE_FORENSIC by default
conversion tools	use H5_SECURITY_PROFILE_UNTRUSTED_STRICT by default
rendering paths	bounded strings only
legacy converters	disable by default; build behind explicit HDF5_ENABLE_LEGACY_UNSAFE_TOOLS=ON
plugin-dependent tools	warn or require allowlist

A dangerous file should not become more dangerous because the user tried to inspect it.

Recommendation CORE-S10: Plugin policy and signed extensions

Plugins are a different risk class. They are executable code loaded at runtime. HDF5's plugin system supports dynamically loaded filter plugins and lets users implement custom filters. That is useful, but it must not be invisible in untrusted mode.

Implement:

```
default profile:
  trusted_fast: existing plugin behavior
  untrusted_strict: plugins disabled unless allowlisted
  forensic: plugins disabled; report missing filter
```

Add a plugin manifest:

```
plugin_id: 32008
name: blosc
version: 1.0.0
sha256: ...
signer: ...
allowed_profiles:
  - trusted_fast
  - untrusted_strict
capabilities:
  - filter_decode
limits:
  max_expansion_ratio: 100
  max_alloc_bytes: 1073741824
```

Do not start with a perfect PKI. Start with allowlisted hashes and paths. Then add signatures. The signed-plugin work matters, but without resource limits a signed buggy plugin can still crash the process.

Recommendation CORE-S11: Coordinate supply-chain controls with parser hardening

Supply-chain work can proceed in parallel with parser hardening. Assign it an owner and scope independently, and record any concrete cross-track dependency rather than inferring order from an unscored comparison of the risk areas.

Minimum controls:

Table 16 – Minimum supply-chain controls

Control	Target
OpenSSF Scorecard	weekly scheduled run, alerts in security tab
CodeQL	required for PRs touching C/C++ parser surfaces
pinned GitHub Actions	no floating third-party action refs
SBOM	release artifacts include source and binary SBOMs
signed release artifacts	signatures plus checksums
SLSA provenance	release builds produce verifiable provenance

OpenSSF Scorecard has an official GitHub Action, and public repositories can use it without cost. The SLSA GitHub generator provides tooling for SLSA provenance on GitHub Actions, including provenance that users can verify to understand how an artifact was built.

Recommendation CORE-S12: Metrics that force the right behavior

Use metrics that measure class elimination, not activity.

Table 17 – Security program metrics

Metric	Target
CVE corpus pass rate under ASan/UBSan/LSan	100%
parser decode functions with explicit buffer size or cursor	100%
parser allocations through checked wrappers	100%

Table 17 – Security program metrics, continued

Metric	Target
parser memcopy/memmove through checked wrappers or reviewed exemption	100%
high-risk structures with invariant files	100%
high-risk structures with fuzz target	100%
new CVEs that add invariant updates	100%
time from new crash to minimized corpus seed	under 48 hours
time from minimized seed to invariant classification	under 5 business days
sanitizer-clean nightly fuzz runs	sustained
untrusted profile test coverage	every release

Track this in a public dashboard. Not because dashboards fix bugs. They stop the team from pretending that “more tests” is a plan.

3.5.2. Privacy

In this section we summarize privacy threats in HDF5 based on the audit findings and describe corresponding mitigation strategies.

Overview of Privacy Threat Categories

The HDF5 Privacy Exposure Model [53] identifies seven categories of privacy threats that describe the principal mechanisms through which sensitive information may be unintentionally exposed in HDF5. Privacy threats primarily arise during normal scientific data creation, processing, sharing, and preservation. They are a consequence of HDF5’s self-describing data model, rich metadata capabilities, extensible software architecture, broad interoperability across scientific applications, and prolonged data life cycle.

Several threat categories involve direct disclosure of information stored within HDF5 files. Metadata Exposure (P1) occurs when descriptive information, such as

object names, attributes, datatype member names, or other user-defined metadata, reveals sensitive contextual information even when the underlying scientific data are protected. Structural Metadata Exposure (P2) arises from examination of HDF5's internal storage structures, including file layout, storage organization, and implementation metadata, which may disclose characteristics of the stored data without requiring HDF5 software. Raw Data Exposure (P3) addresses situations in which information about scientific data becomes observable through storage patterns, embedded textual descriptions, or other implementation artifacts rather than through intended data access.

Another group of threats results from routine scientific data processing. Unintended Data Alteration or Inclusion (P4) occurs when software automatically generates, expands, or preserves additional information during data conversion or processing. Data Aggregation and Correlation (P5) recognizes that individually non-sensitive datasets may collectively reveal sensitive information when combined or interpreted together. Persistent Data Beyond Intended Usage (P6) addresses privacy risks associated with temporary files, metadata snapshots, cached datasets, archived copies, and other artifacts that remain accessible after their intended purpose has ended.

The remaining threat category Misplaced Trust in Privacy by format (P7) reflects broader characteristics of modern HDF5 ecosystems. Examples include:

- Misinterpretation of data privacy in HDF5 format leads to the possibility of sensitive information disclosure through metadata, structural information, or inference.
- Conversion to HDF5 highlights that transforming legacy scientific formats into HDF5 often increases accessibility and interoperability by making implicit information explicit, but this additional semantic information may itself introduce new privacy risks.
- Loss of Data Control describes situations in which data movement, replication, backup, cloud migration, or transfer across organizational boundaries weakens the original privacy protections and governance mechanisms applied to the data.

Although presented as distinct categories, these threats frequently occur together. A single scientific workflow may enrich metadata during format conversion, aggregate datasets from multiple sources, generate temporary processing artifacts, and replicate results across multiple storage systems. Consequently, privacy risks should be evaluated across the complete scientific data lifecycle rather than by considering individual HDF5 files in isolation.

Recommendations

Because HDF5 was designed to maximize scientific data sharing, portability, interoperability, and long-term usability rather than enforce privacy, no single mechanism can eliminate all privacy risks. Effective privacy protection therefore requires a multi-facet approach that considers the entire scientific data lifecycle, including data creation, processing, storage, sharing, transfer, and archival. Privacy should be treated as a property of the complete HDF5 ecosystem including applications, plugins, workflows, storage systems, and organizational practices rather than solely of the HDF5 file format. The following CORE-PRIV-S identifiers identify recommendations in this track. Their numbers do not express risk, urgency, effort, dependency, or implementation order.

Recommendation CORE-PRIV-S1: *Privacy exposure awareness*

Scientists, software developers, data stewards, and infrastructure providers should recognize that HDF5's self-describing nature inherently exposes contextual information in many ways. Privacy reviews should therefore evaluate not only scientific datasets, but also metadata, structural organization, workflow artifacts, derived products, and information that may be inferred through aggregation or correlation. Reviews should also take into consideration possible privacy exposure during data lifecycle.

Recommendation CORE-PRIV-S2: *Privacy exposure through HDF5 tools and plugins awareness*

The HDF5 ecosystem extends beyond the core HDF5 software (i.e., file format

and the library), and includes a diverse collection of command-line utilities, visualization tools, analysis libraries, VOL connectors, VFDs, filters, and third-party applications. These components frequently generate additional outputs such as logs, diagnostic messages, temporary files, metadata snapshots, converted datasets, and cached intermediate results that may expose sensitive information beyond the contents of the original HDF5 file. Furthermore, plugins may introduce new metadata, or transform data in ways that alter their privacy characteristics. Consequently, privacy assessments should evaluate not only HDF5 files but also the behavior of the software ecosystem that processes them. Developers should document the privacy implications of their tools, minimize unnecessary generation of sensitive artifacts, and provide users with mechanisms to control logging, metadata generation, and retention of intermediate products.

Recommendation CORE-PRIV-S3: *Privacy-aware system design*

HDF5 software systems should be built with data privacy in mind. Applications should minimize collection and retention of unnecessary metadata, avoid embedding sensitive information in object names or descriptive attributes, remove temporary processing artifacts when they are no longer needed, and carefully evaluate automatically generated metadata introduced during data conversion or interoperability. Workflow designers should review intermediate products, logs, cached datasets, and derived files before publication or long-term archival.

Recommendation CORE-PRIV-S4: *Data encryption as privacy control*

Encryption represents an important but limited privacy control.

Currently, HDF5 doesn't support data encryption that allows I/O on encrypted data, effectively disabling sensitive data exposure during data transfer and storage. Users may implement custom raw data encryption and partial metadata encryption (i.e., names of the objects) using existing HDF5 filtering mechanism. Such approach still leaves user-defined metadata (e.g., attributes) and structural metadata unencrypted. Information that remains unencrypted as application-specific workflow artifacts, temporary files, system logs, or derived datasets may continue to disclose sensitive information.

HDF5 encryption feature that properly implements encryption of all data stored in HDF5 while allowing partial I/O on encrypted data is currently under development. However, encryption does not eliminate all HDF5 privacy risks. Once encrypted data are decrypted for legitimate processing, applications, plugins, caches, diagnostic logs, and intermediate workflow products may again become sources of unintended exposure. Encryption therefore reduces the attack surface but does not address inference, aggregation, excessive metadata generation, data retention, or loss of governance. Encryption also complicates workflows and may lead to data loss if on some stage of data life cycle encryption keys become unavailable.

Therefore, encryption should be viewed as one component of a comprehensive privacy strategy rather than as a complete solution. Effective protection requires combining encryption with careful metadata management, lifecycle-aware data governance, privacy-aware application design, access controls provided by the underlying computing environment, and education of users regarding the unique privacy characteristics of HDF5-based scientific data systems.

4. HDF5 Library Extensions

4.1. Overview

Supply chain-related issues are discussed in more detail in [Section 7](#).

4.2. Virtual Object Layer (VOL) Connectors

4.2.1. Privacy-Relevant Mechanisms for VOL Connectors

HDF5 VOL connectors can substantially broaden a deployment's privacy-assessment boundary. When a VOL connector (or a stack of VOL connectors) is used, data privacy can no longer be evaluated by examining only the HDF5 file, its lifecycle, and the workflows in which it is used. Instead, the privacy boundary extends to the entire data ecosystem, including all underlying data sources, connector-generated data and metadata, caches, authentication credentials, network communications, and the dynamically loaded plugin code itself. Consequently, any comprehensive HDF5 privacy model must account for these components, their interactions, and the trust relationships they establish.

The following mechanisms can create deployment-specific privacy exposure when HDF5 VOL connectors are used.

External Data Sources (P8 Ecosystem Exposure)

Users traditionally assume that an HDF5 file contains all of the data being accessed and that inspecting or protecting the file is sufficient to understand and secure the complete dataset. However, this assumption no longer holds when HDF5 VOL connectors are used. A VOL connector can transparently retrieve and integrate data from numerous external sources while presenting it as a single HDF5 file. These sources may include cloud object stores, databases, remote servers accessed through REST or other network services, live data streams, or files in non-HDF5 formats. In addition, connectors may generate derived data, metadata, or virtual objects that do not physically exist in the underlying storage. As a result, users

may be unaware of the true origin, location, ownership, and privacy policies governing the data being accessed, making it more difficult to assess privacy risks and apply appropriate protections.

Transparent Data Aggregation (P3 Derived Information, P8 Ecosystem Exposure)

A VOL connector can transparently aggregate data from multiple HDF5 files, databases, cloud object stores, external file formats, and live data streams into a single logical HDF5 dataset. For example, a connector could combine data from a geospatial database, near real-time weather and natural disaster feeds, and property assessment records to produce an HDF5 dataset for analyzing the potential impact of natural disasters on property values. From the application's perspective, all of these heterogeneous data sources appear as a single HDF5 dataset, potentially obscuring the number, nature, and privacy policies of the underlying data sources. Such transparent aggregation increases the risk of unintended disclosure because data originating from independent sources with different ownership, access controls, or privacy policies may be analyzed or shared as a single integrated dataset without the user's explicit awareness.

Access to non-HDF5 data (P8 Ecosystem Exposure)

VOL connectors can access data in other binary formats, for example TIFF/GeoTIFF, BUFR, GRIB2, and CDF, and special storage systems, for example, DAOS. Therefore, the privacy implications of these formats and storage systems must be included in the deployment's HDF5 privacy assessment.

Generated metadata (P1 Metadata Exposure, P3 Derived Information)

VOL connectors may generate their own metadata that in turn may reveal, for example, dataset relationships, storage locations, URLs, cloud bucket names, and provenance. VOL connectors may generate additional metadata; for example, BUFR and GRIB2 VOL connectors generate file inventories revealing file organization, create derived attributes and dimension scales even when raw data remain protected.

Network Workflow Artifacts (P6 Workflow Artifacts)

HDF5 VOL connectors that access remote data sources generate network workflow artifacts as part of normal operation. These artifacts may include HTTP request and response headers, DNS queries and logs, proxy logs, browser or client history, authentication records, local caches, temporary downloads, and other network-related metadata retained on local or remote systems. Such artifacts can create a detailed record of the datasets accessed, potentially exposing sensitive information even when the underlying data remain protected. Consequently, HDF5 VOL connectors that rely on network communications inherit many of the privacy risks associated with networked systems and should be evaluated within a broader network privacy and security model.

Caching (P2 Raw Data Exposure, P3 Derived Information)

HDF5 VOL connectors may cache all sorts of data (metadata, downloaded raw data, authentication information, etc.) that remain after execution and may be shared, copied, and archived. A user may not be even aware of VOL's artifacts and leaked data.

Provenance leakage (P1 Metadata Exposure, P3 Derived Information, P8 Ecosystem Exposure)

VOL connectors may reveal provenance information, e.g., data origin, timestamps, organizational structure, modification history.

Policy Bypass (P8 Ecosystem Exposure)

HDF5 applications are generally privacy-policy agnostic and have no inherent awareness of the privacy policies governing the data they access. When VOL connectors are used, the same application may transparently access data originating from multiple sources, each subject to different ownership, access controls, retention requirements, or privacy regulations. Because the application interacts only with the HDF5 API, it may unknowingly combine, process, or redistribute data under incompatible privacy policies, effectively bypassing policy boundaries that would otherwise apply to the individual data sources.

Plugin Trust (P7 Trust and Supply Chain)

HDF5 VOL connectors are dynamically loaded plugins that execute external code within the application's process. As a result, a connector has direct access to the data flowing through the HDF5 API and can inspect, copy, modify, cache, export, or share that data before returning it to the application. A malicious or untrusted VOL connector could therefore compromise the confidentiality, integrity, or privacy of the data without the application's knowledge. Consequently, VOL connectors should be obtained from trusted sources, verified before deployment, and included within the application's overall trust and privacy model.

Table 18 – Primary privacy mechanisms for VOL connector privacy risks

Risk	Primary Privacy Mechanism
External Data Sources	P8 Ecosystem Exposure
Transparent Data Aggregation	P3 Derived Information P8 Ecosystem Exposure
Access to non-HDF5 Data	P8 Ecosystem Exposure
Generated Metadata	P1 Metadata Exposure P3 Derived Information
Network Workflow Artifacts	P6 Workflow Artifacts
Caching	P2 Raw Data Exposure P3 Derived Information
Provenance Leakage	P1 Metadata Exposure P3 Derived Information P8 Ecosystem Exposure
Policy Bypass	P8 Ecosystem Exposure
Plugin Trust	P7 Trust and Supply Chain

4.3. Filter Plugins

4.3.1. Privacy-Relevant Mechanisms for Filter Plugins

Filter plugins operate on data immediately before storage and immediately after retrieval. As a result, the privacy boundary extends beyond the HDF5 file itself

and the application that uses the data. Filter plugins execute external code, may create temporary plaintext copies of sensitive data, generate intermediate artifacts, maintain internal state, or transmit information outside the application. Consequently, evaluating privacy risks requires considering not only the stored HDF5 file but also the behavior of the filter plugins, their execution environment, and any artifacts they produce during data processing.

The following mechanisms can create deployment-specific privacy exposure when HDF5 filters are used.

Metadata leakage via filters identifiers (P1 Metadata Exposure)

The filter pipeline is stored in the file as HDF5 metadata in the object header. Filter identifier and its parameters may reveal security mechanisms, organizational standards, software ecosystem, application domain, etc.

Data characteristics leakage via filter parameters (P1 Metadata Exposure, P3 Derived Information)

Filter parameters such as compression level, block sizes, scale-offset parameters, etc. may reveal expected precision, data resolution, floating-point accuracy, acceptable information loss. Usage of lossy filters shows acceptable data approximation, expected error bounds, and precision requirements. Such data characteristics can give insights into assumptions under which data was collected and characteristics of experimental setup.

Sizes of compressed chunks reveal data characteristics (P1 Metadata Exposure, P3 Derived Information)

Chunk sizes are metadata and can be examined without access to data. Different sizes of compressed chunks may reveal sparsity, repeated patterns, data randomness, and empty regions to name a few.

Filters operate on plaintext data buffers (P2 Raw Data Exposure)

Before data compression or encryption is applied filters have access to data. Mali-

cious filter may have access to data before specialized compression or encryption are applied to protect data.

Filters may persist data outside HDF5 (P2 Raw Data Exposure, P6 Workflow Artifacts)

Filters may allocate memory buffers that may remain in memory, or paged to disk, appear in crash dumps. This sensitive data may persist outside the HDF5 file.

Plugin trust (P7 Trust and Supply Chain)

As HDF5 VOL connectors, HDF5 filters are dynamically loaded plugins that execute external code within the application's process. If the filter is malicious, it can do anything before passing data to application or to storage, for example, inspect memory, write logs, copy decoded data and send it elsewhere or retain it. Untrusted filter plugin could compromise data confidentiality, integrity and privacy without application's knowledge.

Plugin search path (P7 Trust and Supply Chain)

Dynamic filters are loaded from directories specified by environment variables while the HDF5 library is searching for the requested plugin. Such process may result in loading a malicious filter. On different systems application may load different plugins. Thus, it becomes a supply-chain problem.

Filters may generate derived information (P3 Derived Information). Since filters have access to data they can generate and store any type of derived information, e.g., statistics, patterns, sparsity characteristics, etc. The derived information may reveal sensitive information about data.

The table below provides primary privacy mechanism for built-in filters and several popular third-party filters.

Table 19 – Primary privacy mechanisms associated with HDF5 filter plugins

HDF5 Filter	Primary Privacy Categories	Representative Privacy Considerations
Deflate (GZIP)	P1 Metadata Exposure P3 Derived Information	Compression method, compression level, and resulting chunk sizes may reveal data entropy, sparsity, and redundancy.
Shuffle	P3 Derived Information	Byte reordering itself is reversible, but its use together with compression may reveal characteristics of the underlying numeric representation and data organization.
Fletcher32	P1 Metadata Exposure	Checksum metadata reveals integrity protection is used but generally introduces minimal additional privacy risk.
N-bit	P1 Metadata Exposure P3 Derived Information	Bit-width reduction reveals effective numeric precision and expected value ranges, providing insight into experimental accuracy and measurement characteristics.
Scale-Offset	P1 Metadata Exposure P3 Derived Information	Scale factors and offsets reveal expected precision, acceptable quantization error, and data resolution.
ZFP	P1 Metadata Exposure P3 Derived Information	Compression mode (fixed rate, fixed precision, or fixed accuracy) and associated parameters reveal acceptable information loss and numerical accuracy requirements.
SZ / SZ3	P1 Metadata Exposure P3 Derived Information	Error bounds expose tolerated approximation error and characteristics of scientific datasets.
Blosc	P1 Metadata Exposure P3 Derived Information	Compression algorithm, block size, and shuffle/bitshuffle options reveal storage optimization choices and data organization.
Zstandard (Zstd)	P1 Metadata Exposure P3 Derived Information	Compression level and resulting compressed sizes may reveal entropy and structural properties of datasets.
LZ4	P1 Metadata Exposure P3 Derived Information	Fast compression with modest ratios may reveal data compressibility through chunk sizes.
BZIP2	P1 Metadata Exposure P3 Derived Information	Compression characteristics and block sizes may expose redundancy and data structure.

Table 19 – Primary privacy mechanisms associated with HDF5 filter plugins, continued

HDF5 Filter	Primary Privacy Categories	Representative Privacy Considerations
All Dynamic Filters	P2 Raw Data Exposure	Filters operate on plaintext data before writing or after reading. Dynamically loaded plugins may inspect, cache, copy, or export sensitive data and may generate temporary buffers, logs, or crash artifacts.
	P6 Workflow Artifacts	
	P7 Trust and Supply Chain	

4.4. Virtual File Drivers (VFD)

4.4.1. Privacy-Relevant Mechanisms for VFDs

HDF5 VFDs manage how actual bytes are stored and retrieved. While VFDs perform I/O and do not change the logical HDF5 file and data model, they can create privacy-relevant exposure through data movement, storage, and application I/O characteristics.

The following mechanisms can create deployment-specific privacy exposure when HDF5 VFDs are used.

External Data Sources (P8 Ecosystem Exposure)

Unlike traditional file I/O, Virtual File Drivers may transparently store and retrieve HDF5 data from cloud object stores, distributed file systems, network storage, memory-resident files, or multiple physical storage devices. Consequently, users and system administrators may incorrectly assume where sensitive information resides and which security policies, regulatory requirements, or administrative controls apply. The privacy boundary therefore extends beyond the HDF5 file to the entire storage ecosystem.

Multiple Copies of Data (P2 Raw Data Exposure, P6 Workflow Artifacts)

Some VFDs create additional copies of HDF5 data without the application's explicit awareness. These copies may exist in replicated files, metadata journals,

backing stores, memory dumps, swap files, or mirrored storage systems. Because these copies may persist beyond the lifetime of the primary HDF5 file, sensitive information can remain recoverable even after the original file has been deleted or relocated.

Storage Metadata Exposure (P1 Metadata Exposure)

Although VFDs do not understand HDF5 objects, they manage physical storage and therefore may expose low-level storage metadata, including physical offsets, allocation sizes, storage layouts, and file organization. Such information can reveal characteristics of datasets, storage architecture, and application behavior even without accessing the logical HDF5 objects.

Access Pattern Leakage (P3 Derived Information)

Storage activity observed by the operating system, distributed file system, storage servers, or cloud infrastructure may reveal application behavior. Access frequency, read/write ratios, sequential versus random I/O, update frequency, and accessed file regions can reveal properties of the underlying datasets, application algorithms, or user activity. These observations enable inference of information that is not explicitly stored within the HDF5 file.

Workflow Artifacts (P6 Workflow Artifacts)

VFDs may generate artifacts during normal operation, including metadata journals, temporary files, swap files, memory images, crash dumps, replicated storage objects, and cloud access logs. These artifacts frequently persist outside the HDF5 file itself and may retain sensitive information or evidence of application activity.

Plugin Trust (P7 Trust and Supply Chain)

Dynamically loadable Virtual File Drivers execute external code within the application's process. A malicious or compromised VFD can inspect, modify, retain, duplicate, or export data before writing it to storage or returning it to the application. Consequently, VFDs should be obtained only from trusted sources and considered part of the application's overall trust and privacy model.

Table 20 – Major privacy risks associated with HDF5 Virtual File Drivers

HDF5 VFD	Privacy Categories	Representative Privacy Risks
SEC2	P2 Raw Data Exposure	Disk blocks allocated for new HDF5 files may contain residual information if the underlying storage is not securely initialized or overwritten.
STDIO	P2 Raw Data Exposure	Similar to the SEC2 driver, persistent storage may expose residual data remaining on reused disk blocks.
Core	P2 Raw Data Exposure P6 Workflow Artifacts	Stores the entire HDF5 file in memory. Sensitive information may persist in process memory, swap space, or operating-system crash dumps. When the backing-store option is enabled, the in-memory file is written to persistent storage upon closing.
Family	P2 Raw Data Exposure	Splits a logical HDF5 file into multiple physical files. Misconfigured permissions or incomplete deletion of family members may expose portions of the dataset.
Split	P1 Metadata Exposure P2 Raw Data Exposure P8 Ecosystem Exposure	Stores metadata and raw data in separate files, which may have different permissions or reside on different storage systems. The driver also creates multiple physical copies of file information.
Multi	P1 Metadata Exposure P2 Raw Data Exposure P8 Ecosystem Exposure	Stores different HDF5 memory types in separate files. Independent storage locations and permissions increase the risk of metadata and raw data disclosure.
Mirror	P2 Raw Data Exposure P7 Trust and Supply Chain P8 Ecosystem Exposure	Replicates HDF5 data to a remote mirror service. Privacy depends on secure communication, trusted mirror daemons, authentication, and protection of replicated copies.
Log SWMR)	(VFD P1 Metadata Exposure P6 Workflow Artifacts	Metadata journaling creates persistent journal files containing metadata snapshots for crash recovery, leaving additional workflow artifacts outside the HDF5 file.

Table 20 – Major privacy risks associated with HDF5 Virtual File Drivers, continued

HDF5 VFD	Privacy Categories	Representative Privacy Risks
MPI-I/O	P1 Metadata Exposure	Transfers metadata and raw data through the underlying HPC communication infrastructure. Unless protected by lower-layer mechanisms, network traffic may expose sensitive information.
	P2 Raw Data Exposure	
	P8 Ecosystem Exposure	
Subfiling	P1 Metadata Exposure	Divides a logical HDF5 file into multiple subfiles distributed across storage devices. Fragmentation and independently managed files increase the risk of unauthorized disclosure through misconfigured access controls.
	P2 Raw Data Exposure	
	P8 Ecosystem Exposure	
Onion	P1 Metadata Exposure	Maintains historical versions of HDF5 files, allowing recovery of deleted or overwritten data and reconstruction of meta-data evolution, provenance, and workflow history.
	P2 Raw Data Exposure	
	P3 Derived Information	
ROS3	P6 Workflow Artifacts	Accesses HDF5 files stored in S3-compatible object stores. HTTP requests, DNS queries, cloud access logs, and HTTP Range requests create network artifacts and extend the privacy boundary to cloud infrastructure.
	P8 Ecosystem Exposure	

4.5. Architectural Observations and Mitigation Planning

The general privacy-boundary observation in this section is recorded as evidence-backlog item EXT-PRIV-001 in Appendix A. It is not a formal finding because the report has not defined a deployment-specific sensitive-data population, recipient, retention condition, impact, or exposure. The recommendations below remain valid control proposals; their presence does not silently convert the observation into a rated finding.

4.5.1. Privacy

The architectural analysis identifies ways in which privacy boundaries may extend beyond the HDF5 file itself. VOL connectors, filter plugins, and Virtual File Drivers can add external data sources, dynamically loaded plugins, storage systems, cloud services, and network infrastructure. Depending on a concrete deployment, these mechanisms may expose raw data, metadata, derived information, workflow artifacts, or information about the surrounding software ecosystem, even when the HDF5 file itself is adequately protected. The following sections summarize the principal observations for each extension mechanism and present mitigation recommendations to improve privacy awareness, transparency, and trustworthiness within the HDF5 ecosystem.

Privacy – HDF5 VOL Connectors

Architectural observations

The analysis identifies VOL connectors as a particularly broad potential extension of the privacy boundary. Unlike the HDF5 core library, a VOL connector may reach external data sources, cloud services, databases, network infrastructure, authentication systems, caches, and dynamically loaded plugins. Because applications interact only with the HDF5 API, users may be unaware of the true origin of data, the privacy policies governing those data, or the workflow artifacts generated during processing. Consequently, deployment-specific privacy exposure can arise not only from the HDF5 file itself but also from the broader software ecosystem accessed by the connector; the resulting harm and risk depend on the data, recipients, and controls in that deployment.

Recommendations

The following VOL identifiers identify recommendations in this track. Their numbers do not express risk, urgency, effort, dependency, or implementation order:

Recommendation VOL-S1 - Document connector privacy characteristics

Each VOL connector should explicitly document any of applicable items listed below:

- External data sources VOL connector accesses
- Generated metadata
- Caching mechanism
- Network communications
- Authenticaion mechanism
- Workflow artifacts
- Privacy assumptions

Recommendation VOL-S2 - Improve connector transparency and introspection

HDF5 should provide a standardized mechanism through which applications and audit tools can identify the active VOL connector or connector stack and query privacy-relevant operational characteristics. Existing VOL introspection callbacks can report connector identity and selected capabilities, but they do not expose whether a connector accesses external resources, aggregates multiple sources, generates metadata, maintains caches, creates workflow artifacts, or performs network communication. The VOL introspection interface, connector capability flags, or standardized optional operations should therefore be extended to expose this information.

Possible standartize queries could include:

- Connector name, version, and stack composition
- Types and locations of external data sources
- Whether
 - network access is performed

- raw data, metadata, or credentials are cached
- the connector creates temporary or persistent artifacts
- the connector generates metadata or derived data
- the connector combines data governed by different policies
- privacy-relevant configuration information can be obtained

■ TBD

Recommendation VOL-S3 - Strengthen connector trust and deployment practices

VOL connectors are dynamically loaded shared libraries and therefore become part of the application's trusted computing base. Organizations should deploy only trusted connectors, restrict the directories searched for plugins, verify the provenance and integrity of connector libraries, and avoid loading untrusted plugins from user-writable or publicly accessible locations.

Future versions of HDF5 could further improve security by providing configurable policies that restrict connector loading based on connector identity, implemented transparency and introspection, or administrative policy. Where signed-plugin verification is used, users and application developers should deploy HDF5 2.2.0 or a later verified release, build it with `HDF5_REQUIRE_SIGNED_PLUGINS=ON`, configure and protect the trusted keystore, sign approved connector artifacts, and test rejection of unsigned or untrusted plugins; upgrading alone does not enable the control (Table 38).

Recommendation VOL-S4 - Follow privacy-aware connector development guidelines

Future connector implementations should minimize unnecessary metadata generation, avoid persistent caches unless explicitly requested, and clearly document connector's privacy characteristics.

Privacy – HDF5 Filter Plugins

Architectural observations

The analysis shows that HDF5 filters can alter a deployment's privacy characteristics because they execute immediately before storage and immediately after retrieval while operating directly on plaintext data. Filter parameters, compression characteristics, and generated metadata may reveal information about the underlying datasets even when the data themselves remain protected. Dynamically loaded filter plugins also introduce a security-relevant supply-chain mechanism because they execute arbitrary code within the application's process and may generate temporary artifacts outside the HDF5 file.

Recommendations

The following FILTER identifiers identify recommendations in this track. Their numbers do not express risk, urgency, effort, dependency, or implementation order:

Recommendation FILTER-S1 - Strengthen filter trust and deployment practices

Organizations should deploy only trusted connectors, restrict the directories searched for plugins, verify the provenance and integrity of connector libraries, and avoid loading untrusted plugins from user-writable or publicly accessible locations.

Future versions of HDF5 could further improve security by providing configurable policies that restrict connector loading based on connector identity, implemented transparency and introspection, or administrative policy. Where signed-plugin verification is used, users and application developers should deploy HDF5 2.2.0 or a later verified release, build it with `HDF5_REQUIRE_SIGNED_PLUGINS=ON`, configure and protect the trusted keystore, sign approved filter artifacts, and test rejection of unsigned or untrusted plugins; upgrading alone does not enable the control (Table 38).

Recommendation FILTER-S2 - Select and document filter configurations with privacy in mind

Filter identifiers and parameters are stored in HDF5 object headers and are required for correct interpretation of the stored data. Consequently, this metadata cannot generally be removed or obscured without affecting interoperability. Users should evaluate whether filter configurations reveal sensitive information about data precision, compression characteristics, or scientific workflows, and document these privacy implications when selecting filter pipelines.

Recommendation FILTER-S3 - Use encryption when filter metadata are privacy sensitive

When filter metadata themselves may disclose sensitive information, encrypting the entire HDF5 file provides the most effective mitigation. Encryption solutions that protect both raw data and HDF5 metadata—including filter pipelines, object headers, and structural metadata—prevent unauthorized disclosure of filter identifiers, parameters, compressed chunk characteristics, and other metadata that could otherwise be used to infer properties of the underlying data.

Recommendation FILTER-S4 - Minimize workflow artifacts

Filter implementations should securely erase temporary buffers when possible, avoid persistent temporary files, and clearly document any generated artifacts.

Recommendation FILTER-S5 - Standardize privacy documentation

Built-in and registered filters should document:

- Generated metadata
- Plaintext processing
- Derived information
- Temporary artifacts
- Privacy implications of filter parameters

Privacy – HDF5 Virtual File Drivers

Architectural observations

The analysis shows that Virtual File Drivers can affect a deployment's privacy boundary through physical storage management rather than the logical HDF5 data model. VFDs influence where data are stored, how they are replicated, transmitted, cached, or versioned, and consequently extend the HDF5 privacy boundary to operating systems, distributed storage systems, cloud infrastructure, and network services. Different VFDs emphasize different privacy concerns, including persistent copies of data, storage metadata exposure, historical version retention, network artifacts, and cloud-based workflow exposure.

Recommendations

The following VFD identifiers identify recommendations in this track. Their numbers do not express risk, urgency, effort, dependency, or implementation order:

Recommendation VFD-S1 - Document storage behavior

Every VFD should clearly describe:

- Where data are stored
- Whether additional copies are created
- Whether network communication occurs
- Generated workflow artifacts
- Storage assumptions

Recommendation VFD-S2 - Minimize unintended persistence

Drivers that create replicated files, journal files, historical versions, or backing stores should provide mechanisms for secure deletion, retention management, and lifecycle control.

Recommendation VFD-S3 - Strengthen cloud and distributed-storage guidance

Cloud-based and distributed-storage VFDs should document authentication requirements, network communications, logging behavior, and storage-provider privacy assumptions.

Recommendation VFD-S4 - Strengthen VFD trust and deployment practices

Organizations should deploy only trusted VFD plugins, restrict the directories searched for plugins, verify the provenance and integrity of connector libraries, and avoid loading untrusted plugins from user-writable or publicly accessible locations.

Future versions of HDF5 could further improve security by providing configurable policies that restrict VFD plugin loading based on VFD's identity, implemented transparency and introspection, or administrative policy. Where signed-plugin verification is used, users and application developers should deploy HDF5 2.2.0 or a later verified release, build it with `HDF5_REQUIRE_SIGNED_PLUGINS=ON`, configure and protect the trusted keystore, sign approved VFD artifacts, and test rejection of unsigned or untrusted plugins; upgrading alone does not enable the control (Table 38).

Summary

The analysis shows that HDF5 library extensions can alter a deployment's privacy characteristics. While the HDF5 core library primarily exposes information through the file format itself, VOL connectors, filter plugins, and Virtual File Drivers can extend the privacy boundary to external software, storage systems, network infrastructure, cloud services, and dynamically loaded plugins. The existence and magnitude of harm remain deployment-specific. Effective privacy assessment should therefore evaluate both HDF5 files and the execution environment in which HDF5 operates. This broader ecosystem perspective should guide the design, implementation, deployment, and review of future HDF5 extensions.

5. HDF5 Wrappers and Language Bindings

5.1. Overview

Complete:

- C#
- Java
- Python
- JavaScript
- Rust

Partials...

5.2. Python

- CVE-2025-9905 [37]
- CVE-2026-0897 [38]
- CVE-2026-1669 [39]
- CVE-2026-2492 [28]

5.3. Java

5.4. Audit Findings and Mitigation Planning

This chapter does not establish an additional binding-specific formal finding. The listed Keras and TensorFlow cases are rated at their application boundaries as APP-SEC-002 through APP-SEC-005 in Appendix A; their presence in a Python-facing workflow does not make them h5py or Python-binding findings without separate evidence.

6. Applications using HDF5

Applications treat HDF5 as inert data, but HDF5 files can carry behavior-relevant metadata: paths, external references, huge declared shapes, filter/plugin requirements, serialized application objects, and model-layer definitions. That creates integration bugs even when the HDF5 library is behaving as designed.

The HDF Group's security policy [54] already attempts the right scope distinction: core libhdf5, official tools, Remote Code Execution (RCE) via parsing/API abuse, and supply-chain compromise are in scope; third-party plugins and application-level usage are usually triaged or referred to their maintainers.

Table 21 – Common application-level HDF5 failure families

Family	Typical failure	Examples	Why it is common
malformed file metadata reaches C memory code	buffer overflow, over-read, UAF, double-free, null dereference, divide-by-zero	many HDFGroup records, including 2024 and 2025 issues in object headers, datatypes, dataspaces, filters, heaps, free-space metadata, and cache images	HDF5 is a complex binary metadata graph, not a flat byte container
application deserialization layered on HDF5	arbitrary code execution	Keras CVE-2025-9905: crafted <code>.h5/.hdf5</code> model archives can execute code because legacy <code>.h5</code> loading did not honor <code>safe_mode=True</code> for Lambda-layer pickled code [37, 32].	ML frameworks often use HDF5 as a model container, then deserialize framework-level objects from it.
external references and file path indirection	arbitrary local file read, path traversal, data exfiltration	Keras CVE-2026-1669: crafted <code>.keras</code> model file using HDF5 external dataset references could read local files [39, 33].	HDF5 supports links and external storage mechanisms. External links store both target filename and object path; external storage can resolve raw-data files through prefixes and current working directory rules [52].
unbounded resource allocation	memory exhaustion / interpreter crash	Keras CVE-2026-0897: crafted <code>.keras</code> archive with <code>model.weights.h5</code> declaring an extremely large dataset shape could exhaust memory and crash Python [38, 31].	HDF5 metadata can declare logical shapes much larger than the actual useful payload; application code may allocate based on declared shape before policy checks.
dynamic plugin loading and search paths	local privilege escalation / arbitrary code loading	TensorFlow CVE-2026-2492: HDF5 plugin handling loaded plugins from an unsecured location, enabling local privilege escalation [28, 56, 47].	HDF5 supports dynamic plugin loading, and plugin paths can be affected by defaults or <code>HDF5_PLUGIN_PATH</code> ; dynamic loading can also be disabled via <code>H5PLset_loading_state()</code> or <code>HDF5_PLUGIN_PRELOAD=:</code> [49].

Table 21 – Common application-level HDF5 failure families, continued

Family	Typical failure	Examples	Why it is common
vulnerable or stale embedded HDF5 copies	inherited CVEs, unpatched parser behavior	CVE-2021-36977 involved a heap overflow related to use of HDF5 1.12.0; Apple CVE-2021-31009 says multiple issues were addressed by removing HDF5 [15, 5].	Downstream products vendor, statically link, or lag HDF5 releases; vulnerability scanners then attribute HDF5 defects to the application.
helper-tool exposure	crashes or code execution through inspection/conversion utilities	h5dump appears in older and newer issues; CVE-2026-34734 describes a heap-use-after-free in the h5dump helper utility triggered by a malicious .h5 file [16, 50].	Applications often call h5dump, h5repack, or converters as “safe inspection” tools on untrusted files.

6.1. Boundary Case Study: External Raw Storage and the Hugging Face Incident

The July 2026 Hugging Face incident is a concrete example of an application trust-boundary failure involving an intentional HDF5 capability. Hugging Face reports that its dataset service processed attacker-supplied, valid HDF5 files whose datasets declared local paths as external raw storage. The worker read `/proc/self/environ` and source files with its own filesystem permissions and returned the bytes as dataset rows. Hugging Face expressly distinguishes this file-disclosure vector, which executed no code, from a separate Jinja2 injection that supplied code execution [36].

The HDF Group likewise concludes that external raw storage was the mechanism, not an HDF5 parser vulnerability: the documented feature behaved as designed, while the authority-bearing service acted as a confused deputy. Updating `libhdf5` alone would not remove that service boundary; the relevant controls are fail-closed external-resource policy, preflight inspection, path confinement, least-privileged workers, and credential isolation [55].

The `h5py` community expressly considered the same boundary. Maintainers described per-dataset external-storage checks as possible but laborious, recommended sandboxing genuinely untrusted files, opened upstream issue #6618 because `h5py` had no direct enforcement mechanism, and discussed a simpler detection API. Issue #6618 in turn asks for unified controls at or before external-resource resolution across raw storage, external links, and virtual-dataset sources.

The discussion records policy and API proposals, including use of the external `h5policy` prototype as a proving ground; this report does not treat those proposals as delivered controls [13, 46]. Formal finding APP-SEC-001 in Appendix A rates the incident at the affected service boundary. The similar Keras external-dataset failure is separately registered as APP-SEC-003; recurrence of a mechanism does not erase the differences in product, version, and deployment scope.

The unifying root cause: The repeated mistake is *trust-boundary confusion*. HDF5 sits at the boundary between a file and the process. Downstream frameworks often add another boundary: model loading, dataset ingestion, scientific workflow execution, browser upload, cloud service processing, or plugin resolution. Many CVEs happen because those layers collapse into one assumption: “This is just an HDF5 file, so reading it is safe.” That assumption is false. An HDF5 file can influence:

- memory allocation size
- dataset rank and shape
- chunk count and cache pressure
- filter/plugin loading
- external file lookup
- link traversal
- datatype conversion
- application-level model reconstruction
- tool output rendering

The common issue is **unsafe interpretation of HDF5-controlled metadata at the application boundary**.

6.2. Audit Findings and Mitigation Planning

The formal application findings are APP-SEC-001 through APP-SEC-005 in Appendix A. Their ratings apply to the bounded versions and deployments stated there, not to Keras, TensorFlow, Hugging Face, or applications using HDF5 as undifferentiated projects.

Mitigation has to be layered. Patching `libhdf5` alone will not fix Keras model deserialization, TensorFlow plugin path handling, or application-level external-reference policy.

The APP-S identifiers below identify recommendations in the downstream- application track. Their numbers do not express risk, urgency, effort, dependency, or implementation order.

Recommendation APP-S1: Define an “untrusted HDF5” profile

HDF5 should offer, and downstreams should use, a strict profile for any file received from users, networks, archives, model hubs, object stores, email, web uploads, or third-party datasets.

Default behavior for that profile:

```
dynamic plugins disabled
external links disabled or sandboxed
external raw dataset storage disabled or sandboxed
VDS source traversal restricted
maximum rank enforced
maximum element count enforced
maximum allocation size enforced
maximum metadata bytes enforced
maximum chunk count enforced
maximum filter expansion ratio enforced
cycles and deep graph traversal rejected
unknown or legacy-dangerous messages rejected
```

unless explicitly allowed

Today, pieces exist: plugin loading can be controlled, and all dynamic plugins can be disabled with `H5PLset_loading_state(0)` or `HDF5_PLUGIN_PRELOAD=:.` But this needs to become a cohesive security profile, not a set of hidden knobs.

Recommendation APP-S2: Ship a preflight validator

Create a validator that reads metadata only and returns a policy decision before the application allocates large arrays or deserializes model objects.

Example output:

```
{
  "safe_for_untrusted_load": false,
  "reasons": [
    "external dataset reference outside sandbox",
    "dataset declares 8.7 TB logical size",
    "requires dynamic filter plugin",
    "contains legacy Keras Lambda layer metadata"
  ]
}
```

For core HDF5, this validator should reason about file-format invariants. For downstreams, it should expose application hooks:

```
on_external_reference(path)
on_dataset_shape(path, dtype, shape, logical_bytes)
on_filter_required(filter_id)
on_link_traversal(source, target)
on_attribute(name, size)
```

Keras and TensorFlow could then enforce model-specific policy before creating Python objects.

Recommendation APP-S3: Disable dangerous HDF5 features by default in ML model loading

ML loaders should not behave like general HDF5 viewers.

For Keras/TensorFlow-style use:

```
do not allow Lambda or pickled code from legacy .h5
do not allow external dataset references
do not allow dynamic HDF5 plugins
do not eagerly allocate declared tensors before checking total
    byte budget
do not resolve paths relative to current working
    directory
do not honor HDF5_PLUGIN_PATH in model loading
    contexts
```

This directly addresses the Keras arbitrary-code issue, the Keras arbitrary-file-read issue, the Keras memory-exhaustion issue, and the TensorFlow plugin-search-path issue.

Recommendation APP-S4: Make external references opt-in

External links and external raw dataset storage are legitimate HDF5 features, but they are unsafe defaults for hostile content. HDF5 documentation states that external links store a target filename and object path, and external dataset storage search behavior can involve the current working directory, absolute paths, relative paths, `{ORIGIN}`, and `HDF5_EXTFILE_PREFIX`.

Mitigation:

```
reject absolute external paths
reject path traversal
reject current-working-directory lookup
require explicit sandbox root
```

```
require explicit allowlist by extension or path
log every external resolution
never follow external references during metadata
    preview
```

For services, the safest default is: `externalreferences=off`.

Recommendation APP-S5: Treat plugins as executable code

HDF5 filter plugins, VOL connectors, and VFDs are not data. They are code. The HDF5 docs state that plugins are shared libraries and that the default path can be overwritten by `HDF5_PLUGIN_PATH`. That is enough to create an application-level vulnerability if a privileged process uses an attacker-controlled path.

Mitigation:

```
clear HDF5_PLUGIN_PATH, HDF5_PLUGIN_PRELOAD,
    HDF5_EXTFILE_PREFIX in services
set plugin loading state explicitly at process start
allow plugins only from root/admin-owned directories
reject writable plugin directories
require hashes or signatures for plugins
never load plugins in setuid, service, notebook-hub,
    web-worker, or privileged contexts unless explicitly
    allowlisted
```

Sandboxing plugins...

Recommendation APP-S6: Require downstream SBOM and version reporting

Downstream projects should report:

HDF5 version

linkage type: static / dynamic / vendored / system
enabled filters
enabled VOL/VFD connectors
plugin search path policy
external-reference policy
safe-mode policy

This solves a practical problem: a user seeing “HDF5 CVE” in a scanner often cannot tell whether they are affected through `libhdf5`, an official tool, a vendored copy, a Python wheel, a model loader, or a plugin.

Recommendation APP-S7: Split CVE classification into scope tags

For HDF5-related CVE triage, use explicit tags:

HDF5-core-parser
HDF5-official-tool
HDF5-legacy-tool
HDF5-plugin-loading
HDF5-external-reference
HDF5-downstream-deserialization
HDF5-downstream-resource-policy
HDF5-vendored-library
not-HDF5
duplicate/rejected

This avoids bad prioritization. A heap overflow in `H5T__conv_struct_opt` is not the same class as Keras ignoring `safe_mode` for legacy `.h5` files, even though both mention HDF5.

A practical mitigation matrix for downstream maintainers

Table 22 – Minimum safe policies for downstream HDF5 use cases

Downstream use case	Minimum safe policy
viewing unknown .h5 files	run in a sandbox; disable plugins; disable external references; cap metadata and output size
loading ML models	never load untrusted legacy .h5; disable Lambda/pickled code; validate tensor shapes before allocation
cloud upload service	preflight only; no plugin loading; no external file access; resource limits; process isolation
HPC workflow	separate trusted internal files from imported files; scrub environment; pin plugin directories; use module-level HDF5 version floors
desktop scientific app	prompt before following external references; ship patched HDF5; avoid writable global plugin dirs
package/distribution	publish SBOM; expose HDF5 version; rebuild promptly after HDF5 security releases
library binding	expose security controls in the binding API, not just through environment variables

What The HDF Group can do to reduce downstream CVEs: The most useful move is not just more parser hardening. It is to give downstreams safe controls that are easy to use.

Recommended deliverables:

```
H5Pset_security_profile(fapl, H5_SECURITY_PROFILE_UNTRUSTED)
H5Pset_external_reference_policy(fapl, H5_EXTREF_DENY
    | H5_EXTREF_SANDBOX)
H5Pset_plugin_policy(fapl, H5_PLUGIN_DENY
    | H5_PLUGIN_ALLOWLIST)
H5Pset_max_logical_dataset_bytes(fapl, n)
H5Pset_max_metadata_bytes(fapl, n)
H5Pset_max_object_count(fapl, n)
H5Pset_max_link_traversal_depth(fapl, n)
h5validate --profile untrusted --json file.h5
```

Then publish downstream recipes for Keras, TensorFlow, h5py, netCDF, MATLAB, R, Java, and cloud services.

7. HDF5 in the Software Supply Chain

- HDF5 2.0.0 source-artifact integrity check [\[51\]](#)
- SBOM

7.1. Upstream Dependencies

This subsection summarizes external software that can be required by an HDF5 build. It starts with the default serial C library and is organized by build option, because the default serial C library has a much smaller dependency set than feature-complete, testing, packaging, or developer builds. More details are provided in [Appendix D](#).

HDF5's CMake build can either locate dependencies that are already installed or, for selected filter-related projects, add external source trees to the build with `FetchContent`. See [table 33](#) for details.

The baseline HDF5 build has no mandatory external dependencies. The core library and C API tests can be built and run without any additional software. See [table 34](#) for details.

The HDF5 build system has options that trigger additional dependencies when enabled. For example, enabling parallel HDF5 requires an MPI implementation, while enabling Fortran support requires a Fortran compiler. See [table 35](#) for details.

Enabling filter plugins or the plugin project can introduce additional filter-library dependencies. The HDF5 cache defaults include entries for bitgroom, bitround, bitshuffle, Blosc, Blosc2, bzip2, fpzip, JPEG, LZ4, LZF, SZ, ZFP, and Zstandard. Those libraries are controlled by the plugin project's own options when `hdf5_plugins` is built or found. See [table 36](#) for details.

Enabling VFDs for ROS3, HDFS, or other storage systems can introduce dependencies on external libraries and credentials. The same applies to VOL connectors. These are not filter dependencies, but they can affect the security and robustness of HDF5 file access, especially for third-party data. See [table 37](#) for details.

Additional dependencies are required for optional tools, tests, and security features. For example, the `hdf5_security` target depends on OpenSSL when built with `HDF5_ENABLE_SECURITY_FEATURES`. See table 38 for details.

Finally, developer builds and packaging scripts have their own dependencies. These include code linters, formatters, static analyzers, documentation tools, and packaging tools. These dependencies are not required for a default HDF5 build, but they are relevant for the supply-chain risk of development and release processes. For example, if a security vulnerability is introduced in a packager or source formatter, it could affect the integrity of HDF5 releases even if the vulnerability is not present in the HDF5 source code itself. See table 39 for details.

Several default upstream source locations are encoded in `config/CacheURLs.cmake` for dependencies that HDF5 can fetch or whose values are passed to external filter-plugin builds. See table 40 for details.

7.2. Downstream Dependencies

For this audit, downstream dependencies are projects that compile against, dynamically load, package, or define data conventions on top of HDF5. The HDF5 ecosystem is much larger than any static list, so the most important downstreams are best identified by blast radius: broad installation footprint, long-lived archival data, domain-standard file conventions, or use as an intermediate layer for other tools. The following categories of downstreams are especially relevant.

Scientific data models and exchange formats.

The highest-impact downstream is netCDF-4, which uses HDF5 as the storage layer for the enhanced netCDF data model and is central to climate, weather, ocean, atmospheric, and other Earth-system data workflows [57]. NASA HDF-EOS5, NeXus, and CGNS similarly define domain-specific conventions over HDF5 for Earth observation, neutron/x-ray/muon facilities, and CFD or aerospace simulation data [27, 42, 12]. For these formats, HDF5 compatibility is not just a library question: it affects the readability of long-lived archives and the ability of independent tools to interpret a shared schema.

Language bindings and analysis libraries.

h5py, PyTables, pandas HDFStore, Bioconductor’s rhdf5, HDF5.jl, and MATLAB’s HDF5 interfaces make HDF5 a routine dependency for Python, R, Julia, and MATLAB users [26, 45, 44, 9, 30, 40]. These packages are important because they often sit at the boundary between upstream HDF5 builds and end-user scripts. Their packaging choices determine whether users load a bundled HDF5, a system HDF5, or an environment-provided HDF5, and therefore whether ABI, plugin-path, thread-safety, MPI, and filter support match the files being opened.

Geospatial, visualization, and inspection tools.

GDAL’s HDF5 driver, ParaView/VTK-family builds, ITK’s HDF5 module, HDFView, and similar readers expose HDF5 files to interactive and automated analysis workflows [43, 34, 29]. This is an important security boundary: these tools are commonly used to inspect third-party data files, so robustness against malformed HDF5 objects, unusual filters, and unexpected VFD/plugin configuration has direct operational value.

HPC and parallel-I/O frameworks.

ADIOS2 includes an HDF5 engine, while netCDF-4, CGNS, h5py, and many simulation applications can be built against serial or parallel HDF5 variants [3]. These downstreams amplify configuration risk: MPI ABI compatibility, collective I/O semantics, file locking behavior, subfiling support, and optional VFDs must line up across the application, HDF5, MPI, and filesystem stack.

Machine-learning and model-artifact workflows.

TensorFlow/Keras still supports older HDF5 model and weight files even as newer native formats are preferred [48]. This keeps HDF5 in the model-exchange and training-checkpoint ecosystem, usually through h5py, and makes HDF5 parser behavior relevant for model files obtained from external sources.

Table 23 – Representative downstream projects that depend on HDF5.

Downstream	Role	Supply-chain relevance
------------	------	------------------------

netCDF-4	Common scientific data model and format layered on HDF5.	Large transitive footprint through climate, weather, ocean, remote-sensing, and HPC data stacks. Uses a constrained HDF5 subset, so compatibility depends on both HDF5 behavior and netCDF conventions.
HDF-EOS5	NASA Earth-observation format built on HDF5 concepts and libraries.	Long-lived public archives and many third-party readers make backward compatibility and robust metadata handling high-value.
NeXus	Facility data convention for neutron, x-ray, and muon science.	Uses HDF5 groups, datasets, and attributes as a standardized experimental-data container, so HDF5 schema interpretation affects reproducibility across facilities.
CGNS	CFD and aerospace data standard with an HDF5 mapping.	Important for mesh and simulation-result exchange; parallel-HDF5 behavior and large-file support affect production simulation workflows.
h5py, PyTables, and pandas HDFStore	Python interfaces and tabular/array storage layers.	Common bridge between binary HDF5 files and Python analysis. Wheel and conda packaging can hide which HDF5 build is actually loaded.
rhdf5, HDF5.jl, MATLAB HDF5 APIs	R, Julia, and MATLAB access layers.	Expose HDF5 to laboratory and scientific-computing workflows where files are often exchanged outside controlled build environments.

GDAL and geospatial readers	Raster and subdataset access for HDF5-based products.	Converts HDF5 issues into geospatial ingestion issues, especially for remote-sensing products with complex metadata and nested subdatasets.
ParaView/VTK, ITK, HDFView, and viewers	Interactive inspection, visualization, and conversion.	Frequently open untrusted or externally generated files; defensive parsing, filter availability, and plugin search paths matter.
ADIOS2 and simulation I/O layers	Alternative I/O stacks with HDF5 read/write engines or compatibility paths.	Parallel and high-throughput workflows depend on matching MPI, filesystem, and HDF5 feature assumptions across the whole stack.
TensorFlow/Keras HDF5 artifacts	Legacy model and weight serialization.	Keeps HDF5 in ML artifact exchange; malformed or incompatible model files surface through h5py and HDF5 library behavior.

7.3. Audit Findings and Mitigation Planning

The build-and-feature mismatch theme is recorded as evidence-backlog item SUP-SAFE-001 in Appendix A. It is not a formal finding pending a bounded affected population and evidence sufficient to assign exposure. The bullets below describe ecosystem conditions and potential failure mechanisms; they are not additional formally rated findings.

- HDF5 changes have a large transitive blast radius because many users reach HDF5 through netCDF, GDAL, h5py, MATLAB, or domain formats rather than through the HDF5 C API directly.
- ABI and packaging mismatches are a recurring downstream risk. Python, R, Julia, MATLAB, MPI, and system-package environments may all load different HDF5 builds in the same organization.

- File parsing is a practical security boundary. Viewers, converters, notebooks, and data-ingestion jobs often process files received from outside the organization that built the HDF5 library.
- Optional features can become hidden interoperability requirements: filter plugins, SZIP/zlib variants, ROS3/HDFS/VFD support, parallel HDF5, and file-locking behavior may be assumed by downstream data even when they are not present in a default HDF5 build.
- Long-lived scientific archives make deprecation slower than ordinary application software. Even when a downstream project prefers a newer format, historic HDF5 files remain operationally relevant.

The following identifier names a recommendation only; it does not assign risk, urgency, effort, dependency, or implementation order.

Recommendation SUP-S1: Maintain a producer/consumer profile compatibility and migration matrix

For every supported producer, reader, binding, and packaging profile, record the HDF5 version and linkage, ABI, enabled filters and plugins, VOL/VFD features, parallel and MPI assumptions, file-locking policy, and format bounds. Preserve representative artifacts and state the expected accept or controlled-reject result for each supported pair. When a mismatch is discovered, inventory the affected artifacts and publish a deterministic repair, rebuild, migration, or documented compatibility path rather than relying on the fact that one older environment happened to accept the file.

Acceptance requires a finite, versioned supported-profile catalog, matrix, and fixture set in CI; diagnostics that identify the mismatched capability; and a tested deterministic disposition for every incompatible supported pair: repair, rebuild, migration, controlled rejection with a supported alternative, or an accountable exception. Release SBOM and feature reporting under CORE-S11 and APP-S6 supply provenance inputs but do not, by themselves, demonstrate compatibility or treatment of legacy artifacts.

8. Independent HDF5 Implementations

8.1. Overview

PureHDF Managed .NET read/write without native binaries.

jHDF JVM HDF5 reading.

netCDF-Java JVM netCDF/HDF-EOS/HDF5 scientific-data reading.

pyfive Pure Python read-only inspection.

jsfive Browser-side direct HDF5 reading.

scigolib/hdf5 Pure Go read/write.

hdf5-pure and rustyhdf5-format/rustyhdf5 Pure Rust read/write.

async-hdf5 or h5coro Cloud object-store chunk mapping.

JLD2.jl Julia-native persistence in HDF5-compatible files.

Independent readers and writers are valuable checks on both the prose specification and the reference implementation. They also expose a three-way distinction essential to interoperability analysis: a file can be accepted by one reader, conform to or violate the normative format independently of that acceptance, and remain safe or unsafe for a particular deployment. Reader acceptance alone is not conformance evidence.

8.2. Two Distinct 2026 Chunk-Layout Cases

The two cases below produced superficially similar upgrade failures, but they must not be combined. One involved a reader imposing a stronger condition than the format required; the other involved contradictory writer output that older readers had tolerated.

8.2.1. Sufficient but Nonminimal Encoding

HDF5 issue #6409 concerns version-4 chunk-layout dimension widths. The format required an encoded width sufficient to hold the dimension value, but did not require the smallest possible width. The exact-width check present in HDF5 2.0.0, 2.1.0, and 2.1.1 could therefore reject a specification-permitted, nonminimal encoding produced by an independent writer. The merged HDF5-side change accepts any sufficient width and was tracked against 2.2.0 [4, 17]. PureHDF separately changed new output to match the reference reader's expectation [10, 35]. Formal finding IND-SAF-001 records the historical reader-side interoperability risk; issue closure is not, by itself, verification of every release artifact or backport.

8.2.2. Contradictory PureHDF Metadata

HDF5 issue #6534 began as a suspected HDF5 2.0 regression because the same production-derived file opened with HDF5 1.10.10 and 1.14.6 but failed with HDF5 2.0. Maintainer byte-level analysis identified a different condition in the affected PureHDF 2.1.2 output: float64 datatype metadata declared an eight-byte element while the version-4 chunk-layout message recorded a four-byte stored element. The file was internally inconsistent; the older readers had been permissive, and the HDF5 2.0 rejection was correct [2, 1].

The reporter described a continuously written production acquisition pipeline and a reader-version pin as the immediate workaround. A technical metadata-repair path was proposed and older readers remained a workaround, although the reporter said rewriting the files was not operationally feasible in that pipeline. The evidence therefore supports bounded operational and archival harm, not irreversible data loss. Formal finding IND-SAF-002 records this writer-side condition. Existing affected files remain a migration and inventory question even after corrected writer output is deployed.

8.3. Audit Findings and Mitigation Planning

The main interoperability challenge across direct-format implementations is not opening simple files; it is coverage of the long tail: dense groups, fractal heaps, shared object-header messages, chunk-index variants, references, VLEN, compound and nested datatypes, virtual datasets, external storage, SWMR flags, user blocks, non-core filters, unusual library-version bounds, and files produced by different HDF5 releases. This architectural observation is not assigned a risk tier without a concrete affected workflow. The two bounded formal findings are IND-SAF-001 and IND-SAF-002 in Appendix A.

The IND-S identifiers below identify recommendations only; their numbers do not express risk, urgency, effort, dependency, or implementation order.

Recommendation IND-S1: Maintain a differential conformance and compatibility corpus

Independent writers should validate generated files against normative on-disk invariants and a matrix of current and supported older reference readers. Reference-library maintainers should preserve independent-writer fixtures that exercise specification-permitted alternatives, not only files emitted by libhdf5 itself. The shared corpus should include both positive fixtures, which must be accepted, and negative fixtures, which contain a single intentional inconsistency and must be rejected predictably.

At minimum, the program should:

- round-trip generated files through h5dump, h5debug, h5py/libhdf5, and the independent implementation;
- test every supported chunk-layout and index variant, datatype width, filter pipeline, external-resource form, and library-version bound;
- preserve two separate regression cases: #6409 for sufficient but nonminimal widths and #6534 for contradictory element sizes;

- report the writer, writer version, format bounds, reader, reader version, and expected accept/reject result for every fixture; and
- inventory already-produced files when a writer defect is discovered, provide a deterministic repair or migration tool, and preserve checksums and provenance across repair.

Acceptance requires the current supported-reader matrix to accept every valid fixture, reject every intentionally invalid fixture with a controlled and documented diagnostic, and demonstrate a reproducible repair path for the legacy PureHDF case.

The machine-readable specification project `hdf5-pickles` is a natural source for generating and checking these fixtures [18].

9. Long-term Data Accessibility and Interpretability

Long term data accessibility and interpretability [7]

9.1. Audit Findings and Mitigation Planning

The present chapter does not yet define an affected archive, time horizon, failure condition, impact, or exposure sufficient for a separate formal finding. The bounded reader/writer compatibility cases that bear on long-term access are registered as IND-SAF-001 and IND-SAF-002 in [Appendix A](#).

10. Resources

- HDF SSP SIG [\[25\]](#)
- Tools
 - HDF5 CVE test suite [\[22\]](#)
 - A machine-readable specification of the HDF5 file format. [\[18\]](#)
 - HDF5 extension templates [\[23\]](#)
 - HDF5 plugins [\[24\]](#)
- S2D2

References

- [1] Abbo93. *Compatibility Warning: HDF5 2.0.0 / h5py 3.16.0 Regression Breaks Reading PureHDF Files*. 2026. URL: <https://github.com/Apollo3zehn/PureHDF/issues/164>. (accessed: 27.08.2026).
- [2] Abbo93. *Regression in 2.0.0 Chunk Layout Decoder Fails on Valid Files from Third-Party Writers (PureHDF)*. 2026. URL: <https://github.com/HDFGroup/hdf5/issues/6534>. (accessed: 27.08.2026).
- [3] ADIOS2 Developers. *ADIOS2 Supported Engines: HDF5*. 2026. URL: <https://adios2.readthedocs.io/en/latest/engines/engines.html#hdf5>. (accessed: 29.05.2026).
- [4] Apollo3zehn. *HDF5 lib is more restrictive than file format spec*. 2026. URL: <https://github.com/HDFGroup/hdf5/issues/6409>. (accessed: 27.08.2026).
- [5] Apple. *CVE-2021-31009*. 2021. URL: <https://www.cve.org/CVERecord?id=CVE-2021-31009>. (accessed: 04.06.2026).
- [6] Multiple authors. *179 results for 'file corruption'*. 2007-2026. URL: <https://forum.hdfgroup.org/search?q=file%20corruption>. (accessed: 21.05.2026).
- [7] Multiple authors. *223 results for 'plugin'*. 2007-2026. URL: <https://forum.hdfgroup.org/search?q=plugin>. (accessed: 21.05.2026).
- [8] Andreas Beckmann. *How to properly close HDF files when disk is full?* 2023. URL: <https://forum.hdfgroup.org/t/how-to-properly-close-hdf-files-when-disk-is-full/11714>. (accessed: 21.05.2026).
- [9] Bioconductor Project. *rhdf5*. 2026. URL: <https://bioconductor.org/packages/rhdf5>. (accessed: 29.05.2026).
- [10] Blackclaws. *Chunked Datasets Are Unreadable by HDF5 2.x: Chunk Dimension Size Encoded Length Is Hardcoded*. 2026. URL: <https://github.com/Apollo3zehn/PureHDF/issues/168>. (accessed: 27.08.2026).

- [11] Sean Brooks et al. *An Introduction to Privacy Engineering and Risk Management in Federal Systems*. NISTIR 8062. Gaithersburg, MD: National Institute of Standards and Technology, Jan. 2017. DOI: [10.6028/NIST.IR.8062](https://doi.org/10.6028/NIST.IR.8062). URL: <https://doi.org/10.6028/NIST.IR.8062>.
- [12] CGNS Steering Committee. *CGNS/HDF5 – An HPC implementation*. 2026. URL: <https://cgns.org/standard/hdf5.html>. (accessed: 29.05.2026).
- [13] chinhnguyen007. *Local File Access Through Untrusted HDF5 External Dataset References*. 2026. URL: <https://github.com/h5py/h5py/issues/2891>. (accessed: 27.08.2026).
- [14] Cisco Talos. *HDF5 Group libhdf5 H5T_ARRAY Code Execution Vulnerability*. 2016. URL: https://www.talosintelligence.com/vulnerability_reports/TALOS-2016-0176. (accessed: 27.08.2026).
- [15] CVE Project. *CVE-2021-36977*. 2021. URL: <https://www.cve.org/CVERecord?id=CVE-2021-36977>. (accessed: 04.06.2026).
- [16] CVE Project. *CVE-2026-34734*. 2026. URL: <https://www.cve.org/CVERecord?id=CVE-2026-34734>. (accessed: 04.06.2026).
- [17] Neil Fortner. *Allow Reading of Files with Chunk Dimensions Encoded Using More Bytes than Necessary*. 2026. URL: <https://github.com/HDFGroup/hdf5/pull/6432>. (accessed: 27.08.2026; merged pull request).
- [18] The HDF Group. *A machine-readable specification of the HDF5 file format*. 2026. URL: <https://github.com/HDFGroup/hdf5-pickles>. (accessed: 21.05.2026).
- [19] The HDF Group. *Commit 3914bb7*. Sep 25, 2025. URL: <https://github.com/HDFGroup/hdf5/commit/3914bb7f7ec7105d8bfb3aebd92e867cff5>. (accessed: 21.05.2026).
- [20] The HDF Group. *Commit 804f3bae*. Aug 13, 2025. URL: <https://github.com/HDFGroup/hdf5/commit/804f3bace997e416917b235dbd3beac3652a8>. (accessed: 21.05.2026).

- [21] The HDF Group. *Commit ce53bc0*. Mar 31, 2024. URL: <https://github.com/HDFGroup/hdf5/commit/ce53bc020d37e10a06a59501c45f1ab82539f> (accessed: 21.05.2026).
- [22] The HDF Group. *HDF5 CVE Test Suite*. 2026. URL: https://github.com/HDFGroup/cve_hdf5. (accessed: 21.05.2026).
- [23] The HDF Group. *HDF5 extension skeletons, literally*. 2026. URL: <https://github.com/HDFGroup/hdf5-boneyard>. (accessed: 21.05.2026).
- [24] The HDF Group. *HDF5 Plugins*. 2026. URL: https://github.com/HDFGroup/hdf5_plugins. (accessed: 21.05.2026).
- [25] The HDF Group. *HDF5 Safety, Security & Privacy (SSP) Special Interest Group's governance, processes, and artifacts*. 2026. URL: <https://github.com/HDFGroup/hdf5-ssp-sig>. (accessed: 21.05.2026).
- [26] h5py Developers. *HDF5 for Python*. 2026. URL: <https://docs.h5py.org/>. (accessed: 29.05.2026).
- [27] HDF-EOS Tools and Information Center. *HDF-EOS Libraries*. 2026. URL: <https://hdfeos.org/software/library.php>. (accessed: 29.05.2026).
- [28] Zero Day Initiative. *CVE-2026-2492*. 2026. URL: <https://www.cve.org/CVERecord?id=CVE-2026-2492>. (accessed: 21.05.2026).
- [29] Insight Software Consortium. *ITK Module: ITKHDF5*. 2026. URL: https://docs.itk.org/projects/doxygen/en/stable/group__ITKHDF5.html. (accessed: 29.05.2026).
- [30] JuliaIO. *HDF5.jl*. 2026. URL: <https://juliaio.github.io/HDF5.jl/dev/>. (accessed: 29.05.2026).
- [31] Keras Team. *Denial of Service via Malicious HDF5 Shape Metadata in a Keras Model*. 2026. URL: <https://github.com/keras-team/keras/security/advisories/GHSA-mgx6-5cf9-rr43>. (accessed: 27.08.2026).
- [32] Keras Team. *Legacy HDF5 Model Loading Ignores safe_mode=True*. 2025. URL: <https://github.com/keras-team/keras/security/advisories/GHSA-36rr-ww3j-vrjv>. (accessed: 27.08.2026).

- [33] Keras Team. *Local File Disclosure via HDF5 External Storage During Keras Weight Loading*. 2026. URL: <https://github.com/keras-team/keras/security/advisories/GHSA-3m4q-jmj6-r34q>. (accessed: 27.08.2026).
- [34] Kitware, Inc. *Building ParaView*. 2026. URL: https://www.paraview.org/paraview-docs/latest/cxx/md__builds_gitlab-kitware-sciviz-ci_Documentation_dev_build.html. (accessed: 29.05.2026).
- [35] Mark Lambert. *Make Tests Runnable on Windows and with Newer h5dump, with Related Fixes*. 2026. URL: <https://github.com/Apollo3zehn/PureHDF/pull/160>. (accessed: 27.08.2026; merged pull request).
- [36] Hugo Larcher et al. *Anatomy of a Frontier Lab Agent Intrusion: A Technical Timeline of the July 2026 Incident*. 2026. URL: <https://huggingface.co/blog/agent-intrusion-technical-timeline>. (accessed: 27.08.2026).
- [37] Google LLC. *CVE-2025-9905*. 2025. URL: <https://www.cve.org/CVERecord?id=CVE-2025-9905>. (accessed: 21.05.2026).
- [38] Google LLC. *CVE-2026-0897*. 2026. URL: <https://www.cve.org/CVERecord?id=CVE-2026-0897>. (accessed: 21.05.2026).
- [39] Google LLC. *CVE-2026-1669*. 2026. URL: <https://www.cve.org/CVERecord?id=CVE-2026-1669>. (accessed: 21.05.2026).
- [40] MathWorks. *HDF5 Files*. 2026. URL: <https://www.mathworks.com/help/matlab/hdf5-files.html>. (accessed: 29.05.2026).
- [41] National Institute of Standards and Technology. *NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0*. Framework. Gaithersburg, MD: National Institute of Standards and Technology, Jan. 2020. URL: <https://www.nist.gov/privacy-framework> (visited on 06/25/2026).
- [42] NeXus International Advisory Committee. *NeXus Data Format Manual*. 2026. URL: <https://manual.nexusformat.org/>. (accessed: 29.05.2026).

- [43] Open Source Geospatial Foundation. *HDF5 – Hierarchical Data Format Release 5 (HDF5)*. 2026. URL: <https://gdal.org/en/stable/drivers/raster/hdf5.html>. (accessed: 29.05.2026).
- [44] pandas Developers. *IO tools: HDF5 / PyTables*. 2026. URL: https://pandas.pydata.org/docs/dev/user_guide/io.html#hdf5-pytables. (accessed: 29.05.2026).
- [45] PyTables Developers. *PyTables Documentation*. 2026. URL: <https://www.pytables.org/>. (accessed: 29.05.2026).
- [46] takluyver. *Option(s) to Disable Various Kinds of External File Access*. 2026. URL: <https://github.com/HDFGroup/hdf5/issues/6618>. (accessed: 27.08.2026).
- [47] TensorFlow Authors. *Commit 46e7f7f: Disable Loading HDF5 Plugins*. 2025. URL: <https://github.com/tensorflow/tensorflow/commit/46e7f7fb144fd11cf6d17c23dd47620328d77082>. (accessed: 27.08.2026).
- [48] TensorFlow Authors. *Save, serialize, and export models*. 2026. URL: https://www.tensorflow.org/guide/keras/save_and_serialize. (accessed: 29.05.2026).
- [49] The HDF Group. *Dynamically-loaded Plugins (H5PL)*. 2026. URL: https://support.hdfgroup.org/documentation/hdf5/latest/group__h5_p_1.html. (accessed: 04.06.2026).
- [50] The HDF Group. *H5T__conv_struct Use After Free*. 2026. URL: <https://github.com/HDFGroup/hdf5/security/advisories/GHSA-w7v2-9cmr-pwwj>. (accessed: 27.08.2026).
- [51] The HDF Group. *HDF5 2.0.0 source-artifact integrity check*. URL: <https://github.com/HDFGroup/hdf5-ssp-sig/tree/main/audit/proofs/hdf5-core/2.0.0/psirt/release-integrity/PRISUPP-2204>. (accessed: 03.05.2026).
- [52] The HDF Group. *HDF5 Data Model and File Structure*. 2026. URL: https://support.hdfgroup.org/documentation/hdf5/latest/_h5_d_m__u_g.html. (accessed: 04.06.2026).

- [53] The HDF Group. *HDF5 Privacy Exposure Model*. 2026. URL: <https://github.com/HDFGroup/hdf5-ssp-sig/blob/main/models/Privacy%20Exposure.md#hdf5-privacy-exposure-model>. (accessed: 14.07.2026).
- [54] The HDF Group. *HDF5 Security Policy*. 2026. URL: <https://github.com/HDFGroup/hdf5/security/policy>. (accessed: 29.05.2026).
- [55] The HDF Group. *HDF5 Was the Mechanism, Not the Vulnerability*. 2026. URL: <https://www.hdfgroup.org/2026/08/23/hdf5-was-the-mechanism-not-the-vulnerability/>. (accessed: 27.08.2026).
- [56] Trend Micro Zero Day Initiative. *TensorFlow HDF5 Library Uncontrolled Search Path Element Local Privilege Escalation Vulnerability*. 2026. URL: <https://www.zerodayinitiative.com/advisories/ZDI-26-116/>. (accessed: 27.08.2026).
- [57] Unidata Program Center. *NetCDF-4 File Format*. 2026. URL: https://docs.unidata.ucar.edu/nug/2.0-draft/nc4_file_format.html. (accessed: 29.05.2026).

A. Findings Register

This appendix is the authoritative register of formal findings for this revision and maintains a separate evidence-and-scoping backlog. It applies the method in Section 1.7 to public evidence available through August 27, 2026. A formal finding is a concrete adverse-event scenario at a stated boundary; it is not a score assigned to a technology, feature, CVE count, recommendation, or project. Broad mechanisms that do not yet define an adverse consequence and affected population appear only in Table 25; they are not formal findings. Unless a record expressly says otherwise, the assessment did not independently reproduce the reported condition and did not assess the current installed population.

Table 24 records inherent-risk axes and tiers where evaluated, together with every finding's rating status. It does not imply that every version or deployment is affected today. A public fix, issue closure, or reporter statement is noted where relevant, but it is not credited as current residual-risk reduction without sufficient evidence of the implemented control and its coverage. An *NE* entry is an evidence or scoping gap, not a Low-risk conclusion.

Linked recommendation identifiers show intended control coverage only. Response routing is shown separately in Table 26. Implementation dependencies, effort, delivery sequence, ownership, acceptance evidence, and residual-risk decisions do not alter the inherent ratings below and are not populated in this findings register. The proposed work packages, dependencies, accountable roles, effort, and acceptance gates are maintained separately in Appendix B; the linked identifiers must not be read as completed planning records.

Table 24 – Formal findings and report-wide rating status

ID	Scenario shorthand	Dim.	I/E	Tier	Status	Conf.
CORE-SEC-001	Malformed on-disk metadata reaches memory-unsafe core-library paths in historically affected releases.	Security	I3/E2-E3	High	Provisional	Moderate
CORE-SEC-002	File-controlled work, allocation, traversal, or error paths terminate or exhaust an affected reader.	Security	I2/E2-E3	Moderate	Provisional	Moderate
CORE-TOOL-001	A malicious file triggers the reported h5dump use-after-free in HDF5 1.14.1-2 and earlier.	Security	I2-I3/E2	Moderate-High	Provisional	Moderate

Table 24 – Formal findings and report-wide rating status, continued

ID	Scenario shorthand	Dim.	I/E	Tier	Status	Conf.
CORE-PRIV-001	Sensitive plaintext metadata is disclosed when a file is shared under payload-only protection.	Privacy	I2-I3/E2	Moderate-High	Provisional	Moderate
CORE-SAFE-001	Storage exhaustion during write or close may leave an incomplete or corrupted file and may cause data loss.	Safety	I2-I4/E?	Not assigned	NE	Low
APP-SEC-001	The affected Hugging Face dataset service followed attacker-selected external raw-storage paths with worker authority and returned local files.	Security	I3/E4	Critical	Rated	High
APP-SEC-002	Affected Keras legacy-HDF5 model loading executes embedded code despite <code>safe_mode=True</code> .	Security	I3/E2	High	Rated	High
APP-SEC-003	Affected Keras model loading follows attacker-controlled HDF5 external dataset references and discloses local files.	Security	I3/E3	High	Rated	High
APP-SEC-004	Affected Keras weight loading allocates from an extreme file-declared shape and exhausts memory.	Security	I2/E3	Moderate	Rated	High
APP-SEC-005	TensorFlow 2.17.0 loads HDF5 plugins from an uncontrolled search location, enabling local privilege escalation.	Security	I3/E2	High	Rated	Moderate
IND-SAF-001	HDF5 2.0/2.1 exact-width validation rejects a sufficient but nonminimal chunk encoding permitted by the specification.	Safety	I2/E2	Moderate	Rated	High
IND-SAF-002	Older permissive readers accept contradictory PureHDF 2.1.2 chunk metadata that HDF5 2.0 rejects after upgrade.	Safety	I2/E2	Moderate	Rated	High

A.1. Evidence and Scoping Backlog

The observations below identify work needed to determine whether additional formal findings exist. They have no impact or exposure axes, risk tier, response urgency, or implied Low-risk status.

Table 25 – Observations requiring a concrete adverse-event scenario

ID	Observation	Evidence needed for a finding
EXT-PRIV-001	Extensions can move data and metadata across storage, cache, logging, network, and executable-plugin boundaries.	Identify a deployment, sensitive-data population, unauthorized recipient or retention event, affected scope, and resulting harm.
SUP-SAFE-001	Downstream builds and workflows can disagree about ABI, linkage, filters, plugins, VFDs, parallel features, or file locking.	Identify a concrete producer/consumer profile pair, affected population, failure mode, recoverability, and recurrence evidence.

A.2. Response Routing

The routing below follows the default rule in Section 1.7. Where current residual risk was not evaluated, it uses inherent risk as the conservative provisional baseline; a tier range is routed at its upper bound. Routing is conditional on confirming the stated affected scope and is not a claim that every present deployment needs the same action. The target horizons begin when an affected deployment or equivalent exposure is identified. They are assessment recommendations, not stakeholder-approved delivery commitments, and do not incorporate effort or dependencies. In particular, Hugging Face reports that it stopped wrongly processing HDF5 external references, but this assessment did not validate the implemented control or assign a current residual tier. Phases 0–2 of Appendix B operationalize these clocks; later structural work neither replaces nor extends them.

Table 26 – Provisional response urgency and target horizons

Urgency and horizon	Findings	Decision rule for this register
Immediate—before the next untrusted processing job and no later than 24 hours after identification	APP-SEC-001	Immediately contain any equivalent service that still automatically follows file-selected external resources with access to sensitive local files. The historical incident rating is not a current rating of Hugging Face.
Near-term—within 30 days	CORE-SEC-001, CORE-TOOL-001, CORE-PRIV-001, APP-SEC-002, APP-SEC-003, APP-SEC-005	Identify affected releases and exposed deployments, apply available fixes or containment, minimize disclosed metadata, and verify the trust boundary.
Planned—within 90 days or the next supported release or migration window, whichever is sooner	CORE-SEC-002, APP-SEC-004, IND-SAF-001, IND-SAF-002	Plan treatment and acceptance testing; expedite where an affected production pipeline, archive, sensitive-data population, or service is identified.

A.3. Evidence Actions Without Assigned Urgency

CORE-SAFE-001 requires a bounded API/filesystem scenario and recoverability evidence before a tier or urgency can be assigned. Items EXT-PRIV-001 and SUP-SAFE-001 require the scenario evidence listed in Table 25. These are evidence actions, not a fifth response-urgency category.

A.4. Core Library, Tool, and Format Findings

CORE-SEC-001 — Memory-unsafe processing of malformed metadata

Scenario. An untrusted originator supplies a crafted HDF5 file to a process using a historically affected HDF5 C library. Insufficiently validated file-derived sizes, counts, offsets, message state, layout state, filter parameters, or datatype state reach allocation, copy, object-construction, or cleanup paths and cause memory corruption, including credible process compromise for the variants whose primary records support that consequence.

Scope and evidence. The assessed population consists only of deployments matching an affected version-and-path pair represented in Appendix C and processing untrusted files. The H5FS, H5C, H5O, H5T, H5Z, heap, dataspace/layout, and vector-copy variants are evidence for the shared adverse event, not separately scored objects. A detailed primary report for HDF5 1.8.16 traces file-controlled array rank to an out-of-bounds heap write and possible code execution in the consuming application [14]; the cited later fixes demonstrate early sanity checks, bounds and overflow tracking, and controlled rejection replacing unsafe behavior [22, 20, 19, 21]. This record excludes termination-only and resource-consumption variants assigned to CORE-SEC-002 and the tool-specific UAF assigned to CORE-TOOL-001. It does not assert that every CVE had code-execution impact or that a current HDF5 2.x release contains every historical condition.

Rating basis. I3 reflects credible process compromise or major loss of process integrity in the evidenced variants. E2 applies to interactive or otherwise constrained file processing; E3 applies where an affected deployment automatically ingests untrusted files through a common workflow. Both produce a High tier, while exact version and deployment prevalence remain incomplete. The rating is therefore **I3/E2–E3, High, Provisional, Moderate confidence**. Current release and installed-population residual risk were not evaluated.

Linked recommendations. CORE-S0–CORE-S7 and CORE-S12; the primary structural controls are CORE-S1–CORE-S3.

CORE-SEC-002 — Uncontrolled work and resource consumption

Scenario. A crafted, truncated, or inconsistent file reaches affected decode, traversal, arithmetic, allocation, recursion, or lifecycle paths and causes an assertion, null dereference, divide-by-zero, leak, stack exhaustion, or uncontrolled resource consumption, interrupting the consuming process or workflow.

Scope and evidence. The assessed population consists only of deployments matching an affected version-and-path pair in Appendix C and processing the triggering file. This record includes termination and resource-consumption outcomes without evidenced memory corruption; it excludes the memory-unsafe variants assigned to CORE-SEC-001 and the tool-specific UAF assigned to CORE-TOOL-001. Exact fixed versions across the represented paths and the present installed population are not established. The file-space repair is one direct example of converting an assertion reached from corrupted metadata into a controlled error [20, 22].

Rating basis. I2 reflects a meaningful but ordinarily recoverable process or workflow interruption; a mission-level outage requires a separate deployment-specific record. E2 applies to interactive or otherwise constrained file processing; E3 applies where an affected deployment automatically ingests untrusted files through a common workflow. Both produce a Moderate tier, while incomplete version prevalence makes the assessment provisional. The rating is **I2/E2–E3, Moderate, Provisional, Moderate confidence**. Current release and installed-population residual risk were not evaluated.

Linked recommendations. CORE-S0–CORE-S8, CORE-S12, APP-S1, and APP-S2.

CORE-TOOL-001 — h5dump use-after-free

Scenario. An attacker supplies a malicious HDF5 file to a user or automated workflow that invokes an affected h5dump; the file triggers the reported H5T__conv_struct heap use-after-free and may compromise or terminate the inspection process.

Scope and evidence. The HDF Group advisory identifies HDF5 1.14.1-2 and earlier as affected and reproduces AddressSanitizer-detected termination when the supplied file is processed by the utility [16, 50]. It states that practical code-execution exploitability is unknown. This is a tool finding, not evidence that every libhdf5 consumer reaches the same path.

Rating basis. The demonstrated termination supports I2; credible but unverified process compromise from the UAF supports I3 as the upper bound. E2 reflects the affected-version, crafted-file, and explicit inspection preconditions. The rating is **I2–I3/E2, Moderate–High, Provisional, Moderate confidence**. Current installed-population residual risk was not evaluated.

Linked recommendations. CORE–S6, CORE–S9, CORE–S12, and APP–S2.

CORE-PRIV-001 — Plaintext metadata disclosure

Scenario. An HDF5 file containing sensitive object names, attributes, member labels, comments, user-block content, provenance, or structural relationships is shared with a recipient who is authorized for a protected payload but not for that context. Direct HDF5 or byte-level inspection reveals the unintended metadata.

Scope and evidence. This finding is limited to files that actually contain sensitive plaintext metadata and a sharing boundary that protects only the nominal payload. The format’s self-describing structure establishes the mechanism; the Privacy Exposure Model identifies metadata and structural exposure as privacy threat classes [52, 53].

Rating basis. I2 reflects bounded sensitive-context disclosure; I3 is plausible where the same mechanism reveals high-sensitivity context or substantially affects a defined population. E2 reflects the need for both sensitive metadata and a mis-scoped disclosure boundary. Data sensitivity, affected population, and workflow prevalence were not measured, so the rating is **I2–I3/E2, Moderate–High, Provisional, Moderate confidence**. Deployment-specific findings should replace this range when those facts are known. Current installed-population residual risk was not evaluated.

Linked recommendations.

CORE-PRIV-S1 and CORE-PRIV-S3-CORE-PRIV-S4.

CORE-SAFE-001 — Storage-exhaustion write failure

Scenario and evidence gap. Storage exhaustion during file write or close may leave an incomplete or corrupted file and cause data loss, as raised in community reports cited by the core chapter [8, 6]. The report has not bounded the API sequence, version, filesystem and buffering behavior, recovery path, uniqueness of the affected data, or frequency.

Rating. The credible impact spans I2 through I4 depending on recoverability and the value of the data; exposure is not established. The finding is therefore **NE**, **Low confidence**, not Low risk. No existing recommendation fully addresses the evidence and treatment gap.

Linked recommendations. None; treatment gap.

A.5. Application-Boundary Findings**APP-SEC-001 — External raw storage confused deputy**

Scenario. In the affected July 2026 Hugging Face deployment, a remote party supplied a valid HDF5 file whose dataset declared local files as external raw storage. The dataset-processing worker opened those paths with its own filesystem authority and returned their bytes to the requester, disclosing its environment, credentials, and source code.

Scope and evidence. Hugging Face reports that this vector performed file disclosure without executing code; the separate Jinja2 injection supplied code execution. The HDF Group identifies external raw storage as an intentional documented capability and the service as the authority-bearing confused deputy, not an HDF5 parser failure [36, 55]. The rating is confined to the affected service at incident

time and to equivalent deployments with the stated preconditions; it is not an ecosystem-prevalence claim.

Rating basis. I3 reflects actual unauthorized resource access and substantial disclosure of secrets, credentials, and implementation details. E4 reflects normal automatic processing of an ordinary attacker upload, transparent reference following, and a direct, repeatable disclosure path within that deployment. The inherent rating is **Critical, Rated, High confidence**.

Current residual and response. Hugging Face states that its renderer no longer wrongly processes HDF5 external references. Public evidence is insufficient to validate control design and coverage, so current residual risk for that service was not evaluated and no residual tier is assigned. The h5py discussion records laborious application-level detection, a sandbox recommendation, and the decision to seek upstream control; HDF5 issue #6618 records the resulting request for unified controls over external data, external links, and virtual sources. Proposals discussed there are not treated as shipped controls [13, 46]. Equivalent still-exposed deployments require Immediate containment.

Linked recommendations. APP-S1, APP-S2, APP-S4, and CORE-S4.

APP-SEC-002 — Keras legacy-HDF5 code deserialization

Scenario and scope. An attacker supplies a crafted legacy .h5/.hdf5 model to Keras 3.0.0 through 3.11.2. A victim loads it expecting `safe_mode=True` to prevent unsafe reconstruction, but a Lambda layer's serialized code executes in the loader process [37, 32].

Rating basis. I3 reflects arbitrary code execution in the loader's authority. E2 reflects the legacy format, crafted Lambda content, affected version, and passive load preconditions. The rating is **High, Rated, High confidence**.

Linked recommendations. APP-S3. This is application deserialization layered on HDF5, not a core HDF5 parser finding.

APP-SEC-003 — Keras external-dataset local-file read

Scenario and scope. A remote attacker supplies a crafted `.keras` model to Keras $>=3.0.0, <3.12.1$ or $>=3.13.0, <3.13.2$. During model loading, an embedded HDF5 external dataset reference selects a local path and discloses a file readable by the loader process [39, 33].

Rating basis. I3 reflects unauthorized local-resource access and potentially substantial sensitive-information disclosure. E3 reflects a remotely supplied artifact, few technical preconditions, and a normal model-load action, while remaining bounded to the affected versions and model-loading surface. The rating is **High, Rated, High confidence**.

Linked recommendations. APP-S1-APP-S4 and CORE-S4.

APP-SEC-004 — Keras shape-driven memory exhaustion

Scenario and scope. A remote attacker supplies a crafted `.keras` archive to Keras $>=3.0.0, <=3.12.0$ or $>=3.13.0, <3.13.2$. Its valid `model.weights.h5` declares an extremely large dataset shape; weight loading allocates without an adequate budget, exhausts memory, and crashes the Python interpreter [38, 31].

Rating basis. I2 reflects the evidenced process and workflow interruption; no broader outage or durable data loss is assumed. E3 reflects low-complexity, remotely supplied content crossing a normal model-loading boundary, subject to the victim or service loading the artifact. The rating is **Moderate, Rated, High confidence**.

Linked recommendations. APP-S1-APP-S3, CORE-S3, and CORE-S4.

APP-SEC-005 — TensorFlow plugin search-path escalation

Scenario and scope. A low-privileged local attacker on a TensorFlow 2.17.0 installation places a plugin in an unsecured location searched by the HDF5

integration. TensorFlow loads the plugin and executes its code with the target user's authority [28, 56, 47].

Rating basis. I3 reflects privilege escalation and arbitrary code execution. E2 reflects the required local foothold, affected version, writable searched location, and plugin-load path. The condition is supported by the coordinated advisory and vendor fix, but the report did not reproduce it. The rating is **High, Rated, Moderate confidence**.

Linked recommendations. APP-S5 and CORE-S10.

A.6. Independent-Implementation and Interoperability Findings

IND-SAF-001 — Sufficient nonminimal chunk encoding rejected

Scenario. A workflow upgrades its reader to an HDF5 2.0/2.1 release containing the exact-width check—confirmed in 2.0.0, 2.1.0, and 2.1.1—and opens a version-4 chunk layout whose encoded dimension width is sufficient but nonminimal. Validation rejects the file even though the format did not require the smallest possible width, interrupting access to data that earlier readers accepted.

Scope and evidence. HDF5 issue #6409 distinguishes the specification-permitted encoding from an undersized invalid encoding and records effects on independent writers. The merged reader-side change accepts any sufficient width and was tracked against the HDF5 2.2.0 milestone; this report does not claim that a specific release artifact or backport contains it without release-level verification [4, 17, 10, 35].

Rating basis. I2 reflects a meaningful, bounded interoperability and data-access failure. E2 reflects the specific layout version, nonminimal encoding, and reader-upgrade preconditions. The rating is **Moderate, Rated, High confidence** for the historical affected scope. Current residual risk was not evaluated, and no residual tier is assigned.

Linked recommendations. CORE-S1, CORE-S6, CORE-S8, and IND-S1.

IND-SAF-002 — Contradictory PureHDF chunk metadata

Scenario. A production or archival workflow upgrades from a tolerant HDF5 1.x reader to HDF5 2.0 and reads an affected compressed file produced by PureHDF 2.1.2. The file's version-4 chunk layout contradicts its datatype metadata; the stricter reader correctly rejects the affected datasets, interrupting processing and stranding existing data until the reader is pinned or the files are repaired or regenerated.

Scope and evidence. In the supplied production-derived file, the HDF5 maintainer analysis found float64 datatype element size 8 while the chunk layout recorded stored element size 4. Older HDF5 1.10.10 and 1.14.6 readers accepted the bytes; HDF5 2.0 rejected them. The issue was closed as malformed writer output, and the PureHDF discussion records the writer-side response [2, 1]. This condition is distinct from the sufficient nonminimal width in IND-SAF-001; permissive acceptance is not evidence of conformance.

Rating basis. I2 reflects actual production workflow interruption and a persistent but repairable compatibility problem; no irreversible data loss is evidenced. E2 reflects the confirmed writer version, affected layout, compressed dataset, and reader-upgrade preconditions. The rating is **Moderate, Rated, High confidence**. A technical metadata-repair path was proposed and older readers remained a workaround, although the reporter said rewriting affected production files was not operationally feasible in that pipeline. Later PureHDF output restored production operation, but the inventory and repair status of existing files are unknown. Current residual risk for the legacy corpus was not evaluated, and no residual tier is assigned.

Linked recommendations. CORE-S1, CORE-S6, CORE-S8, and IND-S1.

A.7. Evidence-Backlog Record Details

EXT-PRIV-001 — Extension-mediated privacy boundary observation

Observation and evidence gap. VOL connectors, filters, and VFDs can move data or metadata into remote stores, caches, temporary artifacts, logs, networks, or dynamically loaded code and thereby change the privacy boundary described in Section 4. The report does not define a concrete deployment, sensitive-data population, unauthorized recipient, retention period, or harm magnitude for this general scenario [53].

Register treatment. This mechanism is not a formal finding. Impact, exposure, tier, confidence, and response urgency are not assigned; this does not dispute the documented mechanism.

Linked recommendations. CORE-PRIV-S2, CORE-PRIV-S3, VOL-S1-VOL-S4, FILTER-S1-FILTER-S5, and VFD-S1-VFD-S4.

SUP-SAFE-001 — Downstream build and feature mismatch observation

Observation and evidence gap. A downstream environment loads an HDF5 build whose ABI, linkage, filters, plugins, VFDs, parallel features, or file-locking behavior differs from the profile assumed by a file or workflow, causing a read failure or operational interruption. Section 7 establishes the breadth and configuration mechanisms but does not establish an affected population, frequency, bounded version set, or realized impact.

Register treatment. This theme is not a formal finding. Impact, exposure, tier, confidence, and response urgency are not assigned; a material workflow interruption remains a plausible hypothesis, not a report-wide rating.

Linked recommendations. CORE-S11, APP-S6, and SUP-S1.

B. Phased Mitigation Roadmap

This appendix converts the response routing in Table 26 into a proposed delivery plan. It is an assessment recommendation, not evidence that an organization has accepted the dates, assigned the work, or implemented the controls. The response clocks in Phases 0–2 begin when an affected deployment or equivalent exposure is identified, as specified in Table 26; the scope census in RM– 1A and the Phase 3 program horizon begin when the roadmap is adopted. The assessment sponsor should record a dated decision to adopt, modify, or reject the proposal; adoption must set a due date for that census so the response clock cannot remain latent through unbounded non-discovery. A pre-adoption exposure still enters the response route and is not held for the program decision.

The roadmap does not revise inherent risk. Phase, dependency, owner, effort, and implementation order are treatment-planning fields under Table 3; none is added to or subtracted from a finding’s impact, exposure, tier, or confidence. A dependency that prevents a final control from shipping does not extend a response horizon: the accountable owner must maintain an interim containment, record the variance, and obtain an explicit residual-risk decision.

At publication, every work package below has planning status *Proposed* and implementation status *not verified*. The role labels are proposed accountability boundaries, not assertions about present HDF Group or downstream assignments. No residual-risk acceptance is recorded by this roadmap. Within ten business days of adoption, the roadmap authority should replace each role label with a named accountable person, issue or program record, dated target or release, and implementation status. For a triggered Phase 0 record, the APP owner and GOV risk authority are assigned at T0 and containment begins immediately; the ten-day allowance applies only to untriggered program packages.

B.1. Accountability Roles

Table 27 – Proposed roadmap accountability roles

Code	Role	Accountability boundary
GOV	Security and roadmap authority	Owns scope, named assignments, exceptions, phase-gate decisions, and formal residual-risk acceptance or escalation.
CORE	Core library and tools engineering	Owns parser, arithmetic, resource-policy, utility, regression, fuzzing, and core API changes.
APP	Downstream application and service owner	Owns model or dataset loading policy, deployment containment, supported-version rollout, sandboxing, and application acceptance tests.
PRIV	Privacy and data-governance owner	Owns data classification, metadata minimization, disclosure boundaries, retention, encryption requirements, and privacy acceptance evidence.
INTEROP	Format and interoperability owner	Coordinates the reference library, specification, independent implementations, compatibility fixtures, and repair or migration policy.
EXT	Extension and plugin ecosystem owner	Owns plugin, VOL, VFD, and filter policy, manifests, trust controls, introspection, and extension documentation.
REL	Release and supply-chain owner	Owns build provenance, dependency policy, SBOMs, release gates, and downstream-consumable configuration reporting.
ASSURE	Independent verifier	Does not implement the control being reviewed; reproduces the acceptance tests, checks the evidence boundary, and signs the verification result used for closure and residual-risk reassessment.

One role is accountable for each work package even when several roles perform the work. The named accountable person may delegate tasks but remains responsible for the evidence package and readiness attestation; only GOV approves a program gate, exception, or residual-risk disposition. A package that spans independently governed projects or deployments must be instantiated once per accountable owner and scope; the generic APP package, for example, does not make one downstream responsible for another. Every instance also names its responsible

implementer, an ASSURE verifier independent of that implementer, and a separate release or deployment approver that authorizes rollout after verification. For a High or Critical scope, the verifier may not also be the package owner, rollout approver, or risk acceptor.

B.2. Phase Gates and Clocks

Phases are delivery waves, not severity levels. Work may proceed in parallel, and a later-phase structural control may begin before an earlier phase closes. The earlier response clock still controls. Phase 2 also contains evidence work for unrated records; its placement is an assurance target and does not assign those records a response urgency.

Table 28 – Roadmap phases and exit gates

Phase	Clock	Required outcome	Exit gate
0—Contain	Before the next untrusted job and no later than 24 hours after equivalent exposure is identified	Remove the demonstrated external-resource path from attacker reach while preserving evidence and rotating exposed secrets where indicated.	No confirmed equivalent path remains in service without tested accountability; an accountable owner, affected scope, and decision record exist.
1—Verify and remediate known scope	Initial census completes within 30 days of adoption; Near-term treatment completes within 30 days of identifying an affected deployment	Establish the current population and apply supported fixes or tested compensating controls for known High and upper-bound-High scenarios.	Every applicable Phase 1 finding has version and exposure evidence, a negative test, an implementation record, and a current residual-risk disposition.

Table 28 – Roadmap phases and exit gates, continued

Phase	Clock	Required outcome	Exit gate
2— Establish release safeguards	For Planned findings, within 90 days of identification or the next supported release or migration window, whichever is sooner; evidence actions have an administrative assurance target of 90 days after adoption	Deliver strict-processing guardrails, interoperability coverage, and bounded evidence packages for the unrated observations.	The safeguards pass integration tests; compatibility cases have deterministic expected results; evidence gaps are either promoted to findings and routed or remain explicitly bounded and unrated.
3— Eliminate recurring classes	Target 3–12 months after roadmap adoption, through staged supported releases	Replace local repairs with invariant-driven parsing, structural validation, fuzz and review gates, and governed extension loading.	Each declared component or release tranche satisfies its acceptance evidence; unfinished components remain visible with containment and dated follow-on work, rather than being treated as class closure.
4—Sustain and reassess	Every pull request, nightly run, release candidate, supported release, and at least annual program review, evidence as applicable	Keep controls effective, detect regression and ecosystem mismatch, and make residual-risk decisions from verified evidence.	Required gates run at their defined cadence; failures block or create a named, expiring exception; the findings and roadmap registers are updated.

When a package covers findings with different response routes, each finding retains its own maximum horizon. Co-delivering a Planned item during Phase 1 is an implementation convenience, not an increase in its risk or urgency; a Planned item in the same package cannot be used to defer a Near-term item to the later clock.

Each finding-and-scope instance therefore has an SLA child record separate from the work package's final-control or structural due date. The child records the finding ID, defined census boundary and completeness attestation, deployment or artifact scope, T0, urgency and maximum horizon, required interim action, due date, performed date, status, and evidence. A 24-hour containment can close its SLA child without falsely marking a shared architectural package complete; a large shared package cannot hide an overdue child behind its later program date.

B.3. Work-Package Register

Dependencies below are concrete enabling relationships, not reasons to defer containment. *None* means no prerequisite work package is known; *external* means that a supported vendor release, deployment sponsor, or test fixture must be available. Effort uses the definitions in Table 3 and describes work breadth, not risk or elapsed time.

Table 29 – Proposed mitigation work packages

ID	Phase / owner	Records	Scope and recommendation coverage	Dependencies	Effort
RM-0A	0 / APP	APP-SEC-001; equivalent exposure under APP-SEC-003	Disable or sandbox external raw storage, external links, and virtual sources in untrusted processing; remove worker access to unnecessary local files and credentials; preserve logs and rotate secrets where exposure is indicated. Provides application containment consistent with APP-S1 and APP-S4 while compensating for the absent or unverified CORE-S4 API; it does not implement that core recommendation.	None; where a library control is unavailable, isolate or stop the affected job.	Medium
RM-1A	1 / GOV	All formal findings; scoping support for evidence records	Create a deployment, supported-version, feature, provenance, and authority census; assign the applicable HDF5/downstream scope tag; identify applicability, a named owner, and current control evidence for each record. Supports APP-S6, APP-S7, and CORE-S11.	None; affected projects and deployment owners must supply evidence.	Medium

Table 29 – Proposed mitigation work packages, continued

ID	Phase / owner	Records	Scope and recommendation coverage	Dependencies	Effort
RM-1B	1 / CORE	CORE-SEC-001, CORE-SEC-002, CORE-TOOL-001	Move affected core and tool populations to a supported fixed version or isolate them; add minimized negative tests and tool-specific sanitizer regression. Covers the near-term portions of CORE-S0, CORE-S6, CORE-S9, and CORE-S12.	RM-1A; external supported fix or a documented containment.	Medium
RM-1C	1 / APP	APP-SEC-001– APP-SEC-005	Patch affected model and dataset loaders or deploy a tested local compensating control; verify safe deserialization, external-reference rejection, allocation budgets, and plugin-path ownership. Covers APP-S3–APP-S5 and the deployable portions of APP-S1; retains RM-0A until final controls pass.	RM-0A when triggered; RM-1A; an external supported application release or tested local control. Release unavailability does not extend the response clock.	Medium
RM-1D	1 / PRIV	CORE-PRIV-001	Identify sensitive plaintext metadata and sharing boundaries; minimize or tokenize metadata, restrict recipients, and determine whether those controls meet the disclosure policy. Covers CORE-PRIV-S1 and CORE-PRIV-S3.	RM-1A; a data owner must classify the affected population and intended recipients.	Medium
RM-2A	2 / CORE	CORE-SEC-001, CORE-SEC-002, CORE-TOOL-001, enabling APP-SEC-001, APP-SEC-003, APP-SEC-004	Ship an enforceable untrusted-input profile and preflight interface with external-resource, plugin, traversal, metadata, allocation, and expansion budgets; bind any preflight decision to the same file identity and runtime open so validation cannot be bypassed by replacement or policy drift; harden inspection tools. Covers CORE-S3, CORE-S4, CORE-S9, and the core portions of APP-S1 and APP-S2.	RM-1A; fixtures from RM-1B are a coordination input, not a hard prerequisite, and downstream work need not wait for the final core API.	Large
RM-2B	2 / APP	APP-SEC-001, APP-SEC-003, APP-SEC-004	Integrate strict runtime denial and enforcement-coupled preflight into each downstream boundary; impose overflow-safe per-object and aggregate allocation budgets before materialization. Covers the downstream portions of APP-S1–APP-S4. Application allocation controls are independently required and neither wait for nor follow automatically from core checked arithmetic.	RM-1A, RM-1C; RM-2A is a coordination dependency, and an interim application policy wrapper is acceptable.	Medium

Table 29 – Proposed mitigation work packages, continued

ID	Phase / owner	Records	Scope and recommendation coverage	Dependencies	Effort
RM-2C	2 / INTEROP	compatibility policy for CORE-SEC-002; IND-SAF-001, IND-SAF-002	Maintain positive and intentionally invalid fixtures across supported readers and writers; inventory affected legacy files and provide deterministic repair, migration, or documented compatibility handling. Covers CORE-S6, CORE-S8, and IND-S1; per-case normative decisions feed, but do not duplicate, the CORE-S1 registry in RM-3A.	RM-1A; external writer, reader, and production-derived fixtures.	Large
RM-2D	2 / CORE	CORE-SAFE-001	Reproduce storage exhaustion across bounded write, flush, and close sequences, HDF5 versions, VFD/filesystem/buffering profiles, and recovery paths; record the last durable state, diagnostics, repairability, and data uniqueness. This is evidence acquisition, not assigned urgency.	Storage fault injection, representative workloads, and archival/data-owner input.	Medium evidence; treatment Not estimated
RM-2E	2 / PRIV	EXT-PRIV-001	Select a representative extension deployment and trace classified data, metadata, credentials, caches, logs, network flows, artifacts, recipients, and retention to a bounded consequence or negative result. This is evidence acquisition, not assigned urgency.	Deployment sponsor, EXT technical support, data classification, and observable test environment.	Medium
RM-2F	2 / REL	SUP-SAFE-001	Reproduce a concrete producer/consumer mismatch with exact build and runtime profiles, affected artifacts, failure mode, recoverability, population, and recurrence evidence. This is evidence acquisition, not assigned urgency.	INTEROP and downstream owners; representative builds and fixtures.	Medium
RM-2G	2 / PRIV	CORE-PRIV-001 conditionally	Where RM-1D cannot meet policy through minimization and recipient controls, deploy whole-file or equivalent all-metadata protection and test its workflow and recovery behavior. Until verification, avoid the affected sharing boundary or maintain tested access restriction within the Near-term clock. Covers CORE-PRIV-S4.	RM-1D; supported encryption design, named key custodian, protected key lifecycle, backup, and tested recovery procedure.	Large
RM-3A	3 / CORE	CORE-SEC-001, CORE-SEC-002, APP-SEC-004, IND-SAF-001, IND-SAF-002	Create the versioned machine-readable invariant registry and mandatory checked arithmetic, bounds, allocation, and traversal primitives. Covers CORE-S1 and CORE-S3.	RM-1B; RM-2C is a coordination input only for compatibility-sensitive tranches, and work can begin with the existing CVE corpus.	Large
RM-3B	3 / CORE	CORE-SEC-001, CORE-SEC-002	Migrate prioritized structures from direct object construction to bounded raw decode, semantic validation, and construction. Covers CORE-S2.	RM-3A; migrate in independently releasable component tranches.	Large

Table 29 – Proposed mitigation work packages, continued

ID	Phase / owner	Records	Scope and recommendation coverage	Dependencies	Effort
RM-3C	3 / CORE	CORE-SEC-001, CORE-SEC-002, CORE-TOOL-001	Make class closure auditable through structure-aware fuzzing, permanent malformed-input regression, parser-review gates, tool coverage, and public metrics. Covers CORE-S0, CORE-S5-CORE-S7, CORE-S9, and CORE-S12.	RM-3A for invariant identifiers; harness and corpus work may begin in Phase 1.	Large
RM-3D	3 / EXT	APP-SEC-005; EXT-PRIV-001 conditionally	Establish explicit plugin policy, allowlisted paths and identities, manifests, resource limits, and tested signature enforcement; add extension privacy documentation and introspection where the bounded evidence supports it. Covers CORE-S10, APP-S5, CORE-PRIV-S2, VOL-S1-VOL-S3, FILTER-S1, FILTER-S2, FILTER-S5, VFD-S1, VFD-S3, and VFD-S4.	RM-2A for profile policy; privacy-specific prioritization uses RM-2E.	Large
RM-3E	3 / REL	SUP-SAFE-001; all records supported	Publish source and binary SBOMs, pinned dependency and action policy, signed artifacts, verifiable provenance, and runtime/build feature reporting; maintain a producer/consumer profile matrix with deterministic diagnostics and repair, rebuild, or migration paths for supported mismatches. Covers CORE-S11, APP-S6, and SUP-S1.	RM-1A; mismatch-specific treatment uses evidence from RM-2F.	Large
RM-3F	3 / PRIV	EXT-PRIV-001 conditionally	Implement extension privacy-lifecycle controls supported by RM-2E: metadata and cache minimization, privacy-aware connector development, whole-file protection where filter metadata are sensitive, secure temporary-artifact handling, and retention/deletion controls. Covers CORE-PRIV-S3, VOL-S4, FILTER-S3, FILTER-S4, and VFD-S2.	RM-1D, RM-2E; encryption work also requires the key-management and recovery controls in RM-2G.	Large
RM-4A	4 / GOV	All records	Operate the release gates and metrics, re-run applicability and residual-risk reviews, maintain the differential corpus, and close or re-plan exceptions. Sustains CORE-S0, CORE-S6-CORE-S8, CORE-S12, CORE-S11, IND-S1, APP-S6, APP-S7, and SUP-S1.	Begins with Phase 1 evidence and absorbs each accepted package; it does not wait for all Phase 3 work to finish.	Medium (recurring)

B.4. Acceptance and Closure Evidence

A work package is complete only when its artifacts are linked from the implementation record and reproduced or otherwise independently verified by the assigned ASSURE role before acceptance by the accountable role. Shipping code or publishing guidance alone does not establish control coverage or reduce residual risk.

Table 30 – Required work-package acceptance evidence

Package	Required observable evidence	Closure decision
RM-0A	Configuration or code diff; deployment proof; negative fixtures for every supported external-resource form; sandbox escape test; credential and secret-rotation record where indicated.	APP confirms containment; GOV records whether incident handling remains open.
RM-1A	Machine-readable inventory recording version, linkage, enabled features, scope tag, trust boundary, authority, exposure, owner, census boundary and completeness attestation, and evidence date for each applicable scope.	GOV accepts applicability and creates dated treatment or non-applicability records.
RM-1B	Supported-version matrix; patch or isolation record; minimized fixtures; ASan/UBSan/LSan and controlled-error results for affected core and tool paths.	CORE accepts technical evidence; GOV records current residual risk.
RM-1C	Application version and rollout evidence; tests proving safe-mode code rejection, external-path rejection, allocation-budget enforcement, and plugin-path ownership; a canary plugin placed in the current directory, an environment-selected path, and a user-writable searched path must not load or execute, and startup evidence must record the effective plugin-loading state.	APP accepts each deployed boundary; GOV records current residual risk.

Table 30 – Required work-package acceptance evidence, continued

Package	Required observable evidence	Closure decision
RM-1D	Metadata/data-flow inventory, classification and recipient matrix, and before/after inspection through both HDF5 APIs and raw-byte search showing the effect of minimization and recipient controls.	PRIV signs the disclosure-boundary decision and whether RM-2G is required; GOV records current residual risk.
RM-2A	API and policy documentation; default-state tests; hostile-file integration corpus; allocation, traversal, metadata, filter-expansion, external-resource, and plugin tests; a file-replacement test proving preflight and runtime enforcement cannot diverge; tool-default tests.	CORE accepts the core control; GOV records the scope for which it may be credited.
RM-2B	Per-downstream policy and integration tests; before-allocation budget tests for extreme, overflow-boundary, cumulative, and valid boundary cases; external-resource rejection; file-replacement test; deployment evidence.	APP accepts each independently governed integration; GOV records credited coverage and current residual risk.
RM-2C	Versioned positive and negative fixture corpus with writer, reader, format-bound, and expected-result metadata; supported-reader matrix; exact release/backport verification; acceptance of the sufficient nonminimal fixture and predictable rejection of an undersized comparator; corrected writer round-trip; complete in-scope legacy enumeration; and repaired-file pre/post checksums, provenance, and supported-reader acceptance.	INTEROP accepts conformance results and documents unresolved compatibility exceptions.
RM-2D	Fault-injection matrix and logs recording API sequence, version, VFD/filesystem/buffering profile, error, durable file state, recovery result, data uniqueness, and affected workload boundary.	CORE and the data owner submit the bounded result to GOV; an inconclusive study remains open and is re-planned.

Table 30 – Required work-package acceptance evidence, continued

Package	Required observable evidence	Closure decision
RM-2E	Reproducible extension data-flow test, classified sub-population, recipients, storage and network endpoints, cache/log/artifact retention, control evidence, and bounded consequence or negative result.	PRIV and EXT submit the result to GOV; a negative disposition requires a documented method, tested scope and population, and retained results, while an inconclusive study remains open.
RM-2F	Exact producer and consumer build/runtime profiles, reproducible fixture and diagnostic, affected artifact inventory, recoverability, population, and recurrence results.	REL and INTEROP submit the result to GOV; a negative disposition requires a documented method and tested scope, while an inconclusive study remains open.
RM-2G	Ciphertext and metadata inspection, unauthorized-open test, partial-I/O workflow test, protected key inventory, backup/restore evidence, and successful loss-and-recovery exercise.	PRIV and the key custodian accept confidentiality and recoverability; GOV records credited scope and current residual risk.
RM-3A	Versioned invariant files; code-to-invariant mapping; checked primitive APIs; migration inventory; tests showing the prioritized structures reject single-invariant violations predictably.	CORE accepts each declared tranche; missing structures remain open.
RM-3B	Per-component raw-decode/validate/construct boundary; no native object before validation; malformed and valid compatibility corpus results; sanitizer and fuzz evidence.	CORE closes only named migrated components, not the parser class globally.

Table 30 – Required work-package acceptance evidence, continued

Package	Required observable evidence	Closure decision
RM- 3C	PR, nightly, weekly, release-candidate, and CVE-closure jobs; retained minimized seeds; coverage by structure; review-checklist records; metric dashboard and failure-blocking proof.	CORE and GOV approve the release gate; every bypass is named and expiring.
RM- 3D	Plugin manifest and policy; protected allowlist or keystore; tests rejecting unsigned, untrusted, writable-path, over-budget, and wrong-profile plugins; extension data-flow documentation and introspection tests.	EXT accepts technical coverage; PRIV accepts privacy claims; GOV records residual risk for affected findings only.
RM- 3E	Release SBOMs, checksums, signatures, provenance verification, pinned automation, dependency scans, a consumer-visible build/runtime feature report, and a versioned producer/consumer profile matrix with expected outcomes and a finite supported-profile catalog, fixture set, and retained CI execution results. Every incompatible supported pair has a tested deterministic repair, rebuild, migration, controlled rejection with a supported alternative, or accountable exception.	REL accepts the release evidence; mismatches become dated defects or scoped findings.
RM- 3F	Tests and artifacts showing minimized connector metadata and caches, secure temporary-buffer/file handling, enforced retention and deletion, and, where required, ciphertext inspection plus key-loss/recovery testing for filter metadata.	PRIV accepts the bounded lifecycle claims after ASSURE verification; unsupported claims remain open.
RM- 4A	Cadenced gate results, trend metrics, updated finding mappings, expired-exception report, and signed residual-risk decisions for the release or review period.	GOV accepts, further reduces, avoids, transfers, or escalates each verified residual risk.

B.5. Finding and Evidence-Action Coverage

The mapping below prevents a roadmap phase from being declared complete while an in-scope register record has silently disappeared. A formal finding closes only after its stated affected scope is treated or shown not applicable and its current residual risk is reassessed. Closing a work package does not change the historical inherent rating. The package column distinguishes the minimum treatment needed to reassess the concrete finding from continuing class-prevention and sustainment work. A later architectural package does not hold a finding open unless it is selected and credited as that finding's treatment; its own program commitment remains open independently. Evidence records are complete only after the bounded study is dispositioned; they are not assigned a tier merely because the investigation is scheduled, and an inconclusive study remains open and is re-planned.

Table 31 – Register-to-roadmap coverage

Register record	Treatment; continuing prevention	Record-level completion condition
CORE-SEC-001	Treatment: RM-1A, RM-1B. Prevention: RM-2A, RM-3A–RM-3C, RM-4A.	Affected populations are patched or contained and residual scope and risk are recorded. Credited structural tranches pass separately; unimplemented components are not claimed as covered.
CORE-SEC-002	Treatment: RM-1A, RM-1B. Prevention: RM-2A, RM-2C, RM-3A–RM-3C, RM-4A.	Affected populations are patched, contained, or shown to reject or bound file-controlled work; the residual decision states whether compatibility-policy work is credited or remains open.
CORE-TOOL-001	Treatment: RM-1A, RM-1B. Prevention: RM-2A, RM-3C, RM-4A.	Affected tools are patched or isolated and reject the fixture without sanitizer findings; continuing tool gates remain tracked independently.

Table 31 – Register-to-roadmap coverage, continued

Register record	Treatment; continuing prevention	Record-level completion condition
CORE-PRIV-001	Treatment: RM-1A, RM-1D; conditional RM-2G. Sustain: RM-4A.	The actual metadata population and recipients are bounded; minimization and recipient controls pass API and raw-byte inspection; when policy requires encryption, key recovery also passes; remaining disclosure is accepted or further treated.
CORE-SAFE-001	Evidence: RM-2D.	The bounded study is completed and supports a rating and routing decision or a documented negative result over the tested scope. An inconclusive result remains open and re-planned; NE is never converted to Low by schedule alone.
APP-SEC-001	Treatment: RM-0A, RM-1A, RM-1C. Prevention: RM-2A, RM-2B, RM-4A.	The defined census boundary has a completeness attestation; every equivalent deployment found within it is contained, external-resource tests pass, and current residual risk is recorded. Closure of one instance does not close other or unscoped populations; the historical incident tier remains unchanged and later shared architecture stays open independently.
APP-SEC-002	Treatment: RM-1A, RM-1C. Sustain: RM-4A.	Affected loader versions are removed or contained and safe-mode negative tests pass in each deployed boundary.

Table 31 – Register-to-roadmap coverage, continued

Register record	Treatment; continuing prevention	Record-level completion condition
APP-SEC-003	Treatment: RM-1A, RM-1C; RM-0A when a Critical-equivalent service exposure is confirmed. Prevention: RM-2A, RM-2B, RM-4A.	Affected loaders reject or sandbox all supported external-resource forms and deployment evidence supports the residual decision.
APP-SEC-004	Treatment: RM-1A, RM-1C. Prevention: RM-2A, RM-2B, RM-4A.	Affected loaders enforce tested overflow-safe per-object and aggregate budgets before allocation; later reusable APIs remain independent program work.
APP-SEC-005	Treatment: RM-1A, RM-1C. Prevention: RM-3D, RM-4A.	Affected versions are fixed or contained; startup state and planted CWD, environment-path, and writable-path canaries prove that untrusted plugins do not load or execute.
IND-SAF-001	Treatment: RM-1A, RM-2C. Prevention: RM-3A, RM-4A.	Exact supported release/backport artifacts accept the sufficient nonminimal fixture and predictably reject the undersized invalid comparator.
IND-SAF-002	Treatment: RM-1A, RM-2C. Prevention: RM-3A, RM-4A.	Corrected writer output round-trips; the complete defined legacy population is inventoried; and repaired files preserve recorded checksums and provenance and pass supported readers, or have an accountable deterministic disposition.

Table 31 – Register-to-roadmap coverage, continued

Register record	Treatment; continuing prevention	Record-level completion condition
EXT-PRIV-001	Evidence: RM-2E. Conditional treatment: RM-3D, RM-3F.	The bounded study is completed; a negative disposition identifies its tested method, scope and population, an inconclusive result remains open, and a formal rating and treatment follow only if a concrete affected population and harm are supported.
SUP-SAFE-001	Evidence: RM-1A, RM-2F. Conditional treatment: RM-3E.	The bounded mismatch study is completed and routed or records a documented negative result over the tested profile population; an inconclusive result remains open and re-planned.

B.6. Change Control and Residual Risk

Each implementation record should contain the package identifier, named accountable person, responsible implementer, independent verifier, release or deployment approver, affected scope, linked findings and recommendations, linked finding-and-scope SLA child records, trigger event, trigger owner, actual trigger date, recommended maximum horizon, approved committed date or release, hard and coordination dependencies with their owner and state, effort estimate and assumptions, status, evidence links, target residual tier and status with its scope and assumptions, named risk- tolerance authority, exception identifier, reassessment trigger, and the last decision date. Status should use *Proposed*, *Accepted*, *In progress*, *Blocked*, *Implemented pending verification*, *Verified*, *Deferred under exception*, *Risk accepted*, or *Superseded*. A missed due-date event is recorded immutably as *Overdue*; a later active exception may add *Deferred under exception* for the exact scope but does not erase the miss. Blocked, deferred, accepted, or superseded work requires an explanatory decision record.

Any horizon, gate, control, compatibility, or residual-risk exception requires a named GOV approver, rationale, affected scope and unmet requirement, interim or compensating controls with evidence, monitoring owner and cadence, issue date, expiration date, and automatic reopen or reassessment triggers. Exceptions do not revise inherent risk and cannot be indefinite. No exception permits a known, uncontained Critical-equivalent external-resource path to continue untrusted processing: the path is contained or the job is stopped; an exception may govern only later treatment or architecture.

After acceptance testing, the implementer supplies the artifacts, ASSURE verifies them, the package owner attests readiness, and the release or deployment approver authorizes rollout. The named GOV risk authority then reassesses current residual risk using Section 1.7, identifies the controls actually credited, and records a decision to accept, further reduce, avoid, or transfer the remaining risk. Target residual risk is not marked achieved before that review, and the verified current residual is recorded as the later result. Each reassessment is a dated, immutable snapshot with its scope, assumptions, verifier, and evidence; it does not overwrite the original inherent assessment.

The roadmap authority should review Phases 0–2 at least weekly while open, Phase 3 at each planned release gate, and Phase 4 at its stated cadence. New findings enter the response route first and are then mapped to the earliest work package capable of meeting that route; they are not assigned a phase from recommendation numbering or implementation convenience. Event-driven reassessment is also required after a control failure, new incident or reproducer, materially changed HDF5 or downstream release/default, changed trust boundary, privilege, automation, data sensitivity or dependency, fuzz or telemetry regression, and exception expiry. For recurring RM–4A work, each review produces a dated point-in-time verification snapshot rather than a permanent completion claim. A later gate failure, event trigger, or affected release reopens the scoped record and creates a new SLA child and reassessment snapshot while preserving the prior history.

C. CVE History Summary

Table 32 – HDF5 CVE history summary

CVE(s)	Affected area	Reported failure mode	Root cause summary
CVE-2025-7069, CVE-2025-6270, CVE-2025-2914	file-space info / free-space manager	heap buffer overflow	file-derived file-space metadata, especially page size / section data, was accepted without sufficient sanity checks. Fix rejects invalid page size and corrupted free-space info early.
CVE-2025-6858, CVE-2025-6817, CVE-2025-2913, CVE-2025-2912	object-header / metadata-cache cascade	null dereference, resource consumption, use-after-free, heap overflow	corrupted object-header continuation metadata caused later cache/free-list/object-message failures. Root cause is bad continuation-message size/state not rejected at decode time.
CVE-2025-6856, CVE-2025-6816, CVE-2025-2923	object-header continuation messages	heap buffer overflow / use-after-free	crafted object header with continuation message pointing back to itself led to under-sized internal buffer allocation. Fix compares expected and actual object-header chunk counts during deserialization.
CVE-2025-6750, CVE-2024-33874	mtime object-header messages	heap buffer overflow	old/new modification-time messages were not properly decoded; an invalid message size could produce a zero-size buffer passed to an encoder. Fix decodes both mtime formats and rejects invalid size.
CVE-2025-6269, CVE-2025-6516	metadata cache image / address decode	heap buffer overflow	cache-image reconstruction used insufficient bounds and input validation. Fix adds buffer-size tracking, overflow checks, input validation, and cleanup on failure.
CVE-2025-44905, CVE-2025-2308, CVE-2024-29159, CVE-2024-32615, CVE-2016-4331	scale-offset / n-bit filters	heap overflow / buffer overrun / arbitrary code execution	filter decoders trusted encoded precision, byte counts, or scale-offset parameters from the file. Root cause is insufficient bounds checking in decompression/filter parameter handling.
CVE-2025-44904, CVE-2024-32614, CVE-2024-32605, CVE-2024-29165, CVE-2019-9151, CVE-2018-14035, CVE-2018-13875, CVE-2018-11205	vectorized memory copy / scatter-fill paths	heap/stack overflow or over-read	memory-vector copy routines copied between mismatched source/destination selections or trusted element counts too far. Root cause is insufficient validation of vector extents and copy sizes before memcpy-style operations.
CVE-2025-2926	object-header cache checksum serialization	null pointer dereference	object-header checksum/serialization path could operate on incomplete or invalid object-header state. Root cause is missing null/state validation before serialization.
CVE-2025-2925	memory management wrapper	double free	reallocation/error path mishandled ownership of mem. Root cause is ambiguous ownership/cleanup semantics around failed or edge-case realloc.
CVE-2025-2924, CVE-2024-32613, CVE-2024-32612	local heap free-list deserialization	heap buffer overflow	local-heap free-block metadata from the file was trusted. Root cause is insufficient validation of free-block size/offset before rebuilding heap structures.

Table 32 – HDF5 CVE history summary, continued

CVE(s)	Affected area	Reported failure mode	Root cause summary
CVE-2025-2915, CVE-2018-13867	file accumulator	heap overflow / out-of-bounds read	accumulator overlap/offset math accepted invalid ranges. Root cause is weak range validation for file accumulator reads/frees.
CVE-2025-2310, CVE-2019-9152	datatype / attribute string decoding	heap buffer overflow / out-of-bounds read	string duplication from metadata used file-derived length or unterminated data. Root cause is unsafe string length handling during datatype/attribute decode.
CVE-2025-2309, CVE-2024-29163	datatype bit operations	heap buffer overflow	bit-copy / bit-find logic trusted bit offsets, lengths, or precision metadata. Root cause is insufficient bounds checking in datatype bitfield operations.
CVE-2025-2153	shared-message deletion	heap buffer overflow	shared-message deletion path could process corrupted shared-message/object-header state. Root cause appears to be insufficient validation of shared-message metadata and cleanup state before deletion.
CVE-2025-26200, CVE-2024-33877, CVE-2017-17507	compound datatype conversion	heap overflow / out-of-bounds read/write	compound datatype conversion trusted complex datatype layout details. Root cause is unsafe datatype conversion when member layout, unused bits, or conversion metadata are malformed.
CVE-2024-33876	point selection deserialization	heap overflow	serialized point-selection metadata was trusted. Root cause is missing bounds/count validation when rebuilding point selections.
CVE-2024-33875, CVE-2019-8396	dataset layout encode	heap/buffer overflow	dataset layout metadata could encode inconsistent dimensions/storage sizes. Fix family adds dataset layout size checks, multiplication overflow checks, and file-bound checks.
CVE-2024-33873	dataset scatter memory	heap overflow	scatter operation accepted inconsistent memory/file selection sizes. Root cause is insufficient validation of selected element counts and destination capacity.
CVE-2024-32624, CVE-2024-32610	reference datatype memory nulling	heap overflow	reference-memory initialization/nulling used malformed datatype/reference metadata. Root cause is missing size/type validation before clearing reference memory.
CVE-2024-32623	generic array fill	heap overflow	array fill operation trusted element count/size metadata. Root cause is missing multiplication/range validation before filling memory.
CVE-2024-32622, CVE-2024-29158, CVE-2024-29161 note	free-list array allocation	out-of-bounds read / stack overflow	array allocation/free-list path accepted invalid counts or sizes. Root cause is weak validation of allocation quantity derived from file metadata.
CVE-2024-32621, CVE-2024-29162, CVE-2024-29157	global heap read	heap/stack overflow	global heap object size/offset metadata could be inconsistent with actual buffer. Root cause is insufficient validation of heap object boundaries before read.
CVE-2024-32620, CVE-2025-6516, CVE-2021-45830, CVE-2018-13866	address-length decode	heap/stack overflow / over-read	encoded file addresses/lengths could exceed expected bounds. Root cause is insufficient validation of decoded address/length byte counts and destination capacity.

Table 32 – HDF5 CVE history summary, continued

CVE(s)	Affected area	Reported failure mode	Root cause summary
CVE-2024-32619, CVE-2018-14031	datatype copy/reopen	heap overflow / over-read	datatype copy path accepted malformed nested datatype metadata. Root cause is missing validation while copying or reopening datatype structures.
CVE-2024-32618	native datatype conversion	heap overflow	native-type construction trusted malformed datatype metadata. Root cause is inadequate validation during recursive datatype normalization.
CVE-2024-32617	H5MM_xstrdup	heap overflow	unsafe string duplication from file-derived metadata. Root cause is missing bounded string handling.
CVE-2024-32616	datatype object-header encode helper	heap overflow	datatype message encode helper accepted inconsistent datatype message size/state. Root cause is missing encode-time size validation.
CVE-2024-32611	attribute release table	uninitialized value / DoS	attribute-table bookkeeping conflated allocated capacity and actual attribute count. Fix separates current count and maximum capacity and cleans partial tables on error.
CVE-2024-32608, CVE-2024-32607	attribute close	memory corruption / segfault	attribute close/release path could operate on partially initialized or corrupted attribute state. Root cause is unsafe cleanup after failed attribute-table construction or decode.
CVE-2024-32606	h5tools string printing	uninitialized dereference / DoS	tool-side string formatting could dereference uninitialized values. No commit URL listed, so fix review was not possible.
CVE-2024-29166	link-info decode	buffer overrun	object link-info metadata decode trusted malformed encoded size/flags. No commit URL listed.
CVE-2022-26061, CVE-2022-25972, CVE-2022-25942, CVE-2020-10809, CVE-2018-17436, CVE-2018-17433	gif2h5 tool / GIF parser	heap overflow, out-of-bounds write/read, invalid write	legacy GIF conversion code parsed attacker-controlled GIF/HDF inputs unsafely. Commentary says the tool was removed rather than surgically hardened.
CVE-2021-46244	datatype copy completion	divide by zero / DoS	datatype copy logic failed to guard arithmetic denominators or zero-sized datatype state.
CVE-2021-46243	datatype object-header decode	untrusted pointer dereference / DoS	datatype decode accepted malformed pointer/metadata state. Root cause is missing validation before dereference.
CVE-2021-46242, CVE-2020-10810	metadata cache pin/unpin	use-after-free / null dereference	cache entry lifecycle operations did not robustly handle malformed or unexpected cache state.
CVE-2021-45833	chunk file-map hyperslab	stack overflow / DoS	chunk/hyperslab mapping trusted malformed dataspace/chunk metadata. Root cause is inadequate bounds checking in chunk mapping.
CVE-2021-45832	error stack internals	stack overflow / DoS	listed as cannot reproduce; no fix commit. Treat root cause as unconfirmed.
CVE-2021-45829	unspecified HDF5 path	segfault / DoS	Root cause undetermined.
CVE-2021-37501	h5dump string sprint	buffer overflow / DoS	h5dump formatting path wrote beyond buffer while rendering file-derived data.
CVE-2021-36977	mat file I/O library using HDF5	heap overflow	not filed against HDF5. Root cause belongs to downstream integration/context, not the HDF5 fix set.

Table 32 – HDF5 CVE history summary, continued

CVE(s)	Affected area	Reported failure mode	Root cause summary
CVE-2021-31009	Apple platform issue	multiple HDF5 issues	not filed against HDF5; fixed by Apple by removing HDF5 from affected components.
CVE-2020-18494, CVE-2020-18232	dataspace close	buffer overflow / possible RCE	malformed file could corrupt dataspace cleanup/close state. Root cause is unsafe lifecycle handling of malformed dataspace metadata.
CVE-2020-10812	file reference count query	null pointer dereference / DoS	file query path failed to validate file/reference state before dereference.
CVE-2020-10811, CVE-2018-14033	layout decode	heap over-read	dataset layout message decoder trusted encoded layout fields. Root cause is missing bounds checks around decoded layout data.
CVE-2019-8398, CVE-2019-8397	datatype size/close	out-of-bounds read	datatype object state could be malformed before size/close operations. No commit URL listed.
CVE-2018-17439	dataspace extent dimensions during HDF to GIF conversion	stack overflow	conversion tool path trusted dataspace dimensions from file.
CVE-2018-17438	selected I/O	divide by zero / DoS	selected-I/O path failed to guard divisor/count metadata from crafted file. Tool-removal commit, so the listed fix is coarse.
CVE-2018-17437	datatype decode helper	memory leak / DoS	error path leaked allocations when datatype metadata was malformed.
CVE-2018-17435	attribute decode	heap over-read	attribute message decoder trusted encoded sizes/offsets.
CVE-2018-17434	h5repack filter application	divide by zero / DoS	tool-side filter setup failed to guard zero-valued filter/chunk parameters.
CVE-2018-17432	simple dataspace encode	null pointer dereference / DoS	dataspace encode path accepted invalid dataspace state before dereference.
CVE-2018-17237, CVE-2018-17233, CVE-2018-11207, CVE-2018-11203, CVE-2017-17508	chunking / b-tree / datatype arithmetic	divide by zero / SIGFPE / DoS	crafted file could set chunk, b-tree, datatype, or layout parameters to zero. Root cause is missing arithmetic precondition checks.
CVE-2018-17234, CVE-2018-13873, CVE-2018-11204	object-header chunk deserialize	memory leak / over-read / null dereference	object-header chunk deserialization accepted malformed chunk metadata and mishandled error cleanup.
CVE-2018-16438	external links	out-of-bounds read	external-link query trusted malformed external-link metadata.
CVE-2018-15672, CVE-2018-14032	duplicate/rejected IDs	not applicable	rejected duplicate CVEs; no HDF5 root cause to summarize beyond the referenced canonical CVEs.
CVE-2018-15671	property-list callback lookup	excessive stack consumption / DoS	recursive or malformed property-list callback state allowed stack exhaustion.
CVE-2018-14460	simple dataspace decode	heap over-read	dataspace message decoder trusted encoded extent/rank metadata.
CVE-2018-14034	filter pipeline reset	out-of-bounds read	malformed filter-pipeline metadata caused unsafe reset/read behavior. No commit URL listed.

Table 32 – HDF5 CVE history summary, continued

CVE(s)	Affected area	Reported failure mode	Root cause summary
CVE-2018-13876, CVE-2018-13874	sec2 VFD read path	stack overflow	low-level file-driver read/memset path could be driven out of bounds by malformed file metadata. No commit URL listed.
CVE-2018-13872	group entry decode	heap overflow	group-entry decoder trusted malformed symbol-table/group metadata. No commit URL listed.
CVE-2018-13871	free-list block allocation	heap overflow	free-list block allocator accepted invalid allocation size/count.
CVE-2018-13870, CVE-2018-13869	link decode	heap over-read / overlapping memcpy	link-message decoder trusted malformed link metadata, including overlapping source/destination regions.
CVE-2018-13868	old fill-value decode	heap over-read	old fill-value decoder trusted encoded fill-value size. No commit URL listed.
CVE-2018-11206	fill-value decode	out-of-bounds read / possible disclosure	fill-value message decoders trusted encoded size/type fields.
CVE-2018-11202	hyperslab spans	null pointer dereference / DoS	hyperslab span construction failed to validate malformed selection state.
CVE-2017-17509	group cache entry decode vector	out-of-bounds write	group-entry vector decoder trusted file-derived counts/array bounds. No commit URL listed.
CVE-2017-17506, CVE-2017-17505	filter pipeline decode	out-of-bounds read / null dereference	pipeline decoder failed to validate malformed filter counts or fields. No commit URL listed.
CVE-2016-4333	array allocation / initialization loop	out-of-bounds write	file-controlled value could modify loop termination while initializing an allocated array.
CVE-2016-4332	object-header message flags	heap out-of-bounds write / code execution	library failed to check whether a message type supported a flag before casting to an incompatible structure.
CVE-2016-4330	dataspace rank/dimensions	array heap overflow / code execution	file-supplied array dimensionality was not checked against allocated space.

D. Software Supply Chain Details

The `HDF5_ALLOW_EXTERNAL_SUPPORT` modes apply to filter-related dependencies. Some test and example configurations have their own source-fetch paths, such as KWSys for the API test driver and h5py for Python examples. MPI, HDFS, ROS3, OpenSSL, Java, documentation, packaging, and developer tools must be provided by the build environment.

Table 33 – Dependency source modes

Mode	Relevant options	Meaning
System packages	<code>HDF5_ALLOW_EXTERNAL_SUPPORT=NO</code>	CMake uses <code>find_package()</code> , <code>find_library()</code> , or <code>find_program()</code> to locate installed dependencies. This is the default.
Git fetch	<code>HDF5_ALLOW_EXTERNAL_SUPPORT=GIT</code> plus a dependency-specific <code>*_USE_EXTERNAL=ON</code> option	CMake downloads source from the configured <code>*_GIT_URL</code> and <code>*_GIT_TAG</code> values and builds it with HDF5.
Tarball fetch	<code>HDF5_ALLOW_EXTERNAL_SUPPORT=TGZ</code> plus a dependency-specific <code>*_USE_EXTERNAL=ON</code> option	CMake downloads from <code>*_TGZ_ORIGPATH</code> and <code>*_TGZ_NAME</code> , or uses <code>TGZPATH</code> when the dependency-specific <code>*_USE_LOCALCONTENT=ON</code> option is set.

Table 34 – Baseline build

Dependency	Trigger	Notes
CMake 3.26 or newer	Always	Required by the top-level <code>cmake_minimum_required()</code> .
C compiler and native build tool	Always	The top-level project is a C project.
Platform C library, headers, and system calls	Always	CMake probes standard headers, types, functions, byte order, large-file support, file locking, <code>pread/pwrite</code> , and related platform features.
Platform link libraries	Platform-dependent	CMake adds libraries only when probes show they are needed: <code>m</code> , <code>dl</code> , <code>rt</code> , <code>posix4</code> , <code>ucb</code> , <code>ws2_32</code> , <code>wsock32</code> , and <code>shlwapi</code> .

PkgConfig	Optional probe	Used only when available. It can help some find modules, such as zlib-ng and libaec, but it is not a hard requirement for the default build.
Threads	Found in every configure; CMake searches for C11 threads, Win32 required by thread features	threads, or pthreads. When found, HDF5 records thread support and links Threads::Threads; HDF5_ENABLE_THREADSAFE, HDF5_ENABLE_CONCURRENCY, and HDF5_ENABLE_SUBFILING_VFD require it.

Table 35 – HDF5 feature triggers

Feature or component	Build options	Dependency	Notes
Parallel HDF5	HDF5_ENABLE_PARALLEL=ON	MPI C with MPI-IO, MPI standard 3.0 or newer	Adds MPI::MPI_C to public link libraries. Parallel filtered writes and large parallel I/O are enabled only when the required MPI symbols are present. Parallel tests also need an MPI launcher such as mpiexec.
Parallel Fortran	HDF5_ENABLE_PARALLEL=ON, HDF5_BUILD_FORTRAN=ON	MPI Fortran	The Fortran build adds MPI Fortran libraries. The mpi_f08 module is used when available.
Thread-safe library	HDF5_ENABLE_THREADSAFE=ON	Threads	Unsupported with parallel, Fortran, C++, or high-level library unless HDF5_ALLOW_UNSUPPORTED=ON. On Windows, static libraries are rejected.

Multi-threaded concurrency	HDF5_ENABLE_CONCURRENCY=ON	Threads	Experimental. Mutually exclusive with HDF5_ENABLE_THREADS; has the same unsupported combinations as thread-safety unless overridden with HDF5_ALLOW_UNSAFE=ON.
C++ wrappers	HDF5_BUILD_CPP_LIB=ON	C++ compiler	Unsupported with parallel unless HDF5_ALLOW_UNSAFE=ON. High-level C++ wrappers also require HDF5_BUILD_HL_LIB=ON.
Fortran wrappers	HDF5_BUILD_FORTRAN=ON	Fortran compiler with Fortran 2003 ISO_C_BINDING support	Unsupported with thread-safety or concurrency unless HDF5_ALLOW_UNSAFE=ON. High-level Fortran wrappers also require HDF5_BUILD_HL_LIB=ON.
Java wrappers	HDF5_BUILD_JAVA=ON	Java/JDK, shared HDF5 libraries, Java dependency JARs	Java requires shared HDF5 libraries. Java 11 or newer is required for the JNI implementation. Java tests additionally require the JUnit and Hamcrest JARs.
Java JNI implementation	HDF5_BUILD_JAVA=ON, HDF5_ENABLE_JNI=ON, or any Java version earlier than 25	JNI headers and libraries	JNI is the default Java implementation. HDFS also requires JNI.
Java FFM implementation	HDF5_BUILD_JAVA=ON, Java 25 or newer, HDF5_ENABLE_JNI=OFF	jextract from JEXTRACT_HOME/bin or JAVA_HOME/bin	Generates FFM bindings at configure time.

Java logging/test JARs	HDF5_BUILD_JAVA=ON	slf4j-api, slf4j-nop, slf4j-simple; plus JUnit 4 and Hamcrest for tests	The default paths point to bundled JARs under java/lib. They can be overridden with HDF5_JAVA*_JAR cache variables. HDF5_ENABLE_MAVEN_DEPLOY=ON generates Maven-style artifacts and POM files; the CMake build does not locate or run mvn.
Documentation	HDF5_BUILD_DOC=ON	Doxygen	HDF5_ENABLE_DOXY_WARNINGS=ON makes Doxygen warnings fail the build.
Header regeneration	HDF5_GENERATE_HEADERS=ON	Perl	Perl is optional otherwise. If it is missing, generated headers are not regenerated.
Python examples	H5EXAMPLE_BUILD_PYTHON=ON	Python3 interpreter, Python development files, NumPy, h5py source, pip	The examples CMake project fetches h5py from Git and installs it with python3 -m pip.

Table 36 – HDF5 filter dependency choices

Feature	Build options	Dependency	Source choices
DEFLATE filter	HDF5_ENABLE_ZLIB_SUPPORT=ON, HDF5_USE_ZLIB_NG=OFF	zlib	System package by default; ZLIB_USE_EXTERNAL=ON can build zlib from Git or TGZ. HDF5_USE_ZLIB_STATIC=ON prefers a static library.

DEFLATE through zlib-ng	filter	HDF5_ENABLE_ZLIB_SUPPORT=ON, HDF5_USE_ZLIB_NG=ON	zlib-ng	System package by default; ZLIB_USE_EXTERNAL=ON can build zlib-ng from Git or TGZ. zlib compatibility mode is detected.
SZIP filter		HDF5_ENABLE_SZIP_SUPPORT=ON	libaec with libsz compatibility, or another package selected by LIBAEC_PACKAGE_NAME	System package by default; SZIP_USE_EXTERNAL=ON can build libaec from Git or TGZ. HDF5_USE_LIBAEC_STATIC=ON prefers static libraries.
HDF5 filter project	filter plugins	HDF5_ENABLE_PLUGIN_SUPPORT=ON	Installed h5pl/HDF5 filter plugins package, or the hdf5_plugins project	PLUGIN_USE_EXTERNAL=ON can build the plugin project from Git or TGZ. Plugin support is disabled for the 1.6 API.

Table 37 – HDF5 VFD and VOL connector dependency choices

Feature	Build options	Dependency	Notes
Direct VFD	HDF5_ENABLE_DIRECT_VFD=ON	POSIX O_DIRECT and posix_memalign() support	No third-party library. Configuration fails if the platform support is missing.
Mirror VFD	HDF5_ENABLE_MIRROR_VFD=ON	POSIX socket/fork headers and functions	No third-party library. Requires netinet/in.h, netdb.h, arpa/inet.h, sys/socket.h, and fork().

ROS3 VFD	HDF5_ENABLE_ROS3_VFD=ON	aws-c-s3 package	CMake	HDF5 does not fetch this library. Building aws-c-s3 from source can also require AWS C libraries such as aws-c-common, aws-checksums, aws-c-cal, aws-c-io, aws-c-compression, aws-c-http, aws-c-sdkutils, aws-c-auth, and, on Linux, aws-lc and s2n-tls. ROS3 docker-proxy tests additionally require docker and the AWS CLI.
HDFS VFD	HDF5_ENABLE_HDFS=ON	JNI/JVM and Hadoop libhdfs		HADOOP_HOME is used to locate hdfs.h, libhdfs, and the Hadoop version command. Non-MSVC builds also add -pthread.
Subfilng VFD and IOC VFD	HDF5_ENABLE_PARALLEL=ON, HDF5_ENABLE_SUBFILING_VFD=ON	MPI C with MPI_Comm_split_type, plus Threads		Not available on Windows. IOC VFD is built when subfilng is enabled.
External VOL connectors	HDF5_VOL_ALLOW_EXTERNAL=GIT LOCAL_DIR HDF5_VOL_URLnn HDF5_VOL_PATHnn	Connector-defined or with or		Up to ten CMake-based VOL connectors can be added. HDF5 patches connector CMake code to use the in-tree HDF5 build, but each connector may bring its own dependencies.

Table 38 – Tools, Tests, and Security Features

Feature	Build options	Dependency	Notes
Signed plugin verification	HDF5_REQUIRE_SIGNED_PLUGINS=ON	OpenSSL 1.1.0 or newer libcrypto	Adds OpenSSL: : Crypto to HDF5. HDF5_LOCK_PLUGIN_KEYSTORE=ON also requires HDF5_PLUGIN_KEYSTORE_DIR.
h5sign tool	HDF5_REQUIRE_SIGNED_PLUGINS=ON, HDF5_BUILD_TOOLS=ON	OpenSSL libcrypto	Used to sign HDF5 plugins.
Signed-plugin tests	HDF5_REQUIRE_SIGNED_PLUGINS=ON, BUILD_TESTING=ON	openssl executable	Tests generate RSA keys with the OpenSSL command-line tool.
Parallel tools utilities	HDF5_ENABLE_PARALLEL=ON, HDF5_BUILD_PARALLEL_TOOLS=ON	MFU, CIRCLE, DTCMP	CMake looks for headers and libraries, using MFU_ROOT as a hint.
API test driver	BUILD_TESTING=ON, HDF5_TEST_API_ENABLE_DRIVER=ON	KWSys	The test driver fetches KWSys from a tarball or from TGZPATH when KWSYS_USE_LOCALCONTENT=ON.
Shell-script tests	BUILD_TESTING=ON	PowerShell or Bash	CMake uses pwsh/powershell when available; otherwise Unix builds look for bash.
ROS3 VFD tests	HDF5_ENABLE_ROS3_VFD=ON, HDF5_ENABLE_ROS3_VFD_DOCKER_PROXY=ON	Docker daemon and AWS CLI	Used to run S3 proxy tests.

Table 39 – Developer and Packaging Dependencies

Configuration	Build options	Dependency
Analyzer tooling	HDF5_ENABLE_ANALYZER_TOOLS=ON	clang-tidy, include-what-you-use, and cppcheck are probed and used by the analyzer macros.
Source formatting targets	HDF5_ENABLE_FORMATTERS=ON	clang-format and cmake-format.
Code coverage with Clang/IntelLLVM	HDF5_ENABLE_COVERAGE=ON, CODE_COVERAGE=ON	llvm-cov and llvm-profdata; AppleClang uses xcrun llvm-cov and xcrun llvm-profdata.
Code coverage with GCC	HDF5_ENABLE_COVERAGE=ON, CODE_COVERAGE=ON	lcov and genhtml; fallback instrumentation can also link gcov.
Sanitizers	HDF5_ENABLE_SANITIZERS=ON, HDF5_USE_SANITIZER=<kind>	Compiler sanitizer runtime support. Supported values depend on compiler and platform.
AFL support module	Explicit inclusion of config/sanitizer/afl-fuzzing.cmake	afl-cc and afl-c++. This module is available but is not included by the top-level HDF5 build by default.
Dependency graph support module	Explicit inclusion of config/sanitizer/dependency-graph.cmake	Graphviz dot. This module is available but is not included by the top-level HDF5 build by default.
Windows installers	CPack on Windows	NSIS and WiX are probed when available.
Linux packages	CPack on Unix-like systems	dpkg-shlibdeps enables DEB generation; rpmbuild enables RPM generation for non-parallel builds.

Table 40 – External Source Defaults

Dependency	Default version/tag	Default source
------------	---------------------	----------------

zlib	1.3.2 / v1.3.2	https://github.com/madler/zlib.git or https://github.com/madler/zlib/releases/download/v1.3.2/zlib-1.3.2.tar.gz
zlib-ng	2.3.3	https://github.com/zlib-ng/zlib-ng.git or https://github.com/zlib-ng/zlib-ng/archive/refs/tags/2.3.3.tar.gz
libaec	1.1.6 / v1.1.6	https://github.com/MathisRosenhauer/libaec.git or https://github.com/MathisRosenhauer/libaec/releases/download/v1.1.6/libaec-1.1.6.tar.gz
HDF5 filter plugins	master	https://github.com/HDFGroup/hdf5_plugins.git or https://github.com/HDFGroup/hdf5_plugins/releases/download/snapshot/hdf5_plugins-master.tar.gz
KWSys API-test helper	master tarball	https://gitlab.kitware.com/utils/kwsys/-/archive/master/kwsys-master.tar.gz
h5py Python examples	master	https://github.com/h5py/h5py.git
bitshuffle	master or 0.5.2 tarball	https://github.com/kiyo-masui/bitshuffle.git or https://github.com/kiyo-masui/bitshuffle/archive/refs/tags/bitshuffle-0.5.2.tar.gz
Blosc	1.21.6	https://github.com/Blosc/c-blosc.git or https://github.com/Blosc/c-blosc/archive/refs/tags/c-blosc-1.21.6.tar.gz
Blosc zlib helper	develop or 1.3.1 tarball	https://github.com/madler/zlib.git or https://github.com/madler/zlib/releases/download/v1.3.1/zlib-1.3.1.tar.gz
Blosc2	2.17.1	https://github.com/Blosc/c-blosc2.git or https://github.com/Blosc/c-blosc2/archive/refs/tags/c-blosc2-2.17.1.tar.gz

Blosc2 zlib helper	develop or 1.3.1 tarball	https://github.com/madler/zlib.git or https://github.com/madler/zlib/releases/download/v1.3.1/zlib-1.3.1.tar.gz
bzip2	bzip2-1.0.8	https://github.com/libarchive/bzip2.git or https://github.com/libarchive/bzip2/archive/refs/tags/bzip2-bzip2-1.0.8.tar.gz
fpzip	develop or 1.3.0 tarball	https://github.com/LLNL/fpzip.git or https://github.com/LLNL/fpzip/releases/download/1.3.0/fpzip-1.3.0.tar.gz
JPEG	jpeg-9e	https://github.com/libjpeg-turbo/libjpeg-turbo.git or https://www.ijg.org/files/jpegsrc.v9e.tar.gz
LZ4	dev or 1.10.0 tarball	https://github.com/lz4/lz4.git or https://github.com/lz4/lz4/releases/download/v1.10.0/lz4-1.10.0.tar.gz
LZF	3.6 tarball	http://dist.schmorp.de/liblzf/liblzf-3.6.tar.gz
SZ	master or 2.1.12.5 tarball	https://github.com/szcompressor/SZ.git or https://github.com/szcompressor/SZ/releases/download/v2.1.12.5/SZ-2.1.12.5.tar.gz
ZFP	develop or 1.0.1 tarball	https://github.com/LLNL/zfp.git or https://github.com/LLNL/zfp/releases/download/1.0.0/zfp-1.0.1.tar.gz
Zstandard	1.5.7	https://github.com/facebook/zstd.git or https://github.com/facebook/zstd/releases/download/v1.5.7/zstd-1.5.7.tar.gz
